



201~307

▼ 1

▼ 英文:

A security analyst attempted to troubleshoot the monitoring of suspicious security group changes. The analyst was told that there is an Amazon CloudWatch alarm in place for these AWS CloudTrail log events. The analyst tested the monitoring setup by making a configuration change to the security group but did not receive any alerts.

Which of the following troubleshooting steps should the analyst perform?

- A. Ensure that CloudTrail and S3 bucket access logging is enabled for the analyst's AWS account.
- B. Verify that a metric filter was created and then mapped to an alarm. Check the alarm notification action.
- C. Check the CloudWatch dashboards to ensure that there is a metric configured with an appropriate dimension for security group changes.
- D. Verify that the analyst's account is mapped to an IAM policy that includes permissions for `cloudwatch:GetMetricStatistics` and `cloudwatch:ListMetrics`.

▼ 中文:

一名安全分析师尝试排查可疑安全组更改的监控问题。分析师被告知，针对这些 AWS CloudTrail 日志事件已经设置了一个 Amazon CloudWatch 警报。分析师通过对安全组进行配置更改来测试监控设置，但未收到任何警报。以下哪项排查步骤是分析师应该执行的？

- A. 确保 CloudTrail 和 S3 bucket 访问日志记录已为分析师的 AWS 账户启用。

B.验证是否已创建一个指标过滤器并映射到警报。检查警报通知操作。

C.检查 CloudWatch 仪表板以确保已配置一个具有适当维度的指标用于安全组更改。

D.验证分析师的账户是否映射到包含 cloudwatch:GetMetricStatistics 和 cloudwatch:ListMetrics 权限的 IAM 策略。

▼ 答案:

B

题目分析与解答

1. 考察的知识点

本题考察的是如何正确配置和排查 Amazon CloudWatch 与 AWS CloudTrail 的集成，用于监控安全组的更改事件。

涉及的知识点包括:CloudTrail日志记录、CloudWatch指标过滤器、警报通知配置、IAM权限等。

2. 选项分析

A. Ensure that CloudTrail and S3 bucket access logging is enabled for the analyst's AWS account.

错误:虽然启用CloudTrail是监控安全组更改的前提，但题目中并未提到CloudTrail未启用的问题。S3 bucket访问日志记录与本题无关，因为它主要用于监控S3存储桶的访问行为，而不是安全组的更改。

B. Verify that a metric filter was created and then mapped to an alarm. Check the alarm notification action.

正确:CloudTrail日志需要通过CloudWatch的指标过滤器提取相关事件，并映射到警报。没有正确配置指标过滤器或警报通知动作会导致无法收到警报。

C. Check the CloudWatch dashboards to ensure that there is a metric configured with an appropriate dimension for security group changes.

错误:CloudWatch仪表板用于可视化指标，但它与警报的触发和通知无关。题目中没有提到仪表板的配置问题。

D. Verify that the analyst's account is mapped to an IAM policy that includes permissions for cloudwatch:GetMetricStatistics and cloudwatch:ListMetrics.

错误:这些权限用于访问CloudWatch指标统计数据 and 列出指标，与警报的触发和通知无直接关系。题目中没有提到权限不足的问题。

▼ 2

▼ 英文:

An Amazon API Gateway API invokes an AWS Lambda function that needs to interact with a software-as-a-service (SaaS) platform. A unique client token is generated in the SaaS platform to grant access to the Lambda function. A security engineer needs to design a solution to encrypt the access token at rest and pass the token to the Lambda function at runtime.

Which solution will meet these requirements MOST cost-effectively?

- A. Store the client token as a secret in AWS Secrets Manager. Use the AWS SDK to retrieve the secret in the Lambda function.
- B. Configure a token-based Lambda authorizer in API Gateway.
- C. Store the client token as a SecureString parameter in AWS Systems Manager Parameter Store. Use the AWS SDK to retrieve the value of the SecureString parameter in the Lambda function. Most Voted.
- D. Use AWS Key Management Service (AWS KMS) to encrypt the client token. Pass the token to the Lambda function at runtime through an environment variable.

▼ 中文:

一个 Amazon API Gateway API 调用一个需要与软件即服务 (SaaS) 平台交互的 AWS Lambda 函数。在 SaaS 平台中生成一个唯一的客户端令牌，以授予 Lambda 函数访问权限。一名安全工程师需要设计一个解决方案，以加密静态存储的访问令牌，并在运行时将令牌传递给 Lambda 函数。

哪个解决方案将以最具成本效益的方式满足这些要求？

- A. 将客户端令牌作为秘密存储在 AWS Secrets Manager 中。在 Lambda 函数中使用 AWS SDK 检索秘密。
- B. 在 API Gateway 中配置基于令牌的 Lambda 授权器。
- C. 将客户端令牌作为 SecureString 参数存储在 AWS Systems Manager Parameter Store 中。在 Lambda 函数中使用 AWS SDK 检索 SecureString 参数的值。
- D. 使用 AWS Key Management Service (AWS KMS) 加密客户端令牌。通过环境变量在运行时将令牌传递给 Lambda 函数。

▼ 答案:

C

1. 考察的知识点

安全存储敏感数据(如访问令牌)的最佳实践。

AWS服务(Secrets Manager、Parameter Store、KMS)的功能和成本效益比较。

如何在Lambda函数中安全地检索和使用敏感数据。

2. 选项分析

A. Store the client token as a secret in AWS Secrets Manager. Use the AWS SDK to retrieve the secret in the Lambda function.

正确性分析:Secrets Manager是专门设计用于存储和管理敏感信息的服务，支持加密和版本控制。Lambda可以通过AWS SDK安全地检索秘密。

成本分析:Secrets Manager的成本较高，尤其是对于频繁访问的场景。相比Parameter Store，成本效益较低。

结论:虽然技术上可行，但不是最具成本效益的解决方案。

B. Configure a token-based Lambda authorizer in API Gateway.

正确性分析:Lambda authorizer用于验证API请求的身份，而不是存储或加密令牌。此选项与题目要求不符。

结论:错误选项。

C. Store the client token as a SecureString parameter in AWS Systems Manager Parameter Store. Use the AWS SDK to retrieve the value of the SecureString parameter in the Lambda function.

正确性分析:Parameter Store支持SecureString参数，可以安全地存储加密数据。Lambda可以通过AWS SDK检索数据，满足题目要求。

成本分析:Parameter Store的成本较低，尤其是对于频繁访问的场景，是最具成本效益的解决方案。

结论:正确选项。

D. Use AWS Key Management Service (AWS KMS) to encrypt the client token. Pass the token to the Lambda function at runtime through an environment variable.

正确性分析:虽然KMS可以加密令牌，但通过环境变量传递敏感数据存在安全风险(例如环境变量可能被意外暴露)。

成本分析:KMS的加密操作可能会增加成本，且此方法不如Parameter Store直接和安全。

结论:技术上可行，但不是最佳实践。

▼ 3

▼ 英文:

A company is using an Amazon CloudFront distribution to deliver content from two origins. One origin is a dynamic application that is hosted on Amazon EC2 instances. The other origin is an Amazon S3 bucket for static assets.

A security analysis shows that HTTPS responses from the application do not comply with a security requirement to provide an X-Frame-Options HTTP header to prevent frame-related cross-site scripting attacks. A security engineer must make the full stack compliant by adding the missing HTTP header to the responses.

Which solution will meet these requirements?

- A. Create a Lambda@Edge function. Include code to add the X-Frame-Options header to the response. Configure the function to run in response to the CloudFront origin response event.
- B. Create a Lambda@Edge function. Include code to add the X-Frame-Options header to the response. Configure the function to run in response to the CloudFront viewer request event.
- C. Update the CloudFront distribution by adding X-Frame-Options to custom headers in the origin settings.
- D. Customize the EC2 hosted application to add the X-Frame-Options header to the responses that are returned to CloudFront.

▼ 中文:

一家公司正在使用 Amazon CloudFront 分发来自两个源交付内容。一个源是托管在 Amazon EC2 实例上的动态应用程序，另一个源是用于静态资产的 Amazon S3 存储桶。

安全分析显示，来自该应用程序的 HTTPS 响应不符合安全要求，未提供 X-Frame-Options HTTP 头以防止与框架相关的跨站脚本攻击。安全工程师必须通过添加缺失的 HTTP 头使整个堆栈符合要求。

哪种解决方案可以满足这些要求？

- A. 创建一个 Lambda@Edge 函数。包含代码以将 X-Frame-Options 头添加到响应中。配置该函数以响应 CloudFront 源响应事件运行。
- B. 创建一个 Lambda@Edge 函数。包含代码以将 X-Frame-Options 头添加到响应中。配置该函数以响应 CloudFront 观众请求事件运行。

C. 通过在源设置中将 X-Frame-Options 添加到自定义头来更新 CloudFront 分发。

D. 自定义托管在 EC2 上的应用程序，以将 X-Frame-Options 头添加到返回给 CloudFront 的响应中。

▼ 答案:

A

1. 考察的知识点

Amazon CloudFront的功能与事件类型（如origin response和viewer request）。

Lambda@Edge的使用场景及其事件触发机制。

HTTP安全头（如X-Frame-Options）的作用及其配置方法。

2. 选项分析

A. Create a Lambda@Edge function. Include code to add the X-Frame-Options header to the response. Configure the function to run in response to the CloudFront origin response event.

正确：Lambda@Edge可以在CloudFront的origin response事件中运行，允许修改从源返回的HTTP响应头。

此解决方案直接解决了问题，因为它可以在动态应用和静态资源的响应中添加X-Frame-Options头。

B. Create a Lambda@Edge function. Include code to add the X-Frame-Options header to the response. Configure the function to run in response to the CloudFront viewer request event.

错误：viewer request事件发生在客户端请求到达CloudFront时，而不是响应返回时。此事件无法修改HTTP响应头。

C. Update the CloudFront distribution by adding X-Frame-Options to custom headers in the origin settings.

错误：CloudFront的origin settings中的自定义头仅适用于请求发送到源，而不是修改源返回的响应头。

D. Customize the EC2 hosted application to add the X-Frame-Options header to the responses that are returned to CloudFront.

错误：虽然可以通过修改EC2应用程序来添加头，但此方法无法解决S3静态资源的响应头问题，因此不符合题目要求。

▼ 4

▼ 英文:

An application has been built with Amazon EC2 instances that retrieve messages from Amazon SQS. Recently, IAM changes were made and the instances can no longer retrieve messages.

What actions should be taken to troubleshoot the issue while maintaining least privilege? (Choose two.)

- A. Configure and assign an MFA device to the role used by the instances.
- B. Verify that the SQS resource policy does not explicitly deny access to the role used by the instances.
- C. Verify that the access key attached to the role used by the instances is active.
- D. Attach the AmazonSQSFullAccess managed policy to the role used by the instances.
- E. Verify that the role attached to the instances contains policies that allow access to the queue.

▼ 中文:

一个应用程序使用 Amazon EC2 实例从 Amazon SQS 中检索消息。最近，IAM 发生了更改，实例无法再检索消息。

应该采取哪些操作来排查问题，同时保持最低权限？（选择两个）

- A. 为实例使用的角色配置并分配一个 MFA 设备。
- B. 验证 SQS 资源策略是否未明确拒绝实例使用的角色的访问权限。
- C. 验证附加到实例使用的角色的访问密钥是否处于活动状态。
- D. 托管策略附加到实例使用的角色。
- E. 验证附加到实例的角色是否包含允许访问队列的策略。

▼ 答案:

BE

1. 考察的知识点

IAM角色与权限管理

Amazon SQS资源策略

最小权限原则

故障排除与权限验证

2. 选项分析

A. Configure and assign an MFA device to the role used by the instances.

错误：为IAM角色配置MFA设备并不是解决权限问题的正确方法。MFA通常用于用户身份验证，而不是用于EC2实例的角色权限管理。

B. Verify that the SQS resource policy does not explicitly deny access to the role used by the instances.

正确：如果SQS资源策略明确拒绝了实例角色的访问权限，即使IAM角色有正确的权限，也无法访问SQS队列。因此，检查资源策略是故障排除的重要步骤。

C. Verify that the access key attached to the role used by the instances is active.

错误：IAM角色不使用访问密钥进行身份验证。EC2实例通过实例配置文件自动获取临时凭证，因此此选项不相关。

D. Attach the AmazonSQSFullAccess managed policy to the role used by the instances.

错误：虽然此操作可以解决权限问题，但它违反了“最小权限原则”，因为它授予了过多的权限。应仅授予实例访问特定SQS队列所需的权限。

E. Verify that the role attached to the instances contains policies that allow access to the queue.

正确：如果IAM角色没有正确的权限策略，实例将无法访问SQS队列。验证角色是否包含允许访问队列的策略是故障排除的关键步骤。

▼ 5

▼ 英文:

A company has an AWS Key Management Service (AWS KMS) customer managed key with imported key material. Company policy requires all encryption keys to be rotated every year.

What should a security engineer do to meet this requirement for this customer managed key?

A. Enable automatic key rotation annually for the existing customer managed key.

B. Use the AWS CLI to create an AWS Lambda function to rotate the existing customer managed key annually.

C. Import new key material to the existing customer managed key. Manually rotate the key.

D. Create a new customer managed key. Import new key material to the new key. Point the key alias to the new key.

▼ 中文:

一家公司拥有一个使用导入密钥材料的AWS Key Management Service (AWS KMS)客户管理密钥。公司政策要求所有加密密钥每年轮换一次。安全工程师应该怎么做才能满足此客户管理密钥的要求？

- A.为现有的客户管理密钥启用每年的自动密钥轮换。
- B.使用AWS CLI创建一个AWS Lambda函数，以每年轮换现有的客户管理密钥。
- C.向现有的客户管理密钥导入新的密钥材料。手动轮换密钥。
- D.创建一个新的客户管理密钥。向新密钥导入新的密钥材料。将密钥别名指向新密钥。

▼ 答案:

D

1. 考察的知识点

AWS Key Management Service (KMS) 的密钥管理与轮换。
如何处理导入的密钥材料。
密钥别名的使用与更新。

2. 选项分析

A. Enable automatic key rotation annually for the existing customer managed key.

错误：自动密钥轮换仅适用于由AWS KMS生成的密钥，而不适用于导入的密钥材料。

B. Use the AWS CLI to create an AWS Lambda function to rotate the existing customer managed key annually.

错误：虽然可以通过自定义Lambda函数实现密钥轮换，但这不是AWS推荐的最佳实践，尤其是对于导入的密钥材料。

C. Import new key material to the existing customer managed key. Manually rotate the key.

错误：AWS KMS不支持直接替换现有密钥的导入密钥材料。需要创建新的密钥并更新别名。

D. Create a new customer managed key. Import new key material to the new key. Point the key alias to the new key.

正确：这是AWS推荐的最佳实践。导入新的密钥材料需要创建新的密钥，并通过更新别名来指向新的密钥。

▼ 6

▼ 英文:

A healthcare company has multiple AWS accounts in an organization in AWS Organizations. The company uses Amazon S3 buckets to store sensitive information of patients. The company needs to restrict users from deleting any S3 bucket across the organization.

What is the MOST scalable solution that meets these requirements?

- A. Permissions boundaries in AWS Identity and Access Management (IAM)
- B. S3 bucket policies
- C. Tag policies
- D. SCPs

▼ 中文:

一家医疗公司在 AWS Organizations 中的一个组织内拥有多个 AWS 账户。该公司使用 Amazon S3 存储桶来存储患者的敏感信息。公司需要限制用户删除组织内的任何 S3 存储桶。

满足这些要求的最具可扩展性的解决方案是什么？

- A.AWS Identity and Access Management (IAM) 的权限边界
- B.S3 存储桶策略
- C.标签策略
- D.SCPs

▼ 答案:

D

题目分析与解答

1. 考察的知识点

本题考察的是AWS Organizations中的服务控制策略（SCPs）的使用，以及如何在组织级别限制对资源的操作。同时涉及到IAM权限管理、S3存储桶策略和标签策略的适用场景。

2. 选项分析

A. Permissions boundaries in AWS Identity and Access Management (IAM)

权限边界用于限制IAM用户或角色的权限，但它仅适用于单个账户内的资

源管理，无法跨账户实现组织级别的限制。

因此，这个选项不适合解决跨账户的S3存储桶删除限制问题。

B. S3 bucket policies

S3存储桶策略是针对单个存储桶的访问控制策略，无法在组织级别统一管理所有账户的存储桶操作。

因此，这个选项不具备跨账户的可扩展性。

C. Tag policies

标签策略用于管理资源的标签一致性，但它不能直接限制对资源的操作（如删除存储桶）。

因此，这个选项与题目要求不符。

D. SCPs

服务控制策略（SCPs）是AWS Organizations中的一种策略，可以在组织级别限制成员账户对资源的操作。

通过SCPs，可以禁止所有成员账户删除S3存储桶，满足题目要求的“最可扩展解决方案”。

因此，这个选项是正确答案。

▼ 7

▼ 英文:

A company needs to detect unauthenticated access to its Amazon Elastic Kubernetes Service (Amazon EKS) clusters. The company needs a solution that requires no additional configuration of the existing EKS deployment.

Which solution will meet these requirements with the LEAST operational effort?

- A. Install an Amazon EKS add-on from a security vendor.
- B. Enable AWS Security Hub. Monitor the Kubernetes findings.
- C. Monitor Amazon CloudWatch Container Insights metrics for Amazon EKS.
- D. Enable Amazon GuardDuty. Use EKS Audit Log Monitoring. Most Voted

▼ 中文:

一家公司需要检测对其 Amazon Elastic Kubernetes Service (Amazon EKS) 集群的未认证访问。该公司需要一种解决方案，**该解决方案无需对现有的 EKS 部署进行额外配置。**

哪种解决方案能够以最少的运营工作量满足这些需求？

- A. 从安全供应商安装一个 Amazon EKS 插件。
- B. 启用 AWS Security Hub。监控 Kubernetes 发现。
- C. 监控 Amazon CloudWatch Container Insights 指标以用于 Amazon EKS。
- D. 启用 Amazon GuardDuty。使用 EKS 审计日志监控。

▼ 答案:

D

题目分析与解答

1. 考察的知识点

本题考察的是AWS服务中与安全相关的监控和检测功能，特别是如何检测未经身份验证的访问行为。

涉及的服务包括Amazon GuardDuty、AWS Security Hub、CloudWatch Container Insights，以及第三方安全插件的使用。

2. 选项分析

A. Install an Amazon EKS add-on from a security vendor.

错误：虽然第三方安全插件可能提供高级功能，但它需要额外的配置和管理，增加了操作复杂性，不符合题目要求的“最少操作努力”。

B. Enable AWS Security Hub. Monitor the Kubernetes findings.

错误：AWS Security Hub主要用于汇总和管理安全警报，但它本身并不直接监控EKS的未经身份验证访问行为。需要其他服务（如GuardDuty）提供数据源。

C. Monitor Amazon CloudWatch Container Insights metrics for Amazon EKS.

错误：CloudWatch Container Insights主要用于监控容器性能指标，而不是检测未经身份验证的访问行为。它不适合解决此类安全问题。

D. Enable Amazon GuardDuty. Use EKS Audit Log Monitoring.

正确：Amazon GuardDuty可以直接分析EKS的审计日志，检测未经身份验证的访问行为。它无需额外配置现有EKS部署，符合题目要求的“最少操作努力”。

▼ 8

▼ 英文:

A security engineer is investigating a malware infection that has spread across a set of Amazon EC2 instances. A key indicator of the

compromise is outbound traffic on TCP port 2905 to a set of command and control hosts on the internet.

The security engineer creates a network ACL rule that denies the identified outbound traffic. The security engineer applies the network ACL rule to the subnet of the EC2 instances. The security engineer must identify any EC2 instances that are trying to communicate on TCP port 2905.

Which solution will identify the affected EC2 instances with the LEAST operational effort?

A. Create a Network Access Scope in Amazon VPC Network Access Analyzer. Use the Network Access Scope to identify EC2 instances that try to send traffic to TCP port 2905.

B. Enable VPC flow logs for the VPC where the affected EC2 instances are located. Configure the flow logs to capture rejected traffic. In the flow logs, search for REJECT records that have a destination TCP port of 2905.

C. Enable Amazon GuardDuty. Create a custom GuardDuty IP list to create a finding when an EC2 instance tries to communicate with one of the command and control hosts. Use Amazon Detective to identify the EC2 instances that initiate the communication.

D. Create a firewall in AWS Network Firewall. Attach the firewall to the subnet of the EC2 instances. Create a custom rule to identify and log traffic from the firewall on TCP port 2905. Create an Amazon CloudWatch Logs metric filter to identify firewall logs that reference traffic on TCP port 2905

▼ 中文:

一位安全工程师正在调查一种恶意软件感染，该感染已在一组 Amazon EC2 实例中传播。妥协的关键指标是通过 TCP 端口 2905 向互联网上的一组命令和控制主机发送的出站流量。

安全工程师创建了一个网络 ACL 规则，拒绝识别出的出站流量。安全工程师将网络 ACL 规则应用于 EC2 实例的子网。

安全工程师必须识别任何试图通过 TCP 端口 2905 进行通信的 EC2 实例。哪种解决方案能够以**最少的操作工作量**识别受影响的 EC2 实例？

A.在 Amazon VPC Network Access Analyzer 中创建一个 Network Access Scope。使用 Network Access Scope 来识别试图发送流量到 TCP 端口 2905 的 EC2 实例。

B为受影响的 EC2 实例所在的 VPC 启用 VPC flow logs。将 flow logs 配置为捕获被拒绝的流量。在 flow logs 中，搜索目标 TCP 端口为 2905 的 REJECT 记录。

C启用 Amazon GuardDuty。创建一个自定义 GuardDuty IP 列表，当 EC2 实例试图与其中一个命令和控制主机通信时生成一个发现。使用 Amazon Detective 来识别发起通信的 EC2 实例。

D在 AWS Network Firewall 中创建一个防火墙。将防火墙附加到 EC2 实例的子网。创建一个自定义规则以识别并记录通过 TCP 端口 2905 的防火墙流量。在 Amazon CloudWatch Logs 中创建一个日志指标过滤器，以识别引用 TCP 端口2905 流量的防火墙日志。

▼ 答案:

B

1. 考察的知识点

VPC Flow Logs的功能与配置，特别是如何捕获被拒绝的流量。

网络ACL的工作原理及其与VPC Flow Logs的结合使用。

如何高效地识别异常流量来源。

2. 选项分析

A. Create a Network Access Scope in Amazon VPC Network Access Analyzer.

错误：Amazon VPC Network Access Analyzer主要用于分析网络访问路径和验证网络配置是否符合预期，但它无法直接捕获实时流量或识别被拒绝的流量。

B. Enable VPC flow logs for the VPC where the affected EC2 instances are located.

正确：VPC Flow Logs可以捕获被拒绝的流量记录，包括目标端口和协议。通过搜索REJECT记录，可以轻松识别尝试连接到TCP端口2905的EC2实例。此方法操作简单且直接，符合题目要求的“LEAST operational effort”。

C. Enable Amazon GuardDuty.

错误：虽然GuardDuty可以检测恶意活动，但需要额外配置自定义IP列表，并且依赖于Amazon Detective进行进一步分析。这增加了操作复杂性，不符合“LEAST operational effort”的要求。

D. Create a firewall in AWS Network Firewall.

错误：AWS Network Firewall可以记录流量，但需要额外配置防火墙规则和CloudWatch Logs指标过滤器。这种方法比使用VPC Flow Logs更复杂，操作成本更高。

▼ 9

▼ 英文:

A security engineer uses Amazon Macie to scan a company's Amazon S3 buckets for sensitive data. The company has many S3 buckets and many objects stored in the S3 buckets. The security engineer must identify S3 buckets that contain sensitive data and must perform additional scanning on those S3 buckets. Which solution will meet these requirements with the LEAST administrative overhead?

- A. Configure S3 Cross-Region Replication (CRR) on the S3 buckets to replicate the objects to a second AWS Region. Configure Macie in the second Region to scan the replicated objects daily.
- B. Create an AWS Lambda function as an S3 event destination for the S3 buckets. Configure the Lambda function to start a Macie scan of an object when the object is uploaded to an S3 bucket.
- C. Configure Macie automated discovery to continuously sample data from the S3 buckets. Perform full scans of the S3 buckets where Macie discovers sensitive data.
- D. Configure Macie scans to run on the S3 buckets. Aggregate the results of the scans in an Amazon DynamoDB table. Use the DynamoDB table for queries.

▼ 中文:

一名安全工程师使用 Amazon Macie 扫描公司 Amazon S3 存储桶中的敏感数据。公司有许多 S3 存储桶，并且在这些存储桶中存储了许多对象。安全工程师必须识别包含敏感数据的 S3 存储桶，并对这些存储桶执行额外的扫描。哪种解决方案能够以最少管理开销满足这些要求？

- A.在 S3 存储桶上配置 S3 Cross-Region Replication (CRR)，将对象复制到第二个 AWS 区域。在第二个区域中配置 Macie，每天扫描复制的对象。
- B.创建一个 AWS Lambda 函数作为 S3 存储桶的 S3 事件目标。配置该 Lambda 函数，在对象上传到 S3 存储桶时启动 Macie 对该对象的扫描。
- C.配置 Macie 自动发现以持续从 S3 存储桶中抽样数据。对 Macie 发现敏感数据的 S3 存储桶执行全面扫描。

D.配置 Macie 扫描以运行在 S3 存储桶上。将扫描结果汇总到一个 Amazon DynamoDB 表中。使用 DynamoDB 表进行查询。

▼ 答案:

C

1. 考察的知识点

Amazon Macie的功能与使用，包括自动发现和扫描敏感数据。

如何优化敏感数据扫描以减少管理开销。

Amazon S3与Macie的集成方式。

2. 选项分析

A. 配置 S3 Cross-Region Replication (CRR) 并在第二个区域中使用 Macie 扫描：

错误：CRR的主要用途是跨区域复制数据以实现灾难恢复或数据冗余，而不是优化敏感数据扫描。

错误：在第二个区域配置Macie会增加额外的成本和复杂性，并不符合“最少管理开销”的要求。

B. 使用 AWS Lambda 函数触发 Macie 扫描：

错误：虽然可以通过Lambda函数触发Macie扫描，但这种方法需要为每个对象单独触发扫描，管理开销较高。

错误：这种方式不适合大规模的S3存储桶和对象，因为会导致频繁的触发和资源消耗。

C. 配置 Macie 自动发现并对发现敏感数据的存储桶进行全面扫描：

正确：Macie的自动发现功能可以持续抽样数据并标识敏感数据存储桶，减少手动操作。

正确：对标识出的敏感数据存储桶进行全面扫描是高效且符合要求的解决方案。

D. 配置 Macie 扫描并将结果汇总到 DynamoDB 表中：

错误：虽然可以使用DynamoDB存储扫描结果，但这并没有减少管理开销，反而增加了额外的步骤和复杂性。

错误：此选项没有提到如何优化扫描过程，仅关注结果存储。

▼ 10

▼ 英文:

A security engineer for a large company is managing a data processing application used by 1,500 subsidiary companies. The parent and subsidiary companies all use AWS. The application uses TCP port 443 and runs on Amazon C2 behind a Network Load Balancer (NLB). For compliance reasons, the application should only be accessible to the

subsidiaries and should not be available on the public internet. To meet the compliance requirements for restricted access, the engineer has received the public and private CIDR block ranges for each subsidiary. What solution should the engineer use to implement the appropriate access restrictions for the application?

- A. Create a NACL to allow access on TCP port 443 from the 1,500 subsidiary CIDR block ranges. Associate the NACL to both the NLB and EC2 instances.
- B. Create an AWS security group to allow access on TCP port 443 from the 1,500 subsidiary CIDR block ranges. Associate the security group to the NLB. Create a second security group for EC2 instances with access on TCP port 443 from the NLB security group.
- C. Create an AWS PrivateLink endpoint service in the parent company account attached to the NLB. Create an AWS security group for the instances to allow access on TCP port 443 from the AWS PrivateLink endpoint. Use AWS PrivateLink interface endpoints in the 1,500 subsidiary AWS accounts to connect to the data processing application.
- D. Create an AWS security group to allow access on TCP port 443 from the 1,500 subsidiary CIDR block ranges. Associate the security group with EC2 instances.

▼ 中文:

一名大型公司的安全工程师正在管理一个数据处理应用程序，该应用程序由1,500家子公司使用。母公司和子公司均使用AWS。该应用程序使用TCP端口443，并运行在一个位于Network Load Balancer (NLB)后面的Amazon EC2实例上。由于合规原因，该应用程序应仅对子公司开放访问，不对公共互联网开放。为了满足受限访问的合规要求，工程师已收到每个子公司的公共和私有CIDR块范围。

工程师应使用什么[解决方案来实施适当的应用程序访问限制](#)？

- A. 创建一个NACL以允许来自1,500个子公司CIDR块范围的TCP端口443访问。将该NACL关联到NLB和EC2实例。
- B. 创建一个AWS安全组以允许来自1,500个子公司CIDR块范围的TCP端口443访问。将安全组关联到NLB。为EC2实例创建第二个安全组，允许来自NLB安全组的TCP端口443访问。
- C. 在母公司账户中创建一个附加到NLB的AWS PrivateLink端点服务。为实例创建一个AWS安全组，允许来自AWS PrivateLink端点的TCP端口443访问。在1,500个子公司AWS账户中使用AWS PrivateLink接口端点连接到数据处理

应用程序。

D. 创建一个AWS安全组以允许来自1,500个子公司CIDR块范围的TCP端口443访问。将安全组关联到EC2实例。

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS网络安全相关知识，包括网络访问控制、AWS PrivateLink的使用、以及安全组和网络ACL的配置。

重点在于如何限制访问范围，同时满足跨账户的安全访问需求。

2. 选项分析

A. 创建一个NACL以允许来自1,500个子公司CIDR块范围的TCP端口443访问。将该NACL关联到NLB和EC2实例。

错误原因：网络ACL（NACL）是无状态的，无法区分流量的方向，且管理1,500个CIDR块范围的规则会非常复杂且难以维护。此外，NACL无法直接关联到NLB。

B. 创建一个AWS安全组以允许来自1,500个子公司CIDR块范围的TCP端口443访问。将安全组关联到NLB。为EC2实

例创建第二个安全组，允许来自NLB安全组的TCP端口443访问。

错误原因：虽然安全组是有状态的，但管理1,500个CIDR块范围的规则仍然非常复杂且难以维护。此外，安全组无法直接限制跨账户的访问。

C. 在母公司账户中创建一个附加到NLB的AWS PrivateLink端点服务。为实例创建一个AWS安全组，允许来自AWS PrivateLink端点的TCP端口443访问。在1,500个子公司AWS账户中使用AWS PrivateLink接口端点连接到数据处理应用程序。

正确原因：使用AWS PrivateLink可以实现跨账户的安全访问，同时避免暴露服务到公共互联网。通过PrivateLink，子公司账户可以通过接口端点安全地连接到母公司账户的服务。安全组可以进一步限制来自PrivateLink端点的访问。

D. 创建一个AWS安全组以允许来自1,500个子公司CIDR块范围的TCP端口443访问。将安全组关联到EC2实例。

错误原因：虽然安全组可以限制访问，但它无法解决跨账户的访问问题。此外，管理1,500个CIDR块范围的规则仍然非常复杂且难以维护。

▼ 英文:

A company runs workloads on Amazon EC2 instances. The company needs to continually scan the EC2 instances for software vulnerabilities and unintended network exposure.

Which solution will meet these requirements?

- A. Use Amazon Inspector. Set the scan mode to hybrid scanning.
- B. Use Amazon GuardDuty. Enable the Malware Protection feature.
- C. Use Amazon Inspector. Enable the Malware Protection feature.
- D. Use Amazon GuardDuty. Enable the Runtime Monitoring feature.

▼ 中文:

一家公司在 Amazon EC2 实例上运行工作负载。该公司需要持续扫描 EC2 实例以检测软件漏洞和意外的网络暴露。哪种解决方案可以满足这些需求？

- A. 使用 Amazon Inspector。将扫描模式设置为混合扫描。
- B. 使用 Amazon GuardDuty。启用 Malware Protection 功能。
- C. 使用 Amazon Inspector。启用 Malware Protection 功能。
- D. 使用 Amazon GuardDuty。启用 Runtime Monitoring 功能。

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS服务中与安全扫描相关的功能，特别是Amazon Inspector和Amazon GuardDuty的使用场景和功能区别。
重点在于理解如何使用AWS工具进行软件漏洞扫描和网络暴露检测。

2. 选项分析

A. Use Amazon Inspector. Set the scan mode to hybrid scanning.

Amazon Inspector是专门设计用于扫描EC2实例的工具，可以检测软件漏洞和网络暴露。

“混合扫描模式”是一个虚构的选项，Amazon Inspector并没有明确的“混合扫描模式”设置，但它确实可以扫描漏洞和网络暴露。

此选项的描述虽然不完全准确，但Amazon Inspector是正确的服务选择。

B. Use Amazon GuardDuty. Enable the Malware Protection feature.

Amazon GuardDuty主要用于威胁检测，例如恶意活动和异常行为，而不是专门用于漏洞扫描。

Malware Protection是GuardDuty的一项功能，但它的重点是检测恶意软件，而不是扫描软件漏洞或网络暴露。

此选项不符合题目要求。

C. Use Amazon Inspector. Enable the Malware Protection feature.

Amazon Inspector的主要功能是漏洞扫描和网络暴露检测，而不是恶意软件保护。

“Malware Protection”并不是Amazon Inspector的功能，因此此选项是错误的。

D. Use Amazon GuardDuty. Enable the Runtime Monitoring feature.

Amazon GuardDuty没有“Runtime Monitoring”功能，这个选项是虚构的。

GuardDuty的主要功能是威胁检测，而不是漏洞扫描或网络暴露检测。

此选项是错误的。

▼ 12

▼ 英文:

A company has a requirement that no Amazon EC2 security group can allow SSH access from the CIDR block 0.0.0.0/0. The company wants to monitor compliance with this requirement at all times and wants to receive a near-real-time notification if any security group is noncompliant.

A security engineer has configured AWS Config and will use the restricted-ssh managed rule to monitor the security groups.

What should the security engineer do next to meet these requirements?

A. Configure AWS Config to send its configuration snapshots to an Amazon S3 bucket. Create an AWS Lambda function to run on a PutEvent to the S3 bucket. Configure the Lambda function to parse the snapshot for a compliance change to the restricted-ssh managed rule. Configure the Lambda function to send a notification to an Amazon Simple Notification Service (Amazon SNS) topic if a change is discovered.

B. Configure an Amazon EventBridge event rule that is invoked by a compliance change event from AWS Config for the restricted-ssh managed rule. Configure the event rule to target an Amazon Simple Notification Service (Amazon SNS) topic that will provide a notification.

C. Configure AWS Config to push all its compliance notifications to Amazon CloudWatch Logs. Configure a CloudWatch Logs metric filter on the AWS Config log group to look for a compliance notification

change on the restricted-ssh managed rule. Create an Amazon CloudWatch alarm on the metric filter to send a notification to an Amazon Simple Notification Service (Amazon SNS) topic if the alarm is in the ALARM state.

D. Configure an Amazon CloudWatch alarm on the CloudWatch metric for the restricted-ssh managed rule. Configure the CloudWatch alarm to send a notification to an Amazon Simple Notification Service (Amazon SNS) topic if the alarm is in the ALARM state.

▼ 中文:

一家公司有一个要求，即任何 Amazon EC2 安全组都不能允许来自 CIDR 块 0.0.0.0/0 的 SSH 访问。公司希望始终监控对该要求的[合规性](#)，并希望在任何安全组不合规时[接收到近乎实时的通知](#)。

一名安全工程师已配置 AWS Config，并将使用 restricted-ssh 托管规则来监控安全组。

安全工程师接下来应该怎么做以满足这些要求？

A. 配置 AWS Config 将其配置快照发送到一个 Amazon S3 存储桶。创建一个 AWS Lambda 函数以在存储桶的 PutEvent 上运行。配置 Lambda 函数以解析快照中对 restricted-ssh 托管规则的合规性更改。如果发现更改，配置 Lambda 函数向一个 Amazon Simple Notification Service (Amazon SNS) 主题发送通知。

B. 配置一个 Amazon EventBridge 事件规则，该规则由 AWS Config 对 restricted-ssh 托管规则的合规性更改事件触发。配置事件规则以定位一个 Amazon Simple Notification Service (Amazon SNS) 主题，该主题将提供通知。

C. 配置 AWS Config 将其所有合规性通知推送到 Amazon CloudWatch Logs。配置一个 CloudWatch Logs 指标过滤器，用于在 AWS Config 日志组中查找 restricted-ssh 托管规则的合规性通知更改。创建一个 Amazon CloudWatch 警报，用于在指标过滤器处于 ALARM 状态时向一个 Amazon Simple Notification Service (Amazon SNS) 主题发送通知。

D. 在 restricted-ssh 托管规则的 CloudWatch 指标上配置一个 Amazon CloudWatch 警报。配置 CloudWatch 警报以在警报处于 ALARM 状态时向一个 Amazon Simple Notification Service (Amazon SNS) 主题发送通知。

▼ 答案:

B

1. 考察的知识点

本题考察的是AWS Config的合规性规则监控与通知机制。

重点关注AWS Config与Amazon EventBridge的集成，以及如何实现实时通知。

2. 选项分析

A. 配置 AWS Config 将其配置快照发送到一个 Amazon S3 存储桶，并使用 Lambda 函数解析快照:

错误:AWS Config的快照是定期生成的，而不是实时的，因此无法满足“近实时通知”的要求。

错误:解析快照的方式效率较低，且需要额外的逻辑来处理合规性变化。

B. 配置 Amazon EventBridge 事件规则，由 AWS Config 的合规性更改事件触发:

正确:AWS Config可以直接与Amazon EventBridge集成，EventBridge可以实时捕获合规性变化事件。

正确:EventBridge规则可以直接将事件发送到SNS主题，实现近实时通知。

C. 配置 AWS Config 推送通知到 CloudWatch Logs，并使用指标过滤器和警报:

错误:虽然可以通过CloudWatch Logs实现通知，但这种方法需要额外的配置(日志过滤器和警报)，复杂度较高。

错误:这种方法的延迟可能较高，无法保证“近实时通知”。

D. 在 CloudWatch 指标上配置警报:

错误:AWS Config的托管规则并不会直接生成CloudWatch指标，因此无法直接在CloudWatch指标上配置警报。

错误:此选项与AWS Config的工作机制不匹配。

▼ 13

▼ 英文:

A security engineer discovers that a company's user passwords have no required minimum length. The company is using the following two identity providers (IdPs):

- AWS Identity and Access Management (IAM) federated with on-premises Active Directory
 - Amazon Cognito user pools that contain the user database for an AWS Cloud application that the company developed
- Which combination of actions should the security engineer take to implement a required minimum length for the passwords?

(Choose two.)

- A. Update the password length policy in the IAM configuration.
- B. Update the password length policy in the Cognito configuration.
- C. Update the password length policy in the on-premises Active Directory configuration
- D. Create an SCP in AWS Organizations. Configure the SCP to enforce a minimum password length for IAM and Cognito.
- E. Create an IAM policy that includes a condition for minimum password length. Enforce the policy for IAM and Cognito.

▼ 中文:

一位安全工程师发现公司的用户密码没有要求的最低长度。公司正在使用以下两个身份提供商(IdPs):

- AWS Identity and Access Management (IAM) 与本地 Active Directory 联合身份验证
- Amazon Cognito 用户池，包含公司开发的 AWS Cloud 应用程序的用户数据库

安全工程师应该采取哪些组合操作来实施密码的最低长度要求?(选择两个)

- A.更新 IAM 配置中的密码长度策略。
- B.更新 Cognito 配置中的密码长度策略。
- C.更新本地 Active Directory 配置中的密码长度策略。
- D. 在 AWS Organizations 中创建一个 SCP。配置 SCP 以强制执行 IAM 和 Cognito 的最低密码长度。
- E. 创建一个 IAM 策略，其中包含最低密码长度的条件。对 IAM 和 Cognito 强制执行该策略。

▼ 答案:

BC

1. 考察的知识点

密码策略的配置与管理。

如何在不同身份提供者(IdPs)中实施安全控制。

Amazon Cognito 和 Active Directory 的密码策略设置。

2. 选项分析

- A. Update the password length policy in the IAM configuration.

分析:IAM本身不支持直接设置密码长度策略，因为IAM用户的密码策略是通过账户级别的密码策略来管理的，而不是单独配置的。因此此选项错误。

B. Update the password length policy in the Cognito configuration.

分析:Amazon Cognito支持直接配置密码策略，包括设置密码的最小长度。这是正确的操作之一，因此此选项正确。

C. Update the password length policy in the on-premises Active Directory configuration.

分析:Active Directory是公司内部的身份提供者，密码策略需要在Active Directory中配置以满足安全要求。这是正确的操作之一，因此此选项正确。

D. Create an SCP in AWS Organizations. Configure the SCP to enforce a minimum password length for IAM and Cognito.

分析:SCP(Service Control Policy)用于限制AWS账户或组织中的服务操作，但无法直接用于设置密码策略。因此此选项错误。

E. Create an IAM policy that includes a condition for minimum password length. Enforce the policy for IAM and Cognito.

分析:IAM策略无法直接用于设置密码长度条件，密码策略是通过账户级别的密码策略或Cognito的配置来管理的。因此此选项错误。

▼ 14

▼ 英文:

A company uses AWS Key Management Service (AWS KMS). During an attempt to attach an encrypted Amazon Elastic Block Store (Amazon EBS) volume to an Amazon EC2 instance, the attachment fails. The company discovers that a customer managed key has become unusable because the key material for the key was deleted. The company needs the data that is on the EBS volume.

A security engineer must recommend a solution to decrypt the EBS volume's encrypted data key. The solution must also attach the volume to the EC2 instance.

Which solution will meet these requirements?

A. Import new key material into the key. Attach the EBS volume.

B. Restore the EBS volume from a snapshot that was taken before the deletion of the key material.

C. Reimport the same key material that originally was imported into the key. Attach the EBS volume.

D. Create a new key. Import new key material. Attach the EBS volume.

▼ 中文:

一家公司使用AWS Key Management Service (AWS KMS)。在尝试将加密的Amazon Elastic Block Store (Amazon EBS)卷附加到Amazon EC2实例时，附加失败。公司发现一个客户管理的密钥由于其密钥材料被删除而变得不可用。公司需要EBS卷上的数据。

一名安全工程师必须推荐一种解决方案来解密EBS卷的加密数据密钥。该解决方案还必须能够将卷附加到EC2实例。哪种解决方案可以满足这些要求？

- A. 将新的密钥材料导入到密钥中。附加EBS卷。
- B. 从删除密钥材料之前创建的快照恢复EBS卷。
- C. 重新导入最初导入到密钥中的相同密钥材料。附加EBS卷。
- D. 创建一个新密钥。导入新的密钥材料。附加EBS卷。

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS KMS的密钥管理，包括密钥材料的导入与恢复，以及加密资源(如EBS卷)的解密和使用。

重点在于理解如何处理因密钥材料丢失导致的加密资源不可用问题。

2. 选项分析

A. Import new key material into the key. Attach the EBS volume.

错误:导入新的密钥材料不会恢复原始密钥的功能，因为新的密钥材料与原始密钥材料不同，无法解密原始数据。

即使导入新的密钥材料，EBS卷仍然无法解密原始数据。

B. Restore the EBS volume from a snapshot that was taken before the deletion of the key material.

错误:如果快照本身也是使用同一个密钥加密的，那么快照也无法解密，因为密钥材料已被删除。

此选项仅在快照未加密或使用不同的密钥加密时有效，但题目未提到这种情况。

C. Reimport the same key material that originally was imported into the key. Attach the EBS volume.

正确:重新导入原始密钥材料可以恢复密钥的功能，因为原始密钥材料与加密数据匹配。

一旦密钥恢复，EBS卷可以成功解密并附加到EC2实例。

D. Create a new key. Import new key material. Attach the EBS volume.

错误:创建新密钥并导入新的密钥材料不会恢复原始密钥的功能。
新密钥与原始密钥无关，无法解密原始数据。

▼ 15

▼ 英文:

A company needs to analyze access logs for an Application Load Balancer (ALB). The ALB directs traffic to the company's online login portal. The company needs to use visualizations to identify login attempts by bots from a list of known IP sources.

Which solution will meet these requirements?

A. Configure the ALB to send logs directly to Amazon CloudWatch Logs. Analyze and visualize the logs by using CloudWatch Logs Insights.

B. Configure the ALB to send logs directly to Amazon Redshift. Analyze the logs by using SQL queries. Visualize the logs by using custom reports.

C. Configure the ALB to send logs directly to Amazon OpenSearch Service. Analyze the logs by using OpenSearch dashboards. Visualize the logs by using custom OpenSearch dashboards.

D. Configure the ALB to send logs directly to an Amazon S3 bucket. Analyze the logs by using Amazon Athena. Visualize the logs by using Amazon QuickSight.

▼ 中文:

一家公司需要分析应用负载均衡器(ALB)的访问日志。该 ALB 将流量引导至公司的在线登录门户。公司需要使用可视化工具从已知 IP 来源列表中识别机器人登录尝试。哪种解决方案可以满足这些需求?

A. 配置 ALB 将日志直接发送到 Amazon CloudWatch Logs。使用 CloudWatch Logs Insights 分析和可视化日志。

B. 配置 ALB 将日志直接发送到 Amazon Redshift。使用 SQL 查询分析日志。使用自定义报告可视化日志。

C. 配置 ALB 将日志直接发送到 Amazon OpenSearch Service。使用 OpenSearch dashboards 分析日志。使用自定义 OpenSearch dashboards 可视化日志。

D.配置 ALB 将日志直接发送到 Amazon S3 bucket。使用 Amazon Athena 分析日志。使用 Amazon QuickSight 可视化日志。

▼ 答案:

D

1. 考察的知识点

Amazon ALB 日志的收集与分析。

使用 AWS 服务进行日志分析和可视化，包括 Amazon Athena 和 Amazon QuickSight。

如何处理和分析大规模数据(如访问日志)。

2. 选项分析

A.

错误原因:虽然 CloudWatch Logs Insights 可以分析日志，但它不适合处理大规模日志数据的复杂查询和可视化需求。CloudWatch Logs Insights 的可视化功能有限，无法满足复杂的图表和报告需求。

B.

错误原因:Amazon Redshift 是一个数据仓库服务，适合处理结构化数据，但 ALB 日志是非结构化数据，直接发送到 Redshift 需要额外的 ETL(提取、转换、加载)步骤，增加了复杂性。此外，Redshift 本身不提供可视化功能，需要额外工具。

C.

错误原因:Amazon OpenSearch Service 适合实时日志分析和搜索，但题目要求的是从已知 IP 列表中识别登录尝试，这更适合使用 Athena 的 SQL 查询功能。此外，OpenSearch 的可视化功能虽然强大，但与 QuickSight 的高级图表和报告功能相比有所不足。

D.

正确原因:Amazon S3 是存储 ALB 访问日志的最佳选择，Athena 可以直接查询存储在 S3 中的日志数据，支持复杂的 SQL 查询。QuickSight 是 AWS 的高级可视化工具，可以生成丰富的图表和报告，满足题目要求。

▼ 16

▼ 英文:

一家公司在预定义的时间表上，在 Amazon EC2 实例上运行一个 cron 作业。该 cron 作业调用一个 bash 脚本来加密一个

2 KB 的文件。一名安全工程师使用 AWS Key Management Service (AWS KMS) 创建了一个客户管理密钥，并配置了密钥策略。密钥策略和 EC2 实例角色已为此作业配置了必要的权限。

bash 脚本应该使用哪种流程来加密文件？

- A. Use the `aws kms encrypt` command to encrypt the file by using the existing KMS key.
- B. Use the `aws kms create-grant` command to generate a grant for the existing KMS key.
- C. Use the `aws kms encrypt` command to generate a data key. Use the plaintext data key to encrypt the file.
- D. Use the `aws kms generate-data-key` command to generate a data key. Use the encrypted data key to encrypt the file.

▼ 中文:

一家公司在预定义的时间表上，在 Amazon EC2 实例上运行一个 cron 作业。该 cron 作业调用一个 bash 脚本来加密一个 2 KB 的文件。一名安全工程师使用 AWS Key Management Service (AWS KMS) 创建了一个客户管理密钥，并配置了密钥策略。密钥策略和 EC2 实例角色已为此作业配置了必要的权限。

bash 脚本应该使用哪种流程来加密文件？

- A. 使用 `aws kms encrypt` 命令，通过现有的 KMS 密钥加密文件。
- B. 使用 `aws kms create-grant` 命令，为现有的 KMS 密钥生成一个授权。
- C. 使用 `aws kms encrypt` 命令生成一个数据密钥。使用明文数据密钥加密文件。
- D. 使用 `aws kms generate-data-key` 命令生成一个数据密钥。使用加密的数据密钥加密文件。

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS Key Management Service (KMS)的使用，特别是如何使用KMS密钥进行文件加密。涉及到KMS的加密命令和数据密钥的生成与使用。

2. 选项分析

A. Use the `aws kms encrypt` command to encrypt the file by using the existing KMS key.

正确:此选项直接使用AWS KMS的加密命令来加密文件，符合题目要求。

AWS KMS支持直接使用密钥对小文件(如2KB文件)进行加密。

适合小文件加密，因为文件大小在KMS加密的限制范围内。

B. Use the `aws kms create-grant` command to generate a grant for the

existing KMS key.

错误:create-grant命令用于创建权限授权(grant)，而不是用于加密文件。

此选项与题目要求的加密操作无关。

C. Use the aws kms encrypt command to generate a data key. Use the plaintext data key to encrypt the file.

错误:aws kms encrypt命令用于加密数据，而不是生成数据密钥。

生成数据密钥通常使用的是generate-data-key命令，而不是encrypt命令。

D. Use the aws kms generate-data-key command to generate a data key. Use the encrypted data key to encrypt the file.

错误:generate-data-key命令生成的是数据密钥(明文和加密形式)，但加密文件需要使用明文数据密钥，而不是加密

数据密钥。

此选项的描述不符合实际加密流程。

▼ 17

▼ 英文:

A security engineer needs to analyze Apache web server access logs that are stored in an Amazon S3 bucket. Amazon EC2 instance web servers generated the logs. The EC2 instances have the Amazon CloudWatch agent installed and configured to report their access logs.

The security engineer needs to use a query in Amazon Athena to analyze the logs. The query must identify IP addresses that have attempted and failed to access restricted web server content held at the /admin URL path. The query also must identify the URLs that the IP addresses attempted to access.

Which query will meet these requirements?

A. `SELECT client_ip, client_request FROM logs WHERE client_request LIKE '%/admin%!' AND server_status = '403'`

B. `SELECT client_ip FROM logs WHERE client_request CONTAINS '%/admin%' AND server_status = '401' GROUP BY client_ip`

C. `SELECT DISTINCT (client_ip), client_request, client_id FROM logs WHERE server status = '403' LIMIT 1000`

D. `SELECT DISTINCT (client_ip), client_request FROM logs WHERE user_id <> 'admin' AND server_status = '401!'`

▼ 中文:

一位安全工程师需要分析存储在 Amazon S3 存储桶中的 Apache Web 服务器访问日志。这些日志是由 Amazon EC2 实例上的 Web 服务器生成的。EC2 实例已安装并配置了 Amazon CloudWatch Agent，用于报告其访问日志。安全工程师需要在 Amazon Athena 中使用查询来分析日志。查询必须识别尝试访问并未成功访问存储在 /admin URL 路径下受限 Web 服务器内容的 IP 地址。查询还必须识别这些 IP 地址尝试访问的 URL。哪个查询可以满足这些要求？

- A. `SELECT client_ip, client_request FROM logs WHERE client_request LIKE '%/admin%!' AND server_status = '403'`
- B. `SELECT client_ip FROM logs WHERE client_request CONTAINS '%/admin%' AND server_status = '401' GROUP BY client_ip`
- C. `SELECT DISTINCT (client_ip), client_request, client_id FROM logs WHERE server status = '403' LIMIT 1000`
- D. `SELECT DISTINCT (client_ip), client_request FROM logs WHERE user_id <> 'admin' AND server_status = '401!'`

▼ 答案:

A

1. 考察的知识点

Amazon Athena的查询语法和功能。

日志分析的基本概念，包括HTTP状态码的含义(如403和401)。

如何使用SQL查询来筛选和分析日志数据。

2. 选项分析

A. `SELECT client_ip, client_request FROM logs WHERE client_request LIKE '%/admin%!' AND server_status = '403'`

正确:此查询使用了SQL的LIKE操作符来匹配包含"/admin"的URL路径，并筛选出HTTP状态码为403的记录。状态码403表示“禁止访问”，符合题目要求。

正确:返回了两个字段:client_ip(IP地址)和client_request(尝试访问的URL)，完全满足题目要求。

B. `SELECT client_ip FROM logs WHERE client_request CONTAINS '%/admin%' AND server_status = '401' GROUP BY client_ip`

错误:CONTAINS不是Amazon Athena支持的标准SQL操作符，应该使用LIKE。

错误:状态码401表示“未授权”，而题目要求的是状态码403(禁止访问)。

错误:GROUP BY的使用没有意义，因为题目没有要求对IP地址进行分组。

C. SELECT DISTINCT (client_ip), client_request, client_id FROM logs
WHERE server status = '403' LIMIT 1000

错误:虽然状态码403是正确的，但查询中包含了client_id字段，而题目没有要求返回该字段。

错误:LIMIT 1000限制了返回的记录数量，题目没有提到需要限制记录数量。

错误:语法中"server status"有拼写错误，应该是"server_status"。

D. SELECT DISTINCT (client_ip), client_request FROM logs WHERE
user_id <> 'admin' AND server_status = '401!'

错误:状态码401表示"未授权"，而题目要求的是状态码403(禁止访问)。

错误:user_id字段与题目无关，题目没有提到需要筛选user_id。

错误:语法中"server_status = '401!'"有问题，状态码不应该包含感叹号。

▼ 18

▼ 英文:

A company uses Amazon Cognito as an OAuth 2.0 identity platform for its web and mobile applications. The company needs to capture successful and unsuccessful login attempts. The company also needs to query the data about the login attempts.

Which solution will meet these requirements?

A. Configure Cognito to send logs of user activity to Amazon CloudWatch. Configure Amazon EventBridge to invoke an AWS Lambda function to export the logs to an Amazon S3 bucket. Use Amazon Athena to query the logs for event names of SignUp with event sources of cognito-idp.amazonaws.com.

B. Enable AWS CloudTrail to deliver logs to an Amazon S3 bucket. Use Amazon Athena to query the logs for event names of InitiateAuth with event sources of cognito-idp.amazonaws.com.

C. Configure AWS CloudTrail to send Cognito CloudTrail events to Amazon CloudWatch for monitoring. Query the event logs for event names of SignUp with event sources of cognito-idp.amazonaws.com.

D. Configure Amazon CloudWatch metrics to monitor and report Cognito events. Create a CloudWatch dashboard for the provided metrics. Display the Cognito user pools for event names of InitiateAuth with event sources of cognito-idp.amazonaws.com.

▼ 中文:

一家公司使用 Amazon Cognito 作为其网页和移动应用程序的 OAuth 2.0 身份平台。该公司需要捕获成功和失败的登录尝试。公司还需要查询有关登录尝试的数据。哪种解决方案可以满足这些要求？

- A. 配置 Cognito 将用户活动日志发送到 Amazon CloudWatch。配置 Amazon EventBridge 调用 AWS Lambda 函数以将日志导出到 Amazon S3 存储桶。使用 Amazon Athena 查询事件名称为 SignUp 且事件来源为 cognito-idp.amazonaws.com 的日志。
- B. 启用 AWS CloudTrail 将日志传递到 Amazon S3 存储桶。使用 Amazon Athena 查询事件名称为 InitiateAuth 且事件来源为 cognito-idp.amazonaws.com 的日志。
- C. 配置 AWS CloudTrail 将 Cognito 的 CloudTrail 事件发送到 Amazon CloudWatch 进行监控。查询事件日志，事件名称为 SignUp 且事件来源为 cognito-idp.amazonaws.com。
- D. 配置 Amazon CloudWatch 指标以监控和报告 Cognito 事件。为提供的指标创建一个 CloudWatch 仪表板。显示 Cognito 用户池，事件名称为 InitiateAuth 且事件来源为 cognito-idp.amazonaws.com。

▼ 答案:

B

1. 考察的知识点

Amazon Cognito 的身份验证日志记录功能。

AWS CloudTrail 的日志记录和查询能力。

Amazon Athena 的日志查询功能。

如何捕获和分析用户登录事件(成功和失败)。

2. 选项分析

A. 配置 Cognito 将用户活动日志发送到 Amazon CloudWatch。配置 Amazon EventBridge 调用 AWS Lambda 函数以将日志导出到 Amazon S3 存储桶。使用 Amazon Athena 查询事件名称为 SignUp 且事件来源为 cognito-idp.amazonaws.com 的日志。

分析:

Cognito 本身无法直接将用户活动日志发送到 CloudWatch。需要通过 CloudTrail 来捕获 Cognito 的事件。

虽然可以使用 EventBridge 和 Lambda 将日志导出到 S3，但这增加了复杂性，并不是最佳实践。

事件名称 SignUp 仅与用户注册相关，而题目要求捕获登录事件(成功和失

败)，因此不符合题目要求。

结论: 错误。

B. 启用 AWS CloudTrail 将日志传递到 Amazon S3 存储桶。使用 Amazon Athena 查询事件名称为 InitiateAuth 且事件来源为 cognito-idp.amazonaws.com 的日志。

分析:

CloudTrail 是捕获 Cognito 登录事件的正确工具。它可以记录 InitiateAuth 事件(登录尝试，包括成功和失败)。

将 CloudTrail 日志存储到 S3 是标准做法，方便后续查询。

使用 Amazon Athena 查询 S3 中的日志是高效的解决方案，符合题目要求。

结论: 正确。

C. 配置 AWS CloudTrail 将 Cognito 的 CloudTrail 事件发送到 Amazon CloudWatch 进行监控。查询事件日志，事件名称为 SignUp 且事件来源为 cognito-idp.amazonaws.com。

分析:

CloudTrail 可以捕获 Cognito 的事件，但直接发送到 CloudWatch 进行监控并不适合查询历史数据。

事件名称 SignUp 与用户注册相关，而题目要求捕获登录事件(成功和失败)，因此不符合题目要求。

结论: 错误。

D. 配置 Amazon CloudWatch 指标以监控和报告 Cognito 事件。为提供的指标创建一个 CloudWatch 仪表板。显示

Cognito 用户池，事件名称为 InitiateAuth 且事件来源为 cognito-idp.amazonaws.com。

分析:

CloudWatch 主要用于监控指标，而不是存储和查询详细的事件日志。

题目要求查询登录事件的详细数据，而不是创建仪表板监控指标。

结论: 错误。

▼ 19

▼ 英文:

A security engineer is setting up an AWS CloudTrail trail for all regions in an AWS account. For added security, the logs are stored using server-side encryption with AWS KMS-managed keys (SSE-KMS) and have log integrity validation enabled.

While testing the solution, the security engineer discovers that the digest files are readable, but the log files are not. What is the MOST likely cause?

- A. The log files fail integrity validation and automatically are marked as unavailable.
- B. The KMS key policy does not grant the security engineer's IAM user or role permissions to decrypt with it.
- C. The bucket is set up to use server-side encryption with Amazon S3-managed keys (SSE-S3) as the default and does not allow SSE-KMS-encrypted files.
- D. An IAM policy applicable to the security engineer's IAM user or role denies access to the "CloudTrail/" prefix in the Amazon S3 bucket.

▼ 中文:

一位安全工程师正在为一个 AWS 账户中的所有区域设置 AWS CloudTrail 跟踪。为了增强安全性，日志使用 AWS KMS 管理的密钥 (SSE-KMS) 进行服务器端加密，并启用了日志完整性验证。
在测试解决方案时，安全工程师发现摘要文件是可读的，但日志文件不可读。最可能的原因是什么？

- A. 日志文件未通过完整性验证并自动标记为不可用。
- B. KMS 密钥策略未授予安全工程师的 IAM 用户或角色使用该密钥解密的权利。
- C. 存储桶设置为使用 Amazon S3 管理的密钥 (SSE-S3) 作为默认服务器端加密方式，并且不允许 SSE-KMS 加密的文件。
- D. 适用于安全工程师的 IAM 用户或角色的 IAM 策略拒绝访问 Amazon S3 存储桶中的 "CloudTrail/" 前缀。

▼ 答案:

B

1. 考察的知识点

CloudTrail日志的存储与加密机制，包括SSE-KMS。

AWS KMS密钥策略的配置与权限管理。

IAM策略对资源访问的控制。

日志完整性验证的工作原理。

2. 选项分析

- A. The log files fail integrity validation and automatically are marked as unavailable.

错误:CloudTrail日志的完整性验证失败不会导致日志文件不可读。完整性验证是为了确保日志未被篡改,但即使验证失败,日志文件仍然可以被读取。

B. The KMS key policy does not grant the security engineer's IAM user or role permissions to decrypt with it.

正确:如果KMS密钥策略未授予用户或角色解密权限,用户将无法读取使用SSE-KMS加密的日志文件。这与题目描述的现象一致,即日志文件不可读。

C. The bucket is set up to use server-side encryption with Amazon S3-managed keys (SSE-S3) as the default and does not allow SSE-KMS-encrypted files.

错误:S3存储桶可以同时存储使用SSE-S3和SSE-KMS加密的文件。默认加密设置不会影响存储桶接受其他加密方式的文件。

D. An IAM policy applicable to the security engineer's IAM user or role denies access to the "CloudTrail/" prefix in the Amazon S3 bucket.

错误:如果IAM策略拒绝访问"CloudTrail/"前缀,用户将无法读取任何文件,包括digest文件。然而题目中提到digest文件是可读的,因此此选项不符合题目描述。

▼ 20

▼ 英文:

A company needs to securely deploy resources and workloads across AWS accounts. The accounts are in an organization in AWS Organizations.

The company needs to use AWS CloudFormation for infrastructure as code (IaC) management of approved architectural patterns. The company also must enforce tagging requirements and specific guidelines for resource and workload configuration and creation.

Which solution will meet these requirements?

A. Use CloudFormation stack policies to prevent the creation of resources that do not meet the tagging or configuration requirements. Use Amazon EventBridge rules to detect API calls that attempt to create resources outside of CloudFormation.

B. Use an AWS CodePipeline pipeline to test and deploy IaC defined workloads through CloudFormation into the accounts. Use AWS Config rules to enforce the tagging requirements. Apply an SCP to prevent the creation of misconfigured resources in all OUs.

C. Create an IAM permissions boundary to prevent the creation of misconfigured resources through CloudFormation and to enforce the tagging requirements. Apply the permissions boundary to all account roles. Use AWS Config rules to identify existing resources that are in a misconfigured state.

D. Use AWS Service Catalog with CloudFormation to manage access to approved architecture configurations. Provision Service Catalog portfolios to the accounts across the organization. Use AWS Config rules to enforce the tagging requirements and other resource configuration policies across accounts.

▼ 中文:

一家公司需要在多个 AWS 账户之间安全地部署资源和工作负载。这些账户属于 AWS Organizations 中的一个组织。

该公司需要使用 AWS CloudFormation 来管理经过批准的架构模式的基础设施即代码(IaC)。公司还必须[强制执行标签要求以及资源和工作负载配置与创建的具体指南](#)。

哪种解决方案可以满足这些要求？

A. 使用 CloudFormation stack policies 来防止创建不符合标签或配置要求的资源。使用 Amazon EventBridge 规则检测在 CloudFormation 之外创建资源的 API 调用。

B. 使用 AWS CodePipeline 管道通过 CloudFormation 测试和部署 IaC 定义的工作负载到账户中。使用 AWS Config 规则强制执行标签要求。应用 SCP 来防止在所有 OU 中创建配置错误的资源。

C. 创建一个 IAM permissions boundary 来防止通过 CloudFormation 创建配置错误的资源，并强制执行标签要求。将 permissions boundary 应用于所有账户角色。使用 AWS Config 规则识别处于配置错误状态的现有资源。

D. 使用 AWS Service Catalog 和 CloudFormation 来管理对经过批准的架构配置的访问。将 Service Catalog portfolios 提供给组织中的账户。使用 AWS Config 规则强制执行标签要求以及跨账户的其他资源配置策略。

▼ 答案:

D

1. 考察的知识点

跨账户资源管理与部署的安全性。

使用AWS CloudFormation进行基础设施即代码(IaC)管理。

强制执行标签要求和资源配置策略。

使用AWS Service Catalog和AWS Config进行资源管理和合规性检查。

2. 选项分析

A. 使用 CloudFormation stack policies 和 EventBridge:

CloudFormation stack policies可以限制对堆栈资源的操作，但它无法强制执行标签要求或资源配置策略。

EventBridge可以监控API调用，但它无法直接阻止资源创建，只能触发事件进行后续处理。

此选项无法全面满足题目要求，因此错误。

B. 使用 CodePipeline、AWS Config 和 SCP:

CodePipeline可以用于测试和部署，但它无法直接管理跨账户的资源访问或强制执行标签要求。

AWS Config可以强制执行标签要求，但它只能检测现有资源的合规性，无法阻止资源创建。

SCP(Service Control Policies)可以限制账户级别的操作，但它无法细粒度地管理资源配置或标签要求。

此选项部分满足要求，但不够全面，因此错误。

C. 使用 IAM permissions boundary 和 AWS Config:

IAM permissions boundary可以限制资源创建，但它无法直接强制执行标签要求或资源配置策略。

AWS Config可以检测现有资源的合规性，但无法阻止资源创建。

此选项无法全面满足题目要求，因此错误。

D. 使用 AWS Service Catalog 和 AWS Config:

AWS Service Catalog允许管理员定义和管理经过批准的架构配置，并通过CloudFormation进行部署。

Service Catalog portfolios可以跨账户分发，确保资源和工作负载符合公司批准的架构模式。

AWS Config可以强制执行标签要求和其他资源配置策略，确保资源的合规性。

此选项全面满足题目要求，因此正确。

▼ 21

▼ 英文:

A company is migrating its Amazon EC2 based applications to use Instance Metadata Service Version 2 (IMDSv2). A security engineer

needs to determine whether any of the EC2 instances are still using Instance Metadata Service Version 1 (IMDSv1).

What should the security engineer do to confirm that the IMDSv1 endpoint is no longer being used?

- A. Configure logging on the Amazon CloudWatch agent for IMDSv1 as part of EC2 instance startup. Create a metric filter and a CloudWatch dashboard. Track the metric in the dashboard.
- B. Create an Amazon CloudWatch dashboard. Verify that the EC2:MetadataNoToken metric is zero across all EC2 instances. Monitor the dashboard.
- C. Create a security group that blocks access to HTTP for the IMDSv1 endpoint. Attach the security group to all EC2 instances.
- D. Configure user data scripts for all EC2 instances to send logging information to AWS CloudTrail when IMDSV1 is used. Create a metric filter and an Amazon CloudWatch dashboard. Track the metric in the dashboard.

▼ 中文:

一家公司正在将其基于 Amazon EC2 的应用程序迁移为使用 Instance Metadata Service Version 2 (IMDSv2)。一名安全工程师需要确定是否有任何 EC2 实例仍在使用 Instance Metadata Service Version 1 (IMDSv1)。安全工程师应该如何确认 IMDSv1 端点不再被使用？

- A.在 EC2 实例启动时，为 IMDSv1 配置 Amazon CloudWatch agent 的日志记录。创建一个指标过滤器和一个 CloudWatch 仪表板。在仪表板中跟踪该指标。
- B.创建一个 Amazon CloudWatch 仪表板。验证 EC2:MetadataNoToken 指标在所有 EC2 实例中是否为零。在仪表板中进行监控。
- C.创建一个阻止访问 IMDSv1 端点的 HTTP 的安全组。将该安全组附加到所有 EC2 实例。
- D.为所有 EC2 实例配置用户数据脚本，以便在使用 IMDSv1 时将日志信息发送到 AWS CloudTrail。创建一个指标过滤器和一个 Amazon CloudWatch 仪表板。在仪表板中跟踪该指标。

▼ 答案:

B

1. 考察的知识点

本题考察的是对AWS EC2实例元数据服务(IMDSv1和IMDSv2)的理解，以及如何监控和验证实例是否使用IMDSv1。

涉及的服务包括Amazon CloudWatch、EC2元数据服务、以及安全性最佳实践。

2. 选项分析

A. 配置 Amazon CloudWatch agent 的日志记录，创建指标过滤器和仪表板。

错误:IMDSv1的使用并不会直接通过CloudWatch agent的日志记录反映出来。此方法无法有效确认IMDSv1是否被使用。

B. 创建一个 Amazon CloudWatch 仪表板，验证 EC2:MetadataNoToken 指标是否为零。

正确:EC2:MetadataNoToken 是一个专门的CloudWatch指标，用于监控是否有请求未使用IMDSv2的token。如果该指标为零，说明IMDSv1未被使用。

C. 创建一个阻止访问 IMDSv1 的 HTTP 的安全组。

错误:IMDSv1和IMDSv2都使用HTTP协议，无法通过安全组区分IMDSv1和IMDSv2的请求。

D. 配置用户数据脚本，将IMDSv1的使用日志发送到AWS CloudTrail。

错误:虽然可以通过用户数据脚本记录IMDSv1的使用，但这种方法需要额外的配置和开发工作，且不如直接使用CloudWatch指标高效。

▼ 22

▼ 英文:

A company is planning to create an organization by using AWS Organizations. The company needs to integrate user management with the company's external identity provider (IdP). The company also needs to centrally manage access to all of its AWS accounts and applications from the organization's management account.

Which solution will meet these requirements?

A. Configure AWS Directory Service with the external IdP. Create IAM policies and associate them with users from the external IdP.

B. Enable AWS IAM Identity Center and use the external IdP as the identity source. Create permission sets and account assignments by using IAM Identity Center.

C. Configure AWS Identity and Access Management (IAM) to use the external IdP as an IdP. Create IAM policies and associate them with

users from the external IdP.

D. Enable Amazon Cognito in the organization's management account. Create an identity pool and associate it with the external IdP. Create IAM roles and associate them with the identity pool.

▼ 中文:

一家公司计划通过使用AWS Organizations创建一个组织。该公司需要将用户管理与公司的外部身份提供商(IdP)集成。该公司还需要从组织的管理账户集中管理对其所有AWS账户和应用程序的访问。哪种解决方案可以满足这些要求?

A. 配置AWS Directory Service与外部IdP。创建IAM策略并将其与来自外部IdP的用户关联。

B. 启用AWS IAM Identity Center并使用外部IdP作为身份源。通过IAM Identity Center创建权限集和账户分配。

C. 配置AWS Identity and Access Management (IAM)以使用外部IdP作为IdP。创建IAM策略并将其与来自外部IdP的用户关联。

D. 在组织的管理账户中启用Amazon Cognito。创建一个身份池并将其与外部IdP关联。创建IAM角色并将其与身份池关联。

▼ 答案:

B

1. 考察的知识点

本题考察AWS Organizations的使用，以及如何集成外部身份提供商(IdP)进行用户管理和权限管理。

涉及AWS IAM Identity Center(原AWS SSO)、IAM策略、AWS Directory Service、Amazon Cognito等服务的功能和适用场景。

2. 选项分析

A. Configure AWS Directory Service with the external IdP. Create IAM policies and associate them with users from the external IdP.

错误:AWS Directory Service主要用于与Microsoft Active Directory集成，而不是直接与外部IdP集成。它不支持集中管理所有AWS账户和应用的权限。

此外，IAM策略的管理需要逐个账户配置，无法实现集中管理。

B. Enable AWS IAM Identity Center and use the external IdP as the identity source. Create permission sets and account assignments by using IAM Identity Center.

正确:AWS IAM Identity Center(原AWS SSO)支持与外部IdP集成作为身份

源，并允许集中管理AWS账户和应用的访问权限。

通过IAM Identity Center，可以创建权限集和账户分配，从而实现集中管理和简化用户访问控制。

C. Configure AWS Identity and Access Management (IAM) to use the external IdP as an IdP. Create IAM policies and associate them with users from the external IdP.

错误:IAM本身支持与外部IdP集成，但它的管理是基于单个账户的，无法实现跨AWS账户的集中管理。

IAM策略需要逐个账户配置，无法满足题目要求的集中管理需求。

D. Enable Amazon Cognito in the organization's management account. Create an identity pool and associate it with the external IdP. Create IAM roles and associate them with the identity pool.

错误:Amazon Cognito主要用于应用程序的用户身份验证和授权，而不是用于集中管理AWS账户的访问权限。

它不适合用于AWS Organizations的跨账户权限管理场景。

▼ 23

▼ 英文:

A company uses Amazon Elastic Container Registry (Amazon ECR) as the repository for its production applications. A security engineer must implement an automated solution to report any vulnerabilities that ECR enhanced scanning detects. The solution must provide notification of vulnerability findings in an instant message to the company's Slack account

Which solution will meet these requirements with the MOST operational efficiency?

A. Activate Amazon Inspector scans for the ECR repository. Create an Amazon Simple Notification Service (Amazon SNS) topic. Configure an AWS Chatbot client for Slack that consumes the SNS topic. Create an Amazon EventBridge rule for Amazon Inspector findings. Specify the SNS topic as the target for the rule.

B. Activate Amazon Inspector scans for the ECR repository. Write a script to use AWS CLI commands to retrieve image scan findings from Amazon Inspector. Configure the script to send the findings to a Slack endpoint. Launch an Amazon EC2 instance to run the script.

C. Activate Amazon Inspector scans for the ECR repository. Create an AWS Step Functions state machine. Set a first step in the state machine to call the Amazon Inspector ListFindings API operation. Create an

Amazon Simple Notification Service (Amazon SNS) topic with Slack as the target. Add a second step in the state machine to call the Amazon SNS Publish API operation.

D. Activate AWS Security Hub scans for the ECR repository. Create a custom action in Security Hub for findings. Define an Amazon EventBridge rule for the custom action. Configure the EventBridge rule to redirect the findings to a Slack channel.

▼ 中文:

一家公司使用 Amazon Elastic Container Registry (Amazon ECR) 作为其生产应用的存储库。一名安全工程师必须实施一个自动化解决方案，以报告任何由 ECR 增强扫描检测到的漏洞。该解决方案必须能够通过即时消息将漏洞发现通知发送到公司的 Slack 账户。

哪个解决方案能够以最高的运营效率满足这些要求？

A. 激活 Amazon Inspector 扫描 ECR 存储库。创建一个 Amazon Simple Notification Service (Amazon SNS) 主题。配置一个 AWS Chatbot 客户端，用于 Slack 并消费该 SNS 主题。为 Amazon Inspector 的发现创建一个 Amazon EventBridge 规则。指定该 SNS 主题作为规则的目标。

B. 激活 Amazon Inspector 扫描 ECR 存储库。编写一个脚本，使用 AWS CLI 命令从 Amazon Inspector 检索镜像扫描发现。配置脚本将发现发送到一个 Slack 端点。启动一个 Amazon EC2 实例来运行该脚本。

C. 激活 Amazon Inspector 扫描 ECR 存储库。创建一个 AWS Step Functions 状态机。在状态机中设置第一步以调用 Amazon Inspector 的 ListFindings API 操作。创建一个以 Slack 为目标的 Amazon Simple Notification Service (Amazon SNS) 主题。在状态机中添加第二步以调用 Amazon SNS 的 Publish API 操作。

D. 激活 AWS Security Hub 扫描 ECR 存储库。为发现创建一个 Security Hub 的自定义操作。为自定义操作定义一个 Amazon EventBridge 规则。配置 EventBridge 规则将发现重定向到一个 Slack 频道。

▼ 答案:

A

1. 考察的知识点

Amazon Inspector的功能及其与ECR的集成。
Amazon SNS的使用及其与AWS Chatbot的集成。
Amazon EventBridge规则的配置与事件处理。
Slack集成的实现方式。

2. 选项分析

A.

正确:此选项使用Amazon Inspector扫描ECR镜像，并通过EventBridge规则将发现发送到SNS主题。然后通过AWSChatbot将SNS消息发送到Slack。这种方法是自动化的，且具有高操作效率。

B.

错误:此选项需要手动编写脚本并运行EC2实例，增加了操作复杂性和维护成本，不符合“最高操作效率”的要求。

C.

错误:虽然此选项可以实现目标，但使用Step Functions增加了额外的复杂性，且不如选项A直接通过EventBridge规则实现的方式高效。

D.

错误:AWS Security Hub并不直接支持ECR镜像扫描，而Amazon Inspector是专门用于ECR镜像扫描的服务。因此此选项不符合题目要求。

▼ 24

▼ 英文:

A company uses AWS Config rules to identify Amazon S3 buckets that are not compliant with the company's data protection policy. The S3 buckets are hosted in several AWS Regions and several AWS accounts. The accounts are in an organization in AWS Organizations.

The company needs a solution to remediate the organization's existing noncompliant S3 buckets and any noncompliant S3 buckets that are created in the future.

Which solution will meet these requirements?

A. Deploy an AWS Config aggregator with organization-wide resource data aggregation. Create an AWS Lambda function that responds to AWS Config findings of noncompliant S3 buckets by deleting or reconfiguring the S3 buckets.

B. Deploy an AWS Config aggregator with organization-wide resource data aggregation. Create an SCP that contains a Deny statement that prevents the creation of new noncompliant S3 buckets. Apply the SCP to all OUs in the organization.

C. Deploy an AWS Config aggregator that scopes only the accounts and Regions that the company currently uses. Create an AWS Lambda function that responds to AWS Config findings of noncompliant S3 buckets by deleting or reconfiguring the S3 buckets.

D. Deploy an AWS Config aggregator that scopes only the accounts and Regions that the company currently uses. Create an SCP that contains a Deny statement that prevents the creation of new noncompliant S3 buckets. Apply the SCP to all OUs in the organization.

▼ 中文:

一家公司使用 AWS Config 规则来识别不符合公司数据保护策略的 Amazon S3 存储桶。这些 S3 存储桶托管在多个 AWS 区域和多个 AWS 账户中。这些账户属于 AWS Organizations 中的一个组织。该公司需要一种解决方案，以修复组织中现有的不合规 S3 存储桶，以及未来创建的任何不合规 S3 存储桶。哪种解决方案可以满足这些需求？

A.部署一个具有组织范围资源数据聚合的 AWS Config 聚合器。创建一个 AWS Lambda 函数，该函数通过删除或重新配置 S3 存储桶来响应 AWS Config 对不合规 S3 存储桶的发现。

B.部署一个具有组织范围资源数据聚合的 AWS Config 聚合器。创建一个包含 Deny 语句的 SCP，该语句阻止创建新的不合规 S3 存储桶。将 SCP 应用于组织中的所有 OU。

C.部署一个仅限于公司当前使用的账户和区域的 AWS Config 聚合器。创建一个 AWS Lambda 函数，该函数通过删除或重新配置 S3 存储桶来响应 AWS Config 对不合规 S3 存储桶的发现。

D.部署一个仅限于公司当前使用的账户和区域的 AWS Config 聚合器。创建一个包含 Deny 语句的 SCP，该语句阻止创建新的不合规 S3 存储桶。将 SCP 应用于组织中的所有 OU。

▼ 答案:

A

AWS Config规则的使用和跨账户资源聚合。
如何使用AWS Lambda进行自动化修复。

组织范围内的资源管理和策略应用(AWS Organizations)。

2. 选项分析

A. 部署一个具有组织范围资源数据聚合的 AWS Config 聚合器。创建一个 AWS Lambda 函数，该函数通过删除或重新配置 S3 存储桶来响应 AWS Config 对不合规 S3 存储桶的发现。

正确:此选项使用AWS Config聚合器收集组织范围内的资源数据，并通过 AWS Lambda函数自动修复不合规的S3存储桶。这满足了题目要求的“现有和未来的不合规存储桶”的修复需求。

B. 部署一个具有组织范围资源数据聚合的 AWS Config 聚合器。创建一个包含 Deny 语句的 SCP，该语句阻止创建新的不合规 S3 存储桶。将 SCP 应用于组织中的所有 OU。

错误:SCP(Service Control Policy)可以阻止未来的不合规存储桶的创建，但无法修复现有的不合规存储桶。因此不满足题目要求。

C. 部署一个仅限于公司当前使用的账户和区域的 AWS Config 聚合器。创建一个 AWS Lambda 函数，该函数通过删除或重新配置 S3 存储桶来响应 AWS Config 对不合规 S3 存储桶的发现。错误:此选项仅限于当前使用的账户和区域，无法覆盖组织范围内的所有账户和区域，不符合题目要求的“组织范围”需求。

D. 部署一个仅限于公司当前使用的账户和区域的 AWS Config 聚合器。创建一个包含 Deny 语句的 SCP，该语句阻止创建新的不合规 S3 存储桶。将 SCP 应用于组织中的所有 OU。

错误:与选项B类似，SCP无法修复现有的不合规存储桶。此外，此选项仅限于当前使用的账户和区域，无法覆盖组织范围内的所有账户和区域。

▼ 25

▼ 英文:

A company's engineering team is developing a new application that creates AWS Key Management Service (AWS KMS) customer managed key grants for users. Immediately after a grant is created, users must be able to use the KMS key to encrypt a 512-byte payload. During load testing, AccessDeniedException errors occur occasionally when a user first attempts to use the key to encrypt.

Which solution should the company's security specialist recommend to eliminate these AccessDeniedException errors?

A. Instruct users to implement a retry mechanism every 2 minutes until the call succeeds.

B. Instruct the engineering team to consume a random grant token from users and to call the CreateGrant operation by passing the grant token to the operation. Instruct users to use that grant token in their call to encrypt.

C. Instruct the engineering team to create a random name for the grant when calling the CreateGrant operation. Return the name to the users and instruct them to provide the name as the grant token in the call to encrypt.

D. Instruct the engineering team to pass the grant token returned in the CreateGrant response to users. Instruct users to use that grant token in their call to encrypt.

▼ 中文:

一家公司的工程团队正在开发一个新应用程序，该应用程序为用户创建 AWS Key Management Service (AWS KMS) 客户托管密钥授权。授权创建后，用户必须能够立即使用 KMS 密钥加密一个 512 字节的有效负载。在负载测试期间，当用户首次尝试使用密钥进行加密时，偶尔会出现 `AccessDeniedException` 错误。

公司安全专家应推荐哪种解决方案以消除这些 `AccessDeniedException` 错误？

A.指示用户每隔 2 分钟实施一次重试机制，直到调用成功。

B.指示工程团队从用户处消费一个随机授权令牌，并通过将授权令牌传递给 `CreateGrant` 操作来调用该操作。指示用户在其加密调用中使用该授权令牌。

C.指示工程团队在调用 `CreateGrant` 操作时为授权创建一个随机名称。将该名称返回给用户，并指示他们在加密调用 中将该名称作为授权令牌提供。

D.指示工程团队将 `CreateGrant` 响应中返回的授权令牌传递给用户。指示用户在其加密调用中使用该授权令牌。

▼ 答案:

D

1. 考察的知识点

本题考察的是AWS Key Management Service (AWS KMS)的授权机制，特别是客户管理密钥(Customer Managed Key)的授权令牌(Grant Token)的使用。

理解如何正确使用授权令牌以避免权限问题(AccessDeniedException)。

2. 选项分析

A. I

错误:虽然重试机制可以解决某些临时问题，但它并不能解决根本问题。

AccessDeniedException通常是由于权限问题或授权未正确传递导致的，而不是临时性问题。

B.

错误:授权令牌(Grant Token)是由AWS KMS在CreateGrant操作的响应中返回的，不能随机生成。随机生成的令牌无法与AWS KMS的验证机制匹配。

C.

错误:授权令牌不是通过随机名称生成的。授权令牌是AWS KMS在CreateGrant操作的响应中返回的，随机名称无法作为有效的授权令牌使用。

D.

正确:授权令牌是AWS KMS在CreateGrant操作的响应中返回的。用户需要使用该令牌来执行加密操作，以确保权限正确传递并避免AccessDeniedException错误。

▼ 26

▼ 英文:

A company hosts its public website on Amazon EC2 instances behind an Application Load Balancer (ALB). The website is experiencing a global DDoS attack by a specific IoT device brand that has a unique user agent.

A security engineer is creating an AWS WAF web ACL and will associate the web ACL with the ALB. The security engineer must implement a rule statement as part of the web ACL to block the requests. The rule statement must mitigate the current attack and future attacks from these IoT devices without blocking requests from customers.

Which rule statement will meet these requirements?

A. Use an IP set match rule statement that includes the IP address for IoT devices from the user agent.

B. Use a geographic match rule statement. Configure the statement to block countries that the IoT devices are located in.

C. Use a rate-based rule statement. Set a rate limit that is equal to the number of requests that are coming from the IoT devices.

D. Use a string match rule statement that includes details of the IoT device brand from the user agent.

▼ 中文:

一家公司将其公共网站托管在 Amazon EC2 实例上，并通过 Application Load Balancer (ALB) 进行负载均衡。该网站目前正在遭受来自某个特定 IoT 设备品牌的全球 DDoS 攻击，该品牌具有唯一的用户代理。

一名安全工程师正在创建一个 AWS WAF web ACL，并将该 web ACL 与 ALB 关联。安全工程师必须在 web ACL 中实现一个规则声明，以阻止这些请求。该规则声明必须能够缓解当前攻击以及来自这些 IoT 设备的未来攻击，同时不阻止客户的请求。

哪个规则声明可以满足这些要求？

A. 使用包含来自用户代理的 IoT 设备 IP 地址的 IP set match 规则声明。

B. 使用 geographic match 规则声明。将声明配置为阻止 IoT 设备所在国家/地区。

C. 使用 rate-based 规则声明。设置一个等于来自 IoT 设备请求数量的速率限制。

D. 使用包含来自用户代理的 IoT 设备品牌详细信息的 string match 规则声明。

▼ 答案:

D

1. 考察的知识点

本题考察AWS WAF(Web Application Firewall)的规则配置，特别是如何使用规则语句(Rule Statement)来阻止特定类型的攻击。

重点在于如何基于用户代理(User Agent)信息来识别和阻止恶意请求，同时确保不会影响正常用户的访问。

2. 选项分析

A. 使用包含来自用户代理的 IoT 设备 IP 地址的 IP set match 规则声明。

错误:DDoS攻击通常来自大量分布式的IP地址，攻击者可能会动态更改IP地址，因此基于IP地址的匹配规则无法有效阻止攻击。

此外，题目中并未提到具体的IP地址列表，因此无法实现针对性阻止。

B. 使用 geographic match 规则声明。将声明配置为阻止 IoT 设备所在国家/

地区。

错误:地理位置匹配规则会阻止整个国家或地区的流量，这可能会误伤正常用户，尤其是全球性网站。

题目要求不影响客户访问，因此地理位置匹配不符合要求。

C. 使用 rate-based 规则声明。设置一个等于来自 IoT 设备请求数量的速率限制。

错误:Rate-based规则限制请求速率，但无法区分正常用户和恶意IoT设备的请求。

题目要求基于用户代理信息来识别攻击，而不是基于请求速率。

D. 使用包含来自用户代理的 IoT 设备品牌详细信息的 string match 规则声明。

正确:用户代理(User Agent)是攻击的关键特征，使用string match规则可以精确匹配IoT设备的品牌信息。这种方法可以有效阻止恶意请求，同时不会影响正常用户的访问。

▼ 27

▼ 英文:

A company has configured a gateway VPC endpoint in a VPC. Only Amazon EC2 instances that reside in a single subnet in the VPC can use the endpoint.

The company has modified the route table for this single subnet to route traffic to Amazon S3 through the gateway VPC endpoint. The VPC provides internet access through an internet gateway.

A security engineer attempts to use instance profile credentials from an EC2 instance to retrieve an object from the S3 bucket, but the attempt fails. The security engineer verifies that the EC2 instance has an IAM instance profile with the correct permissions to access the S3 bucket and to retrieve objects. The security engineer also verifies that the S3 bucket policy is allowing access properly. Additionally, the security engineer verifies that the EC2 instance's security group and the subnet's network ACLs allow the communication.

What else should the security engineer check to determine why the request from the EC2 instance is failing?

A. Verify that the EC2 instance's security group does not have an implicit inbound deny rule for Amazon S3.

B. Verify that the VPC endpoint's security group does not have an explicit inbound deny rule for the EC2 instance.

- C. Verify that the internet gateway is allowing traffic to Amazon S3.
 - D. Verify that the VPC endpoint policy is allowing access to Amazon S3.
- Most Voted

▼ 中文:

一家公司在VPC中配置了一个网关VPC端点。只有位于该VPC中单个子网中的Amazon EC2实例可以使用该端点。

该公司已修改此单个子网的路由表，通过网关VPC端点将流量路由到Amazon S3。VPC通过一个互联网网关提供互联网访问。

一名安全工程师尝试使用EC2实例的实例配置文件凭证从S3桶中检索对象，但尝试失败。安全工程师验证了EC2实例具有正确权限的IAM实例配置文件，可以访问S3桶并检索对象。安全工程师还验证了S3桶策略正确允许访问。此外，安全工程师验证了EC2实例的安全组和子网的网络ACL允许通信。

安全工程师还应该检查什么以确定为什么来自EC2实例的请求失败？

- A. 验证EC2实例的安全组是否没有对Amazon S3的隐式入站拒绝规则。
- B. 验证VPC端点的安全组是否没有对EC2实例的显式入站拒绝规则。
- C. 验证互联网网关是否允许流量到Amazon S3。
- D. 验证VPC端点策略是否允许访问Amazon S3。

▼ 答案:

D

1. 考察的知识点

VPC Gateway Endpoint的配置与使用。

IAM权限与VPC Endpoint策略的交互。

网络配置(安全组、路由表、ACL等)的排查与验证。

2. 选项分析

A. Verify that the EC2 instance's security group does not have an implicit inbound deny rule for Amazon S3.

安全组默认是“允许出站流量，拒绝入站流量”，但安全组不会直接针对Amazon S3进行隐式入站拒绝。

安全组的规则是基于IP和端口，而不是服务级别(如Amazon S3)。

此选项与问题无关，因此错误。

B. Verify that the VPC endpoint's security group does not have an explicit inbound deny rule for the EC2 instance.

VPC Gateway Endpoint不使用安全组。安全组仅适用于接口端点(Interface Endpoint)。

此选项与Gateway Endpoint无关，因此错误。

C. Verify that the internet gateway is allowing traffic to Amazon S3.

通过VPC Gateway Endpoint访问Amazon S3时，流量不会通过互联网网关(Internet Gateway)。此选项与问题无关，因此错误。

D. Verify that the VPC endpoint policy is allowing access to Amazon S3.

VPC Gateway Endpoint可以配置一个端点策略，用于控制哪些服务或资源可以通过该端点访问。

如果端点策略未正确配置，可能会导致访问失败，即使IAM权限和其他网络配置都正确。

此选项正确。

▼ 28

▼ 英文:

A security administrator is restricting the capabilities of company root user accounts. The company uses AWS Organizations and has all features enabled.

The management account is used for billing and administrative purposes, but it is not used for operational AWS resource purposes.

How can the security administrator restrict usage of member root user accounts across the organization?

A. Disable the use of the root user account at the organizational root. Enable multi-factor authentication (MFA) of the root user account for each organization member account.

B. Configure IAM user policies to restrict root account capabilities for each organization member account.

C. Create an OU in Organizations, and attach an SCP that controls usage of the root user. Add all member accounts to the new OU.

D. Configure AWS CloudTrail to integrate with Amazon CloudWatch Logs. Create a metric filter for RootAccountUsage.

▼ 中文:

安全管理员正在限制公司根用户账户的功能。公司使用AWS Organizations，并启用了所有功能。管理账户用于计费 and 行政目的，但不用于操作AWS资源目的。安全管理员如何限制整个组织中成员根用户账户的使用？

- A. 在组织根级别禁用根用户账户的使用。为每个组织成员账户的根用户账户启用多重身份验证(MFA)。
- B. 配置IAM用户策略以限制每个组织成员账户的根账户功能。
- C. 在Organizations中创建一个OU，并附加一个控制根用户使用的SCP。将所有成员账户添加到新的OU中。
- D. 配置AWS CloudTrail以集成Amazon CloudWatch Logs。为RootAccountUsage创建一个指标过滤器。

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS Organizations的服务控制策略(SCP)的使用，以及如何限制根用户账户的操作权限。

还涉及到AWS账户管理的最佳实践，包括如何保护和限制根用户账户的使用。

2. 选项分析

A. Disable the use of the root user account at the organizational root. Enable multi-factor authentication (MFA) of the root user account for each organization member account.

错误:AWS Organizations无法直接禁用根用户账户的使用。虽然启用MFA是保护根用户账户的最佳实践，但它并不能限制根用户的操作权限。

B. Configure IAM user policies to restrict root account capabilities for each organization member account.

错误:IAM用户策略无法直接应用于根用户账户。根用户账户的权限是固有的，不能通过IAM策略进行限制。

C. Create an OU in Organizations, and attach an SCP that controls usage of the root user. Add all member accounts to the new OU.

正确:服务控制策略(SCP)是AWS Organizations提供的功能，可以限制组织中成员账户的权限，包括根用户账户的操作权限。

通过创建一个组织单元(OU)并附加SCP，可以有效地控制成员账户的根用户使用。

D. Configure AWS CloudTrail to integrate with Amazon CloudWatch Logs. Create a metric filter for RootAccountUsage.

错误:虽然CloudTrail和CloudWatch Logs可以监控根用户的使用情况，但它

们无法直接限制根用户的操作权限。

3. 我的选择

▼ 29

▼ 英文:

A company wants to start processing sensitive data on Amazon EC2 instances. The company will use Amazon CloudWatch Logs to monitor, store, and access log files from the EC2 instances.

The company's developers use CloudWatch Logs for troubleshooting. A security engineer must implement a solution that prevents the developers from viewing the sensitive data. The solution must automatically apply to any new log groups that are created in the account in the future.

Which solution will meet these requirements?

A. Create a CloudWatch Logs account-wide data protection policy. Specify the appropriate data identifiers for the policy.

Ensure that the developers do not have the logs:Unmask IAM permission.

B. Export the CloudWatch Logs data to an Amazon S3 bucket. Set up automated discovery by using Amazon Macie on the S3 bucket. Create a custom data identifier for the sensitive data. Remove the developers' access to CloudWatch Logs.

Grant permissions for the developers to view the exported log data in Amazon S3.

C. Export the CloudWatch Logs data to an Amazon S3 bucket. Set up automated discovery by using Amazon Macie on the S3 bucket. Specify the appropriate managed data identifiers. Remove the developers' access to CloudWatch Logs. Grant permissions for the developers to view the exported log data in Amazon S3.

D. Create a CloudWatch Logs data protection policy for each log group. Specify the appropriate data identifiers for the policy. Ensure that the developers do not have the logs:Unmask IAM permission.

▼ 中文:

一家公司希望开始在 Amazon EC2 实例上处理敏感数据。该公司将使用 Amazon CloudWatch Logs 来监控、存储和访问来自 EC2 实例的日志文件。

公司的开发人员使用 CloudWatch Logs 进行故障排除。安全工程师必须实施一种解决方案，以防止开发人员查看敏感数据。该解决方案必须自动应用于未来在账户中创建的任何新的日志组。

哪种解决方案可以满足这些要求？

A. 创建一个 CloudWatch Logs 全账户范围的数据保护策略。为该策略指定适当的数据标识符。确保开发人员没有 logs:Unmask IAM 权限。

B. 将 CloudWatch Logs 数据导出到一个 Amazon S3 存储桶。使用 Amazon Macie 在 S3 存储桶上设置自动发现。为敏感数据创建一个自定义数据标识符。移除开发人员对 CloudWatch Logs 的访问权限。授予开发人员查看 Amazon S3 中导出的日志数据的权限。

C. 将 CloudWatch Logs 数据导出到一个 Amazon S3 存储桶。使用 Amazon Macie 在 S3 存储桶上设置自动发现。指定适当的托管数据标识符。移除开发人员对 CloudWatch Logs 的访问权限。授予开发人员查看 Amazon S3 中导出的日志数据的权限。

D. 为每个日志组创建一个 CloudWatch Logs 数据保护策略。为该策略指定适当的数据标识符。确保开发人员没有 logs:Unmask IAM 权限。

▼ 答案:

A

1. 考察的知识点

CloudWatch Logs 数据保护策略的使用。

IAM 权限管理，特别是 logs:Unmask 权限的控制。

自动化解决方案的设计，确保新创建的日志组也能应用安全策略。

2. 选项分析

A.

正确: CloudWatch Logs 支持账户范围的数据保护策略，可以自动应用于所有日志组，包括未来创建的日志组。

正确: 通过指定数据标识符，可以检测和保护敏感数据。

正确: 移除 logs:Unmask 权限可以防止开发人员查看被屏蔽的敏感数据。

B.

permissions for the developers to view the exported log data in Amazon S3.

错误: 将日志导出到 S3 并使用 Macie 是一种额外的复杂解决方案，无法直接满足题目要求的自动保护新创建的日志组。

错误: 题目要求保护敏感数据，而不是完全移除开发人员对 CloudWatch Logs

的访问权限。

C.

错误:与选项 B 类似，**导出到 S3 并使用 Macie 是一种复杂且不必要的解决方案。**

错误:无法自动保护新创建的日志组。

D.

错误:为每个日志组单独创建数据保护策略无法自动应用于未来创建的日志组，违背了题目要求。

正确:移除 logs:Unmask 权限可以防止开发人员查看敏感数据，但整体方案不够自动化。

▼ 30

▼ 英文:

A security engineer needs to implement a solution to identify any sensitive data that is stored in an Amazon S3 bucket. The solution must report on sensitive data in the S3 bucket by using an existing Amazon Simple Notification Service (Amazon SNS) topic.

Which solution will meet these requirements with the LEAST implementation effort?

A. Enable AWS Config. Configure AWS Config to monitor for sensitive data in the S3 bucket and to send notifications to the SNS topic.

B. Create an AWS Lambda function to scan the S3 bucket for sensitive data that matches a pattern. Program the Lambda function to send notifications to the SNS topic.

C. Configure Amazon Macie to use managed data identifiers to identify and categorize sensitive data. Create an Amazon EventBridge rule to send notifications to the SNS topic.

D. Enable Amazon GuardDuty. Configure AWS CloudTrail S3 data events. Create an Amazon CloudWatch alarm that reacts to GuardDuty findings and sends notifications to the SNS topic.

▼ 中文:

一位安全工程师需要实施一个解决方案，以识别存储在 Amazon S3 存储桶中的任何敏感数据。该解决方案必须通过使用现有的 Amazon Simple Notification Service (Amazon SNS) 主题来报告 S3 存储桶中的**敏感数据**。哪种解决方案可以**以最少的实施工作量满足这些要求**？

A. 启用 AWS Config。配置 AWS Config 以监控 S3 存储桶中的敏感数据，并将通知发送到 SNS 主题。

B. 创建一个 AWS Lambda 函数以扫描 S3 存储桶中与模式匹配的敏感数据。编程 Lambda 函数以将通知发送到 SNS 主题。

C. 配置 Amazon Macie 使用托管数据标识符来识别和分类敏感数据。创建一个 Amazon EventBridge 规则以将通知发送到 SNS 主题。

D. 启用 Amazon GuardDuty。配置 AWS CloudTrail S3 数据事件。创建一个 Amazon CloudWatch 警报以响应 GuardDuty 发现并将通知发送到 SNS 主题。

▼ 答案:

C

1. 考察的知识点

Amazon Macie的功能:识别和分类敏感数据。

Amazon SNS的集成:如何发送通知。

Amazon EventBridge的使用:事件驱动架构。

AWS服务的最佳实践:选择最少实施努力的解决方案。

2. 选项分析

A. 启用 AWS Config。配置 AWS Config 以监控 S3 存储桶中的敏感数据，并将通知发送到 SNS 主题。

错误原因:AWS Config主要用于资源配置和合规性检查，而不是直接扫描敏感数据。它无法识别S3存储桶中的敏感数据。

B. 创建一个 AWS Lambda 函数以扫描 S3 存储桶中与模式匹配的敏感数据。编程 Lambda 函数以将通知发送到SNS 主题。

错误原因:虽然Lambda可以实现此功能，但需要手动编写代码来扫描敏感数据，增加了实施复杂性，不符合“最少实施努力”的要求。

C. 配置 Amazon Macie 使用托管数据标识符来识别和分类敏感数据。创建一个 Amazon EventBridge 规则以将通知发送到 SNS 主题。

正确原因:Amazon Macie是专门设计用于识别和分类敏感数据的服务。它支持托管数据标识符，可以自动扫描S3存储桶中的敏感数据。通过EventBridge规则，可以轻松将发现结果发送到SNS主题，符合“最少实施努力”的要求。

D. 启用 Amazon GuardDuty。配置 AWS CloudTrail S3 数据事件。创建一个 Amazon CloudWatch 警报以响应 GuardDuty发现并将通知发送到 SNS 主题。

错误原因:GuardDuty主要用于检测威胁和异常行为，而不是扫描敏感数据。虽然可以通过CloudTrail和CloudWatch实现通知，但这不是最佳解决方案。

▼ 31

▼ 英文:

A company has an application on Amazon EC2 instances that store confidential customer data. The company must restrict access to customer data. A security engineer requires secure access to the instances that host the application. According to company policy, users must not open any inbound ports, maintain bastion hosts, or manage SSH keys for the EC2 instances.

The security engineer wants to monitor, store, and access all session activity logs. The logs must be encrypted.

Which solution will meet these requirements?

A. Use AWS Control Tower to connect to the EC2 instances. Configure Amazon CloudWatch logging for the sessions. Select the upload session logs option and allow only encrypted CloudWatch Logs log groups.

B. Use AWS Security Hub to connect to the EC2 instances. Configure Amazon CloudWatch logging for the sessions. Select the upload session logs option and allow only encrypted CloudWatch Logs log groups.

C. Use AWS Systems Manager Session Manager to connect to the EC2 instances. Configure Amazon CloudWatch monitoring to record the sessions. Select the store session logs option for the desired CloudWatch Logs log groups.

D. Use AWS Systems Manager Session Manager to connect to the EC2 instances. Configure Amazon CloudWatch logging. Select the upload session logs option and allow only encrypted CloudWatch Logs log groups.

▼ 中文:

一家公司在 Amazon EC2 实例上运行一个存储机密客户数据的应用程序。该公司必须限制对客户数据的访问。安全工程师需要安全地访问托管该应用程序的实例。根据公司政策，用户不得打开任何入站端口、维护 bastion hosts 或管理 EC2 实例的 SSH 密钥。

安全工程师希望监控、存储并访问所有会话活动日志。这些日志必须被加密。哪种解决方案可以满足这些要求？

- A.使用 AWS Control Tower 连接到 EC2 实例。为会话配置 Amazon CloudWatch 日志记录。选择上传会话日志选项，并 仅允许加密的 CloudWatch Logs 日志组。
- B.使用 AWS Security Hub 连接到 EC2 实例。为会话配置 Amazon CloudWatch 日志记录。选择上传会话日志选项，并仅 允许加密的 CloudWatch Logs 日志组。
- C.使用 AWS Systems Manager Session Manager 连接到 EC2 实例。配置 Amazon CloudWatch 监控以记录会话。为所需的 CloudWatch Logs 日志组选择存储会话日志选项。
- D.使用 AWS Systems Manager Session Manager 连接到 EC2 实例。配置 Amazon CloudWatch 日志记录。选择上传会话日志选项，并仅允许加密的 CloudWatch Logs 日志组。

▼ 答案:

D

1. 考察的知识点

安全访问 EC2 实例的最佳实践。

AWS Systems Manager Session Manager 的功能和配置。

如何使用 Amazon CloudWatch 记录和加密日志。

遵守公司安全政策(无入站端口、无 SSH 密钥管理等)。

2. 选项分析

A. 使用 AWS Control Tower 连接到 EC2 实例。

错误:AWS Control Tower 是用于[设置和管理多账户环境的服务](#)，不用于直接连接 EC2 实例。

错误:Control Tower 不支持会话日志记录或加密功能。

B. 使用 AWS Security Hub 连接到 EC2 实例。

错误:AWS Security Hub 是用于集中管理和监控安全警报的服务，不用于连接 EC2 实例。

错误:Security Hub 不支持会话日志记录或加密功能。

C. 使用 AWS Systems Manager Session Manager 连接到 EC2 实例。

正确:Session Manager 是专门设计用于安全连接 EC2 实例的服务，无需打开入站端口或管理 SSH 密钥。

错误:题目要求“上传会话日志”，而选项 C 提到的是“存储会话日志”，这与题目要求不完全匹配。

D. 使用 AWS Systems Manager Session Manager 连接到 EC2 实例。

正确:Session Manager 满足题目要求，无需打开入站端口或管理 SSH 密钥。

正确:支持将会话日志上传到加密的 CloudWatch Logs 日志组，符合题目要求。

▼ 32

▼ 英文:

A company uses an organization in AWS Organizations to help separate its Amazon EC2 instances and VPCs. The company has separate OUs for development workloads and production workloads.

A security engineer must ensure that only AWS accounts in the production OU can write VPC flow logs to an Amazon S3 bucket. The security engineer is configuring the S3 bucket policy with a Condition element to allow the s3:PutObject action for VPC flow logs.

How should the security engineer configure the Condition element to meet these requirements?

- A. Set the value of the aws:SourceOrgID condition key to be the organization ID.
- B. Set the value of the aws:SourceOrgPaths condition key to be the Organizations entity path of the production OU.
- C. Set the value of the aws:ResourceOrgID condition key to be the organization ID.
- D. Set the value of the aws:ResourceOrgPaths condition key to be the Organizations entity path of the production OU.

▼ 中文:

一家公司使用AWS Organizations中的组织来帮助分离其Amazon EC2实例和VPC。该公司为开发工作负载和生产工作负载分别设置了单独的OU。

一名安全工程师必须确保只有生产OU中的AWS账户可以将VPC流日志写入Amazon S3桶。安全工程师正在使用Condition元素配置S3桶策略，以允许VPC流日志执行s3:PutObject操作。

安全工程师应该如何配置Condition元素以满足这些要求？

- A.将aws:SourceOrgID条件键的值设置为组织ID。
- B.将aws:SourceOrgPaths条件键的值设置为生产OU的Organizations实体路径。
- C.将aws:ResourceOrgID条件键的值设置为组织ID。
- D.将aws:ResourceOrgPaths条件键的值设置为生产OU的Organizations实体路径。

▼ 答案:

B

1. 考察的知识点

本题考察的是AWS Organizations的条件键(Condition Keys)在IAM策略中的使用，特别是如何通过条件键限制资源访问权限。

重点关注aws:SourceOrgPaths和aws:SourceOrgID条件键的使用场景。

2. 选项分析

A. Set the value of the aws:SourceOrgID condition key to be the organization ID.

错误:aws:SourceOrgID条件键用于验证请求的来源是否属于指定的组织ID，但题目要求限制的是生产OU的账户，而不是整个组织的账户。

此条件键无法精确到特定的OU，因此不符合题目要求。

B. Set the value of the aws:SourceOrgPaths condition key to be the Organizations entity path of the production OU.

正确:aws:SourceOrgPaths条件键可以精确到特定的OU路径，允许我们限制只有生产OU的账户可以执行s3:PutObject操作。

此选项完全符合题目要求。

C. Set the value of the aws:ResourceOrgID condition key to be the organization ID.

错误:aws:ResourceOrgID条件键用于验证资源(如S3桶)是否属于指定的组织ID，而不是限制请求来源的账户。此条件键与题目要求无关。

D. Set the value of the aws:ResourceOrgPaths condition key to be the Organizations entity path of the production OU.

错误:aws:ResourceOrgPaths条件键用于验证资源路径，而不是请求来源的账户路径。

此条件键与题目要求无关。

▼ 33

▼ 英文:

Amazon CloudWatch Logs agent is successfully delivering logs to the CloudWatch Logs service. However, logs stop being delivered after the associated log stream has been active for a specific number of hours.

What steps are necessary to identify the cause of this phenomenon?
(Choose two.)

- A. Ensure that file permissions for monitored files that allow the CloudWatch Logs agent to read the file have not been modified.
- B. Verify that the OS Log rotation rules are compatible with the configuration requirements for agent streaming.
- C. Configure an Amazon Kinesis producer to first put the logs into Amazon Kinesis Streams.
- D. Create a CloudWatch Logs metric to isolate a value that changes at least once during the period before logging stops.
- E. Use AWS CloudFormation to dynamically create and maintain the configuration file for the CloudWatch Logs agent.

▼ 中文:

Amazon CloudWatch Logs agent 已成功将日志传送到 CloudWatch Logs 服务。然而，在关联的日志流活跃了特定小时数后，日志停止传送。确定导致此现象的原因需要采取哪些步骤?(选择两个。)

- A. 确保允许 CloudWatch Logs agent 读取文件的受监控文件的文件权限未被修改。
- B. 验证操作系统日志轮换规则是否与代理流配置要求兼容。
- C. 配置一个 Amazon Kinesis producer 以首先将日志放入 Amazon Kinesis Streams。
- D. 创建一个 CloudWatch Logs metric，以隔离在日志停止之前的时间段内至少发生一次变化的值。
- E. 使用 AWS CloudFormation 动态创建和维护 CloudWatch Logs agent 的配置文件。

▼ 答案:

AB

1. 考察的知识点

CloudWatch Logs agent的工作原理和日志流的配置要求。
操作系统日志轮换规则与CloudWatch Logs agent的兼容性。
文件权限对CloudWatch Logs agent读取日志的影响。

2. 选项分析

A.

正确:如果文件权限被修改，CloudWatch Logs agent可能无法读取日志文件，从而导致日志停止传输。

B.

正确:操作系统的日志轮换规则可能会导致日志文件被移动或重命名，CloudWatch Logs agent可能无法继续读取日志文件。

C.

错误:题目中没有提到需要使用Kinesis Streams，且此选项与问题无关。

D.

错误:创建CloudWatch Logs metric无法直接解决日志停止传输的问题。

E.

错误:使用CloudFormation动态创建配置文件与问题无关，且不会解决日志停止传输的问题。

▼ 34

▼ 英文:

A security engineer has designed a VPC to segment private traffic from public traffic. The VPC includes two Availability Zones. The security engineer has provisioned each Availability Zone with one private subnet and one public subnet. The security engineer has created three route tables for use with the environment. One route table is for the public subnets, and two route tables are for the private subnets (one route table for the private subnet in each Availability Zone).

The security engineer discovers that all four subnets are attempting to route traffic out through the internet gateway that is attached to the VPC.

Which combination of steps should the security engineer take to remediate this scenario? (Choose two.)

A. Verify that a NAT gateway has been provisioned in the public subnet in each Availability Zone.

B. Verify that a NAT gateway has been provisioned in the private subnet in each Availability Zone.

C. Modify the route tables that are associated with each of the public subnets. Create a new route for local destinations to the VPC CIDR range.

D. Modify the route tables that are associated with each of the private subnets. Create a new route for the destination 0.0.0.0/0. Specify the NAT gateway in the public subnet of the same Availability Zone as the target of the route.

E. Modify the route tables that are associated with each of the private subnets. Create a new route for the destination 0.0.0.0/0. Specify the internet gateway in the public subnet of the same Availability Zone as the target of the route.

▼ 中文:

一位安全工程师设计了一个VPC，用于将私有流量与公共流量进行分隔。该VPC包括两个可用区。安全工程师为每个可用区配置了一个私有子网和一个公共子网。安全工程师为该环境创建了三个路由表。一个路由表用于公共子网，两个路由表用于私有子网(每个可用区的私有子网使用一个路由表)。安全工程师发现所有四个子网都试图通过连接到VPC的互联网网关路由流量。安全工程师应该采取哪些步骤来解决此问题?(选择两个)

- A.验证是否在每个可用区的公共子网中配置了NAT网关。
- B.验证是否在每个可用区的私有子网中配置了NAT网关。
- C.修改与每个公共子网关联的路由表。为VPC CIDR范围的本地目标创建一个新的路由。
- D.修改与每个私有子网关联的路由表。为目标0.0.0.0/0创建一个新的路由。指定同一可用区公共子网中的NAT网关作为路由的目标。
- E.修改与每个私有子网关联的路由表。为目标0.0.0.0/0创建一个新的路由。指定同一可用区公共子网中的互联网网关作为路由的目标。

▼ 答案:

AD

1. 考察的知识点

VPC网络设计与子网划分

路由表配置与流量管理

NAT网关的使用与配置

互联网网关与私有子网的流量隔离

2. 选项分析

A.

正确:NAT网关通常部署在公共子网中，用于允许私有子网的流量访问互联网，同时保持私有子网的流量隔离。

这是解决问题的必要步骤之一。

B.

错误:NAT网关不能部署在私有子网中，因为它需要能够访问互联网网关，而

互联网网关通常只连接到公共子网。

C.

错误:公共子网的路由表通常已经包含到VPC CIDR范围的本地路由，修改此路由不会解决问题。

D.

正确:私有子网需要通过NAT网关访问互联网，因此需要在其路由表中添加到0.0.0.0/0的路由，并将目标设置为公共子网中的NAT网关。

这是解决问题的必要步骤之一。

E.

错误:私有子网不能直接通过互联网网关访问互联网，这会破坏私有子网的隔离性。

▼ 35

▼ 英文:

A company hired an external consultant who needs to use a laptop to access the company's VPCs. Specifically, the consultant needs access to two VPCs that are peered together in the same AWS Region. The company wants to provide the consultant with access to these VPCs without also providing any unnecessary access to other network resources.

Which solution will meet these requirements?

A. Create an AWS Site-to-Site VPN endpoint in the same Region as the VPCs. Configure access through an appropriate subnet and authorization rule.

B. Create an AWS account. Use the VPC sharing feature through AWS Resource Access Manager to allow the consultant to access the VPCs.

C. Create an AWS Client VPN endpoint in the same Region as the VPCs. Configure access through an appropriate subnet and authorization rule.

D. Create a gateway VPC endpoint in the same Region as the VPCs. Configure access through an appropriate subnet and authorization rule.

▼ 中文:

一家公司聘请了一位外部顾问，该顾问需要使用笔记本电脑访问公司的VPC。具体来说，顾问需要访问两个在同一AWS Region内已建立对等连接的VPC。公司希望为顾问提供对这些VPC的访问权限，同时避免提供对其他网络资源的不必要访问。

哪种解决方案可以满足这些要求？

- A. 在与VPC位于同一Region中创建一个AWS Site-to-Site VPN端点。通过适当的子网和授权规则配置访问权限。
- B. 创建一个AWS账户。通过AWS Resource Access Manager使用VPC共享功能允许顾问访问这些VPC。
- C. 在与VPC位于同一Region中创建一个AWS Client VPN端点。通过适当的子网和授权规则配置访问权限。
- D. 在与VPC位于同一Region中创建一个网关VPC端点。通过适当的子网和授权规则配置访问权限。

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS网络安全相关知识，尤其是如何安全地为外部用户提供对VPC的访问权限。

涉及的服务包括AWS Client VPN、Site-to-Site VPN、VPC共享功能、以及VPC端点。

2. 选项分析

A. Create an AWS Site-to-Site VPN endpoint in the same Region as the VPCs. Configure access through an appropriate subnet and authorization rule.

错误:AWS Site-to-Site VPN主要用于连接本地数据中心与AWS环境，而不是为个人用户(如顾问)提供访问。此选项不适合解决问题。

B. Create an AWS account. Use the VPC sharing feature through AWS Resource Access Manager to allow the consultant to access the VPCs.

错误:VPC共享功能是为了在同一组织内共享资源，而不是为外部用户(如顾问)提供访问权限。此选项不符合题目要求。

C. Create an AWS Client VPN endpoint in the same Region as the VPCs. Configure access through an appropriate subnet and authorization rule.

正确:AWS Client VPN是专门设计用于为个人用户提供安全的远程访问。它支持基于用户身份的授权规则，可以限制顾问仅访问特定的VPC资源。

D. Create a gateway VPC endpoint in the same Region as the VPCs. Configure access through an appropriate subnet and authorization rule.

错误:Gateway VPC Endpoint用于连接VPC与AWS服务(如S3或DynamoDB)，而不是为外部用户提供访问。此选项不适合解决问题。

▼ 36

▼ 英文:

A company uses AWS Organizations to manage a small number of AWS accounts. However, the company plans to add 1,000 more accounts soon. The company allows only a centralized security team to create IAM roles for all AWS accounts and teams. Application teams submit requests for IAM roles to the security team. The security team has a backlog of IAM role requests and cannot review and provision the IAM roles quickly.

The security team must create a process that will allow application teams to provision their own IAM roles. The process must also limit the scope of IAM roles and prevent privilege escalation.

Which solution will meet these requirements with the LEAST operational overhead?

A. Create an IAM group for each application team. Associate policies with each IAM group. Provision IAM users for each application team member. Add the new IAM users to the appropriate IAM group by using role-based access control (RBAC).

B. Delegate application team leads to provision IAM roles for each team. Conduct a quarterly review of the IAM roles the team leads have provisioned. Ensure that the application team leads have the appropriate training to review IAM roles.

C. Put each AWS account in its own OU. Add an SCP to each OU to grant access to only the AWS services that the teams plan to use. Include conditions in the AWS account of each team.

D. Create an SCP and a permissions boundary for IAM roles. Add the SCP to the root OU so that only roles that have the permissions boundary attached can create any new IAM roles.

▼ 中文:

一家公司使用 AWS Organizations 来管理少量的 AWS 账户。然而，该公司计划很快新增 1,000 个账户。公司仅允许一个集中化的安全团队为所有 AWS 账户和团队创建 IAM 角色。应用团队向安全团队提交 IAM 角色请求。安全团队积压了大量 IAM 角色请求，无法快速审核和创建 IAM 角色。

安全团队必须创建一个流程，以允许应用团队自行创建 IAM 角色。该流程还必须限制 IAM 角色的范围并防止权限升级。哪种解决方案能够以最少的运营开销满足这些要求？

A. 为每个应用团队创建一个 IAM 组。将策略与每个 IAM 组关联。为每个应用团队成员创建 IAM 用户。通过基于角色的访问控制 (RBAC) 将新的 IAM 用户添加到适当的 IAM 组中。

B. 授权应用团队负责人为每个团队创建 IAM 角色。每季度审查团队负责人创建的 IAM 角色。确保应用团队负责人接受适当的培训以审查 IAM 角色。

C. 将每个 AWS 账户放入其自己的 OU 中。向每个 OU 添加一个 SCP，以仅授予团队计划使用的 AWS 服务的访问权限。在每个团队的 AWS 账户中包含条件。

D. 为 IAM 角色创建一个 SCP 和权限边界。将 SCP 添加到根 OU，以便只有附加了权限边界的角色才能创建任何新的 IAM 角色。

▼ 答案:

D

1. 考察的知识点

AWS Organizations 的使用，包括服务控制策略 (SCP) 的应用。

IAM 权限边界的概念及其限制权限的功能。

如何设计安全的权限管理流程以防止权限升级 (Privilege Escalation)。

如何减少操作开销，同时满足安全需求。

2. 选项分析

A. 创建 IAM 组并使用 RBAC:

错误: 虽然 RBAC 是一种权限管理方法，但它需要手动管理 IAM 用户和组，操作开销较高。

错误: 无法有效限制 IAM 角色的权限范围，也无法防止权限升级。

B. 授权团队负责人创建 IAM 角色:

错误: 虽然可以分散权限管理，但依赖团队负责人进行角色审查可能导致不一致的安全标准。

错误: 季度审查无法实时防止权限升级，且操作开销较高。

C. 使用 OU 和 SCP 限制服务访问:

错误:SCP可以限制服务访问，但无法直接限制IAM角色的权限范围或防止权限升级。

错误:将每个账户放入单独的OU会增加管理复杂性，操作开销较高。

D. 使用 SCP 和权限边界:

正确:SCP可以限制哪些角色可以创建IAM角色，从而防止权限升级。

正确:权限边界可以限制IAM角色的权限范围，确保安全性。

正确:将SCP应用于根OU可以统一管理，减少操作开销。

▼ 37

▼ 英文:

A developer is receiving AccessDenied errors when the developer invokes API calls to AWS services from a workstation. The developer previously configured environment variables and configuration files on the workstation to use multiple roles with other AWS accounts.

A security engineer needs to help the developer configure authentication. The current credentials must be evaluated without conflicting with other credentials that were previously configured on the workstation.

Where these credentials should be configured to meet this requirement?

- A. In the local AWS CLI configuration file
- B. As environment variables on the local workstation
- C. As variables in the AWS CLI command line options Most Voted
- D. In the AWS shared configuration file

▼ 中文:

开发人员在从工作站调用 AWS 服务的 API 时收到 AccessDenied 错误。开发人员之前在工作站上配置了环境变量和配置文件，以使用其他 AWS 账户的多个角色。安全工程师需要帮助开发人员配置身份验证。当前的凭证必须进行评估，并且不能与之前在工作站上配置的其他凭证发生冲突。这些凭证应该配置在哪里以满足此要求？

- A. 在本地 AWS CLI 配置文件中

- B. 作为本地工作站上的环境变量
- C. 作为 AWS CLI 命令行选项中的变量
- D. 在 AWS 共享配置文件中

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS CLI的身份验证机制，以及如何正确配置和使用多账户或多角色的凭证。

重点在于理解AWS CLI的优先级顺序:命令行选项 > 环境变量 > 配置文件。

2. 选项分析

A. In the local AWS CLI configuration file (在本地 AWS CLI 配置文件中)

错误。虽然AWS CLI配置文件可以存储凭证，但它的优先级低于命令行选项和环境变量。如果开发者需要避免与其他凭证冲突，使用配置文件可能无法满足要求。

B. As environment variables on the local workstation (作为本地工作站上的环境变量)

错误。环境变量的优先级高于配置文件，但仍低于命令行选项。如果开发者已经配置了其他环境变量，可能会导致冲突。

C. As variables in the AWS CLI command line options (作为 AWS CLI 命令行选项中的变量)

正确。命令行选项的优先级最高，可以覆盖环境变量和配置文件中的设置。这种方式可以确保当前凭证不会与其他凭证冲突。

D. In the AWS shared configuration file (在 AWS 共享配置文件中)

错误。共享配置文件的优先级与本地配置文件相同，低于环境变量和命令行选项。无法满足避免冲突的要求。

▼ 38

▼ 英文:

A medical company recently completed an acquisition and inherited an existing AWS environment. The company has an upcoming audit and is concerned about the compliance posture of its acquisition.

The company must identify personal health information inside Amazon S3 buckets and must identify S3 buckets that are publicly accessible.

The company needs to prepare for the audit by collecting evidence in

the environment.

Which combination of steps will meet these requirements with the LEAST operational overhead? (Choose three.)

- A. Enable Amazon Macie. Run an on-demand sensitive data discovery job that uses the PERSONAL_INFORMATION managed data identifier.
- B. Use AWS Glue with the Detect PII transform to identify sensitive data and to mask the sensitive data.
- C. Enable AWS Audit Manager. Create an assessment by using a supported framework.
- D. Enable Amazon GuardDuty S3 Protection. Document any findings that are related to suspicious access of S3 buckets.
- E. Enable AWS Security Hub. Use the AWS Foundational Security Best Practices standard. Review the controls dashboard for evidence of failed S3 Block Public Access controls.
- F. Enable AWS Config. Set up the s3-bucket-public-write-prohibited AWS Config managed rule.

▼ 中文:

一家医疗公司最近完成了一项收购，并继承了现有的AWS环境。该公司即将进行审计，并担心其收购的合规状况。

该公司必须识别Amazon S3桶中的个人健康信息，并必须识别公开访问的S3桶。公司需要通过收集环境中的证据来为审计做准备。

哪些步骤组合可以以最少的操作开销满足这些要求?(选择三项)

- A. 启用Amazon Macie。运行一个按需敏感数据发现任务，该任务使用PERSONAL_INFORMATION托管数据标识符。
- B. 使用AWS Glue与Detect PII转换来识别敏感数据并屏蔽敏感数据。
- C. 启用AWS Audit Manager。使用支持的框架创建评估。
- D. 启用Amazon GuardDuty S3 Protection。记录任何与S3桶可疑访问相关的发现。
- E. 启用AWS Security Hub。使用AWS Foundational Security Best Practices标准。查看控制面板以获取S3 Block Public Access控制失败的证据。

F. 启用AWS Config。设置s3-bucket-public-write-prohibited AWS Config托管规则。

▼ 答案:

ACE

1. 考察的知识点

Amazon Macie的功能:敏感数据发现和分类。

AWS Audit Manager的功能:支持合规性评估和审计准备。

AWS Security Hub的功能:集中管理安全状态和合规性检查。

如何识别和保护S3桶中的敏感数据。

如何检测S3桶的公共访问权限。

2. 选项分析

A. Enable Amazon Macie. Run an on-demand sensitive data discovery job that uses the PERSONAL_INFORMATION managed data identifier.

正确:Amazon Macie是专门设计用于发现和分类敏感数据的服务。使用PERSONAL_INFORMATION托管数据标识符可以有效识别个人健康信息(PHI)。

B. Use AWS Glue with the Detect PII transform to identify sensitive data and to mask the sensitive data.

错误:虽然AWS Glue可以用于数据处理，但它需要复杂的配置和开发工作，增加了操作开销，不符合“LEAST operational overhead”的要求。

C. Enable AWS Audit Manager. Create an assessment by using a supported framework.

正确:AWS Audit Manager可以帮助公司准备审计所需的证据，并支持合规性评估，适合审计准备工作。

D. Enable Amazon GuardDuty S3 Protection. Document any findings that are related to suspicious access of S3 buckets.

错误:Amazon GuardDuty主要用于检测恶意活动和异常行为，而不是直接用于发现敏感数据或检查公共访问权限。

E. Enable AWS Security Hub. Use the AWS Foundational Security Best Practices standard. Review the controls dashboard for evidence of failed S3 Block Public Access controls.

正确:AWS Security Hub可以集中管理安全状态，并提供关于S3桶公共访问控制失败的证据，符合审计准备需求。

F. Enable AWS Config. Set up the s3-bucket-public-write-prohibited AWS Config managed rule.

错误:虽然AWS Config可以监控S3桶的公共写入权限，但它需要额外的配置和管理工作，增加了操作开销。

▼ 39

▼ 英文:

A company finds that one of its Amazon EC2 instances suddenly has a high CPU usage. The company does not know whether the EC2 instance is compromised or whether the operating system is performing background cleanup.

Which combination of steps should a security engineer take before investigating the issue? (Choose three.)

- A. Disable termination protection for the EC2 instance if termination protection has not been disabled.
- B. Enable termination protection for the EC2 instance if termination protection has not been enabled. Most Voted
- C. Take snapshots of the Amazon Elastic Block Store (Amazon EBS) data volumes that are attached to the EC2 instance.
- D. Remove all snapshots of the Amazon Elastic Block Store (Amazon EBS) data volumes that are attached to the EC2 instance.
- E. Capture the EC2 instance metadata, and then tag the EC2 instance as under quarantine.
- F. Immediately remove any entries in the EC2 instance metadata that contain sensitive information.

▼ 中文:

一家公司发现其一台 Amazon EC2 实例突然出现高 CPU 使用率。该公司不确定该 EC2 实例是否被入侵，或者操作系统是否正在执行后台清理。安全工程师在调查问题之前应该采取哪些步骤的组合?(选择三项)

- A. 如果尚未禁用终止保护，则禁用 EC2 实例的终止保护。
- B. 如果尚未启用终止保护，则启用 EC2 实例的终止保护。
- C. 对附加到 EC2 实例的 Amazon Elastic Block Store (Amazon EBS) 数据卷进行快照。

D. 删除附加到 EC2 实例的 Amazon Elastic Block Store (Amazon EBS) 数据卷的所有快照。

E. 捕获 EC2 实例的元数据，然后将 EC2 实例标记为隔离状态。

F. 立即删除 EC2 实例元数据中包含敏感信息的任何条目。

▼ 答案:

BCE

1. 考察的知识点

EC2实例的安全性管理，包括终止保护的使用。

Amazon EBS数据卷的快照备份和数据保护。

实例元数据的捕获与隔离操作。

2. 选项分析

A. Disable termination protection for the EC2 instance if termination protection has not been disabled.

错误:禁用终止保护会使实例更容易被意外删除或恶意删除，这与保护实例的目标相悖。

B. Enable termination protection for the EC2 instance if termination protection has not been enabled.

正确:启用终止保护可以防止实例被意外或恶意终止，是保护实例的关键步骤。

C. Take snapshots of the Amazon Elastic Block Store (Amazon EBS) data volumes that are attached to the EC2 instance.

正确:创建EBS数据卷的快照可以保存当前数据状态，便于后续分析和恢复。

D. Remove all snapshots of the Amazon Elastic Block Store (Amazon EBS) data volumes that are attached to the EC2 instance.

错误:删除快照会导致数据丢失，无法进行后续调查和恢复。

E. Capture the EC2 instance metadata, and then tag the EC2 instance as under quarantine.

正确:捕获实例元数据可以帮助记录当前状态，标记为隔离状态可以防止进一步的潜在威胁扩散。

F. Immediately remove any entries in the EC2 instance metadata that contain sensitive information.

错误:删除元数据中的敏感信息可能会导致丢失重要的调查线索。

▼ 40

▼ 英文:

A company is implementing a customized notification solution to detect repeated unauthorized authentication attempts to bastion hosts. The company's security engineer needs to implement a solution that will provide notification when 5 failed attempts occur within a 5-minute period. The solution must use native AWS services and must notify only the designated system administrator who is assigned to the specific bastion host.

Which solution will meet these requirements?

A. Use the Amazon CloudWatch agent to collect operating system logs. Use Amazon EventBridge to configure an alarm based on a metric filter for failed login attempts. Send an alert to Amazon Simple Notification Service (Amazon SNS) when

the defined threshold for the alarm is exceeded. Use Amazon EC2 instance tags to determine which SNS topics receive notifications.

B. Use AWS Systems Manager Agent to collect operating system logs. Use the Systems Manager Run Command AWS- ConfigureCloudWatch document to configure an Amazon EventBridge event based on a metric filter for failed login attempts. Send an alert to Amazon Simple Notification Service (Amazon SNS) when the defined threshold for the alarm is exceeded. Use SNS messaging filters to control who receives notifications.

C. Use the Amazon CloudWatch agent to collect operating system logs. Create a CloudWatch alarm based on a metric filter for failed login attempts. Send an alert to Amazon Simple Notification Service (Amazon SNS) when the defined threshold for the alarm is exceeded. Use SNS messaging filters to control who receives notifications.

D. Use AWS Systems Manager Agent to collect operating system logs. Use the Systems Manager Run Command AWS- ConfigureCloudWatch document to configure an Amazon CloudWatch alarm based on a metric filter for failed login attempts. Send an alert to Amazon Simple Notification Service (Amazon SNS) when the defined threshold for the alarm is exceeded. Use EC2 instance tags to determine which SNS topics receive notifications.

▼ 中文:

一家公司正在实施一个定制的通知解决方案，用于检测对堡垒主机的重复未经授权的身份验证尝试。公司的安全工程师需要实施一个解决方案，**当在5分钟**

内发生5次失败尝试时提供通知。该解决方案必须使用原生AWS服务，并且只能通知分配给特定堡垒主机的指定系统管理员。

哪个解决方案可以满足这些要求？

A.使用Amazon CloudWatch agent收集操作系统日志。使用Amazon EventBridge基于失败登录尝试的指标过滤器配置一个告警。当告警定义的阈值被超过时，向Amazon Simple Notification Service (Amazon SNS)发送警报。使用Amazon EC2实例标签确定哪些SNS主题接收通知。

B.使用AWS Systems Manager Agent收集操作系统日志。使用Systems Manager Run Command AWS-ConfigureCloudWatch 文档基于失败登录尝试的指标过滤器配置一个Amazon EventBridge事件。当告警定义的阈值被超过时，向Amazon Simple Notification Service (Amazon SNS)发送警报。使用SNS消息过滤器控制谁接收通知。

C.使用Amazon CloudWatch agent收集操作系统日志。基于失败登录尝试的指标过滤器创建一个CloudWatch告警。当告警定义的阈值被超过时，向Amazon Simple Notification Service (Amazon SNS)发送警报。使用SNS消息过滤器控制谁接收通知。

D.使用AWS Systems Manager Agent收集操作系统日志。使用Systems Manager Run Command AWS-ConfigureCloudWatch 文档基于失败登录尝试的指标过滤器配置一个Amazon CloudWatch告警。当告警定义的阈值被超过时，向Amazon Simple Notification Service (Amazon SNS)发送警报。使用EC2实例标签确定哪些SNS主题接收通知。

▼ 答案:

C

1. 考察的知识点

Amazon CloudWatch的日志收集与告警功能。

Amazon SNS的通知机制及消息过滤功能。

如何使用AWS原生服务实现定制化的安全监控解决方案。

2. 选项分析

A. 使用Amazon CloudWatch agent收集操作系统日志，EventBridge配置告警，EC2标签控制SNS通知。

正确点:使用CloudWatch agent收集操作系统日志是合理的选择。

错误点:EventBridge通常用于事件驱动的架构，而不是直接用于基于日志的告警配置。这里应该使用CloudWatch Alarm而不是EventBridge。

错误点:EC2标签控制SNS通知的方式不符合题目要求，SNS消息过滤更适合控制通知接收者。

结论:错误。

B. 使用AWS Systems Manager Agent收集操作系统日志，EventBridge配置事件，SNS消息过滤控制通知。

正确点:使用Systems Manager Agent收集操作系统日志是可行的。

错误点:EventBridge配置事件不适合基于日志的告警需求，应该使用CloudWatch Alarm。

正确点:SNS消息过滤可以控制通知接收者。

结论:错误。

C. 使用Amazon CloudWatch agent收集操作系统日志，CloudWatch告警基于指标过滤器，SNS消息过滤控制通知。

正确点:CloudWatch agent是收集操作系统日志的最佳实践。

正确点:CloudWatch告警基于指标过滤器可以实现对失败登录尝试的监控。

正确点:SNS消息过滤可以精确控制通知接收者，符合题目要求。

结论:正确。

D. 使用AWS Systems Manager Agent收集操作系统日志，CloudWatch告警基于指标过滤器，EC2标签控制SNS通知。

正确点:使用Systems Manager Agent收集操作系统日志是可行的。

正确点:CloudWatch告警基于指标过滤器可以实现对失败登录尝试的监控。

错误点:EC2标签控制SNS通知的方式不符合题目要求，SNS消息过滤更适合控制通知接收者。

结论:错误。

▼ 41

▼ 英文:

An ecommerce website was down for 1 hour following a DDoS attack. Users were unable to connect to the website during the attack period. The ecommerce company's security team is worried about future potential attacks and wants to prepare for such events. The company needs to minimize downtime in its response to similar attacks in the future.

Which steps would help achieve this? (Choose two.)

A. Enable Amazon GuardDuty to automatically monitor for malicious activity and block unauthorized access.

B. Subscribe to AWS Shield Advanced and reach out to AWS Support in the event of an attack.

C. Use VPC Flow Logs to monitor network traffic and an AWS Lambda function to automatically block an attacker's IP using security groups.

D. Set up an Amazon EventBridge rule to monitor the AWS CloudTrail events in real time, use AWS Config rules to audit the configuration, and use AWS Systems Manager for remediation.

E. Use AWS WAF to create rules to respond to such attacks.

▼ 中文:

一个电子商务网站因DDoS攻击宕机1小时。在攻击期间，用户无法连接到该网站。电子商务公司的安全团队对未来潜在攻击感到担忧，并希望为此类事件做好准备。公司需要在未来类似攻击的响应中最大限度地减少停机时间。哪些步骤可以帮助实现这一目标？（选择两个。）

A.用Amazon GuardDuty以自动监控恶意活动并阻止未经授权的访问。

B.订阅AWS Shield Advanced并在发生攻击时联系AWS Support。

C.使用VPC Flow Logs监控网络流量，并使用AWS Lambda函数通过安全组自动阻止攻击者的IP。

D.设置Amazon EventBridge规则以实时监控AWS CloudTrail事件，使用AWS Config规则审计配置，并使用AWS Systems Manager进行修复。

E.使用AWS WAF创建规则以应对此类攻击。

▼ 答案:

BE

1. 考察的知识点

本题主要考察AWS在应对DDoS攻击时的防护措施，包括AWS Shield Advanced、AWS WAF，以及如何快速响应和减少停机时间。

2. 选项分析

A. Enable Amazon GuardDuty to automatically monitor for malicious activity and block unauthorized access.

Amazon GuardDuty是一个威胁检测服务，可以监控恶意活动，但它并不能直接阻止攻击或减少停机时间。

此选项错误，因为GuardDuty的功能是检测，而不是直接防御DDoS攻击。

B. Subscribe to AWS Shield Advanced and reach out to AWS Support in the event of an attack.

AWS Shield Advanced是专门设计用于防御复杂DDoS攻击的服务，提供实时保护和支持。

订阅AWS Shield Advanced后，用户可以获得AWS DDoS响应团队（DRT）的支持，帮助快速响应攻击并减少停机时间。

此选项正确，因为它直接针对DDoS攻击并提供专业支持。

C. Use VPC Flow Logs to monitor network traffic and an AWS Lambda function to automatically block an attacker's IP using security groups.

VPC Flow Logs可以监控网络流量，但它主要用于分析和审计，而不是实时防御DDoS攻击。

使用Lambda函数和安全组阻止IP地址可能对小规模攻击有效，但对于大规模DDoS攻击，这种方法效率较低且无法快速响应。

此选项错误，因为它无法有效减少停机时间或防御大规模攻击。

D. Set up an Amazon EventBridge rule to monitor the AWS CloudTrail events in real time, use AWS Config rules to audit the configuration, and use AWS Systems Manager for remediation.

此选项涉及事件监控、配置审计和修复，但这些功能主要用于合规性和资源管理，而不是直接防御DDoS攻击。

此选项错误，因为它与DDoS攻击的防御无关。

E. Use AWS WAF to create rules to respond to such attacks.

AWS WAF是一种Web应用程序防火墙，可以创建规则来过滤恶意流量，从而有效防御DDoS攻击。

此选项正确，因为它可以帮助减少攻击对网站的影响并减少停机时间。

▼ 42

▼ 英文:

An AWS account includes two S3 buckets: bucket1 and bucket2. The bucket2 does not have a policy defined, but bucket1 has the following bucket policy:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": { "AWS": "arn:aws:iam::123456789012:user/alice" },
      "Action": "s3:*",
      "Resource": ["arn:aws:s3:::bucket1", "arn:aws:s3:::bucket1/*"]
    }
  ]
}
```

In addition, the same account has an IAM User named "alice", with the following IAM policy.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": "s3:*",
    "Resource": ["arn:aws:s3:::bucket2", "arn:aws:s3:::bucket2/*"]
  }]
}
```

Which buckets can user "alice" access?

- A. bucket1 only
- B. bucket2 only
- C. Both bucket1 and bucket2
- D. Neither bucket1 nor bucket2

▼ 中文:

一个 AWS 账户包含两个 S3 存储桶：bucket1 和 bucket2。bucket2 没有定义策略，但 bucket1 有以下存储桶策略：

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": { "AWS": "arn:aws:iam::123456789012:user/alice" },
      "Action": "s3:*",
      "Resource": ["arn:aws:s3:::bucket1", "arn:aws:s3:::bucket1/*"]
    }
  ]
}
```

此外，同一账户有一个名为 "alice" 的 IAM 用户，具有以下 IAM 策略。

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": "s3:*",
    "Resource": ["arn:aws:s3:::bucket2", "arn:aws:s3:::bucket2/*"]
  }]
}
```

用户 "alice" 可以访问哪些存储桶？

- A. bucket1 only
- B. bucket2 only
- C. Both bucket1 and bucket2
- D. Neither bucket1 nor bucket2

▼ 答案:

C

1. 考察的知识点

IAM用户权限与S3存储桶策略的交互。

理解S3存储桶策略和IAM用户策略如何共同决定访问权限。

权限的合并原则：用户的最终权限是存储桶策略和IAM策略的联合结果。

2. 选项分析

A. bucket1 only

错误。虽然bucket1的存储桶策略允许用户“alice”访问bucket1，但IAM用户策略并未限制“alice”对bucket2的访问。因此，

“alice”可以同时访问bucket1和bucket2。

B. bucket2 only

错误。IAM用户策略允许“alice”访问bucket2，但bucket1的存储桶策略也明确允许“alice”访问bucket1。因此，“alice”可以同时访问bucket1和bucket2。

C. Both bucket1 and bucket2

正确。根据权限合并原则，存储桶策略和IAM用户策略共同决定用户的最终权限。“alice”被bucket1的存储桶策略允许访问bucket1，同时IAM用户策略允许访问bucket2。因此，“alice”可以访问两个存储桶。

D. Neither bucket1 nor bucket2

错误。存储桶策略和IAM用户策略都明确授予“alice”访问权限，因此“alice”可以访问两个存储桶。

▼ 43

▼ 英文:

A company plans to create Amazon S3 buckets to store log data. All the S3 buckets will have versioning enabled and will use the S3 Standard storage class.

A security engineer needs to implement a solution that protects objects in the S3 buckets from deletion for 90 days. The solution must ensure that no object can be deleted during this time period, even by an administrator or the AWS account root user.

Which solution will meet these requirements?

A. Enable S3 Object Lock in governance mode. Set a legal hold of 90 days.

- B. Enable S3 Object Lock in governance mode. Set a retention period of 90 days.
- C. Enable S3 Object Lock in compliance mode. Set a retention period of 90 days. Most Voted
- D. Create an S3 Glacier Vault Lock policy that prevents deletion for 90 days.

▼ 中文:

一家公司计划创建 Amazon S3 存储桶来存储日志数据。所有 S3 存储桶都将启用版本控制，并使用 S3 Standard 存储类别。

一名安全工程师需要实施一个解决方案，以保护 S3 存储桶中的对象在 90 天内不被删除。该解决方案必须确保在此期间，即使是管理员或 AWS 账户根用户也无法删除任何对象。

哪种解决方案可以满足这些要求？

- A. 在治理模式下启用 S3 Object Lock。设置 90 天的法律保留。
- B. 在治理模式下启用 S3 Object Lock。设置 90 天的保留期。
- C. 在合规模式下启用 S3 Object Lock。设置 90 天的保留期。
- D. 创建一个 S3 Glacier Vault Lock 策略，防止删除 90 天。

▼ 答案:

C

1. 考察的知识点 Amazon S3 Object Lock 功能，包括治理模式和合规模式的区别。

如何设置保留期以防止对象被删除。

理解 S3 Glacier Vault Lock 的用途和适用场景。

2. 选项分析

A. Enable S3 Object Lock in governance mode. Set a legal hold of 90 days.

治理模式允许特定用户（如管理员）绕过锁定并删除对象，因此不符合题目要求“确保即使管理员或根用户也无法删除”。

法律保留（Legal Hold）是一个独立的功能，与保留期不同，无法直接满足 90 天的不可删除要求。

此选项错误。

B. Enable S3 Object Lock in governance mode. Set a retention period of 90 days.

治理模式允许管理员绕过锁定并删除对象，因此不符合题目要求“确保即使管理员或根用户也无法删除”。

虽然设置了保留期，但治理模式的限制使得此选项不符合要求。

此选项错误。

C. Enable S3 Object Lock in compliance mode. Set a retention period of 90 days.

合规模式确保对象在保留期内无法被删除，即使是管理员或根用户也无法绕过锁定。

设置保留期为90天完全符合题目要求。

此选项正确。

D. Create an S3 Glacier Vault Lock policy that prevents deletion for 90 days.

S3 Glacier Vault Lock适用于归档数据，而题目明确提到使用S3 Standard存储类，因此此选项不适用。

此选项错误。

▼ 44

▼ 英文:

A company has used AWS Lambda functions to build an application on AWS. The company's security engineer implemented Amazon Inspector and activated Lambda standard scanning and Lambda code scanning.

The security engineer reviews the Amazon Inspector console and learns that Amazon Inspector is not scanning some of the Lambda functions. The provided reason is that the scan eligibility expired.

What should the security engineer do to investigate the reason that the scans are failing?

A. Validate that the AmazonInspector2ServiceRolePolicy AWS managed policy grants permissions to access Lambda.

B. Increase the timeout value of the Lambda functions to complete the scans successfully while the code is running.

C. Build a custom runtime for the unscanned Lambda functions. Include the Amazon Inspector agent in the runtime.

D. Determine whether the unscanned Lambda functions have been invoked in the last 90 days.

▼ 中文:

一家公司使用 AWS Lambda 函数在 AWS 上构建了一个应用程序。公司的安全工程师实施了 Amazon Inspector，并启用了 Lambda 标准扫描和

Lambda 代码扫描。

安全工程师查看了 Amazon Inspector 控制台，并了解到 Amazon Inspector 未扫描某些 Lambda 函数。提供的原因是扫描资格已过期。

安全工程师应该怎么做来调查扫描失败的原因？

- A. 验证 AmazonInspector2ServiceRolePolicy AWS 托管策略是否授予访问 Lambda 的权限。
- B. 增加 Lambda 函数的超时时间值，以便在代码运行时成功完成扫描。
- C. 为未扫描的 Lambda 函数构建一个自定义运行时。在运行时中包含 Amazon Inspector 代理。
- D. 确定未扫描的 Lambda 函数是否在过去 90 天内被调用过。

▼ 答案:

D

1. 考察的知识点

Amazon Inspector的功能和限制，特别是针对AWS Lambda函数的扫描机制。

Lambda函数的扫描条件，包括调用频率和扫描有效期。

IAM权限与Amazon Inspector的交互。

2. 选项分析

A. Validate that the AmazonInspector2ServiceRolePolicy AWS managed policy grants permissions to access Lambda.

错误：Amazon Inspector的扫描失败并不是因为权限问题，而是因为扫描有效期已过。此选项与问题无关。

B. Increase the timeout value of the Lambda functions to complete the scans successfully while the code is running.

错误：Lambda函数的超时时间与Amazon Inspector的扫描机制无关。Amazon Inspector扫描的是代码和配置，而不是运行时行为。

C. Build a custom runtime for the unscanned Lambda functions. Include the Amazon Inspector agent in the runtime.

错误：Amazon Inspector不需要在Lambda函数中嵌入代理。它是通过集成的方式扫描代码和配置，而不是依赖自定义运行时。

D. Determine whether the unscanned Lambda functions have been invoked in the last 90 days.

正确：Amazon Inspector的Lambda扫描机制要求函数在过去90天内至少被调用过。如果函数未被调用，扫描资格会过期。

▼ 45

▼ 英文:

A security engineer received an Amazon GuardDuty alert indicating a finding involving the Amazon EC2 instance that hosts the company's primary website. The GuardDuty finding received read: UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.

The security engineer confirmed that a malicious actor used API access keys intended for the EC2 instance from a country where the company does not operate. The security engineer needs to deny access to the malicious actor.

What is the first step the security engineer should take?

- A. Open the EC2 console and remove any security groups that allow inbound traffic from 0.0.0.0/0.
- B. Install the AWS Systems Manager Agent on the EC2 instance and run an inventory report.
- C. Install the Amazon Inspector agent on the host and run an assessment with the CVE rules package.
- D. Open the IAM console and revoke all IAM sessions that are associated with the instance profile.

▼ 中文:

一位安全工程师收到了一条来自 Amazon GuardDuty 的警报，指示涉及托管公司主网站的 Amazon EC2 实例的发现。收到的 GuardDuty 发现内容如下：

UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.

安全工程师确认恶意行为者从公司未运营的国家使用了专用于 EC2 实例的 API 访问密钥。安全工程师需要拒绝恶意行为者的访问。

安全工程师应该采取的第一步是什么？

- A. 打开 EC2 控制台并移除允许来自 0.0.0.0/0 的入站流量的任何安全组。
- B. 在 EC2 实例上安装 AWS Systems Manager Agent 并运行库存报告。
- C. 在主机上安装 Amazon Inspector agent 并使用 CVE 规则包运行评估。
- D. 打开 IAM 控制台并撤销与实例配置文件关联的所有 IAM 会话。

▼ 答案:

D

1. 考察的知识点

Amazon GuardDuty的功能和警报类型。

如何处理IAM用户凭证泄露的安全事件。

如何快速阻止恶意访问并保护AWS资源。

2. 选项分析

A. 打开 EC2 控制台并移除允许来自 0.0.0.0/0 的入站流量的任何安全组。

错误：虽然限制安全组的入站流量是一个安全措施，但此操作无法直接解决凭证泄露问题。

GuardDuty的警报表明IAM凭证被恶意使用，而不是安全组配置问题。

B. 在 EC2 实例上安装 AWS Systems Manager Agent 并运行库存报告。

错误：安装Systems Manager Agent和运行库存报告是用于资源管理和审计的操作，与当前的凭证泄露问题无关。

此操作无法阻止恶意访问。

C. 在主机上安装 Amazon Inspector agent 并使用 CVE 规则包运行评估。

错误：Amazon Inspector用于检测漏洞和评估实例的安全性，但无法解决IAM凭证泄露问题。

此操作无法立即阻止恶意访问。

D. 打开 IAM 控制台并撤销与实例配置文件关联的所有 IAM 会话。

正确：此操作直接针对凭证泄露问题，能够立即阻止恶意用户使用泄露的API访问密钥。

撤销IAM会话是处理凭证泄露的第一步，确保恶意用户无法继续访问AWS资源。

▼ 46

▼ 英文:

A company is testing incident response procedures for destination containment. The company needs to contain a critical Amazon EC2 instance as quickly as possible while keeping the EC2 instance running. The EC2 instance is the only resource in a public subnet and has active connections to other resources. Which solution will contain the EC2 instance IMMEDIATELY?

A. Create a new security group that has no inbound rules or outbound rules. Attach the new security group to the EC2

instance.

B. Configure the existing security group for the EC2 instance. Remove all existing inbound rules and outbound rules from the security group.

C. Create a new network ACL that has a single Deny rule for inbound traffic and outbound traffic. Associate the new network ACL with the subnet that contains the EC2 instance.

D. Create a new VPC for isolation. Stop the EC2 instance. Create a new AMI from the EC2 instance. Use the new AMI to launch a new EC2 instance in the new VPC.

▼ 中文:

一家公司正在测试针对目标隔离的事件响应程序。该公司需要尽快隔离一个关键的 Amazon EC2 实例，同时保持该 EC2 实例运行。该 EC2 实例是公共子网中的唯一资源，并且与其他资源有活动连接。

哪种解决方案可以立即隔离该 EC2 实例？

A. 创建一个没有入站规则或出站规则的新安全组。将新的安全组附加到该 EC2 实例。

B. 配置该 EC2 实例的现有安全组。从安全组中移除所有现有的入站规则和出站规则。

C. 创建一个新的网络 ACL，其中包含一个针对入站流量和出站流量的单一拒绝规则。将新的网络 ACL 关联到包含该 EC2 实例的子网。

D. 创建一个用于隔离的新 VPC。停止该 EC2 实例。从该 EC2 实例创建一个新的 AMI。使用新的 AMI 在新的 VPC 中启动一个新的 EC2 实例。

▼ 答案:

C

1. 考察的知识点

本题考察的是 AWS 安全性相关的知识，特别是如何快速隔离和控制网络流量以应对安全事件。

涉及的服务包括：Amazon EC2、Security Groups、Network ACLs、VPC。

2. 选项分析

A. Create a new security group that has no inbound rules or outbound rules. Attach the new security group to the EC2

instance.

正确性分析：创建一个没有规则的安全组并附加到EC2实例确实可以阻止流量，但安全组的更改可能需要时间传播，

无法保证“立即”生效。

结论：此选项不符合“立即”隔离的要求。

B. Configure the existing security group for the EC2 instance.

Remove all existing inbound rules and outbound rules from the security group.

正确性分析：修改现有安全组的规则也可以阻止流量，但与选项A类似，安全组的更改可能需要时间传播，无法保

证“立即”生效。

结论：此选项不符合“立即”隔离的要求。

C. Create a new network ACL that has a single Deny rule for inbound traffic and outbound traffic. Associate the new network ACL with the subnet that contains the EC2 instance.

正确性分析：网络ACL是子网级别的控制机制，规则更改会立即生效。通过创建一个新的网络ACL并关联到子网，可以立即阻止所有流量。

结论：此选项符合“立即”隔离的要求，是正确答案。

D. Create a new VPC for isolation. Stop the EC2 instance. Create a new AMI from the EC2 instance. Use the new AMI to launch a new EC2 instance in the new VPC.

正确性分析：此选项涉及停止实例、创建AMI和启动新实例，整个过程需要较长时间，无法满足“立即”隔离的要求。

结论：此选项不符合“立即”隔离的要求。

▼ 47

▼ 英文:

A company needs to use HTTPS when connecting to its web applications to meet compliance requirements. These web applications run in Amazon VPC on Amazon EC2 instances behind an Application Load Balancer (ALB). A security engineer wants to ensure that the load balancer will only accept connections over port 443, even if the ALB is mistakenly configured with an HTTP listener.

Which configuration steps should the security engineer take to accomplish this task?

- A. Create a security group with a rule that denies inbound connections from 0.0.0.0/0 on port 80. Attach this security group to the ALB to overwrite more permissive rules from the ALB's default security group.
- B. Create a network ACL that denies inbound connections from 0.0.0.0/0 on port 80. Associate the network ACL with the VPC's internet gateway.
- C. Create a network ACL that allows outbound connections to the VPC IP range on port 443 only. Associate the network ACL with the VPC's internet gateway.
- D. Create a security group with a single inbound rule that allows connections from 0.0.0.0/0 on port 443. Ensure this security group is the only one associated with the ALB.

▼ 中文:

一家公司需要在连接其网络应用程序时使用HTTPS，以满足合规要求。这些网络应用程序运行在Amazon VPC中的 Amazon EC2实例上，并位于一个 Application Load Balancer (ALB)之后。安全工程师希望确保负载均衡器仅接受通过端口443的连接，即使ALB被错误地配置为使用HTTP监听器。安全工程师应该采取哪些配置步骤来完成此任务？

- A.创建一个安全组，规则为拒绝来自0.0.0.0/0的端口80的入站连接。将此安全组附加到ALB，以覆盖ALB默认安全组中更宽松的规则。
- B. 创建一个网络ACL，规则为拒绝来自0.0.0.0/0的端口80的入站连接。将此网络ACL与VPC的互联网网关关联。
- C. 创建一个网络ACL，规则为仅允许到VPC IP范围的端口443的出站连接。将此网络ACL与VPC的互联网网关关联。
- D.创建一个安全组，规则为单一入站规则，允许来自0.0.0.0/0的端口443的连接。确保此安全组是唯一与ALB关联的安全组。

▼ 答案:

D

1. 考察的知识点

安全组和网络ACL的使用与配置。

如何限制ALB的监听端口以确保符合HTTPS连接的合规性要求。

理解安全组和网络ACL的作用范围及优先级。

2. 选项分析

A.

错误：安全组不支持“拒绝”规则，只支持“允许”规则。因此无法通过安全

组来拒绝端口80的连接。

B.

错误：网络ACL可以拒绝流量，但它作用于子网级别，而不是直接作用于ALB。将网络ACL与互联网网关关联并不能直接控制ALB的监听端口。

C.

错误：此选项限制的是出站流量，而题目要求限制的是入站流量。出站规则与题目需求不符。

D.

正确：安全组可以通过仅允许端口443的入站规则来确保ALB只接受HTTPS连接。通过确保此安全组是唯一与ALB关联的安全组，可以有效限制其他端口的访问。

▼ 48

▼ 英文:

A consultant agency needs to perform a security audit for a company's production AWS account. Several consultants need access to the account. The consultant agency already has its own AWS account. The company requires multi-factor authentication (MFA) for all access to its production account. The company also forbids the use of long-term credentials.

Which solution will provide the consultant agency with access that meets these requirements?

A. Create an IAM group. Create an IAM user for each consultant. Add each user to the group. Turn on MFA for each consultant.

B. Configure Amazon Cognito on the company's production account to authenticate against the consultant agency's identity provider (IdP). Add MFA to a Cognito user pool.

C. Create an IAM role in the consultant agency's AWS account. Define a trust policy that requires MFA. In the trust policy, specify the company's production account as the principal. Attach the trust policy to the role.

D. Create an IAM role in the company's production account. Define a trust policy that requires MFA. In the trust policy, specify the consultant agency's AWS account as the principal. Attach the trust policy to the role.

▼ 中文:

一家咨询机构需要对某公司的生产 AWS 账户进行安全审计。多个咨询顾问需要访问该账户。咨询机构已经拥有自己的 AWS 账户。

该公司要求所有访问其生产账户的操作都必须使用多重身份验证（MFA）。该公司还禁止使用长期凭证。

哪种解决方案可以为咨询机构提供符合这些要求的访问权限？

- A. 创建一个 IAM 组。为每个咨询顾问创建一个 IAM 用户。将每个用户添加到该组中。为每个咨询顾问启用 MFA。
- B. 在公司的生产账户中配置 Amazon Cognito，以针对咨询机构的身份提供商（IdP）进行身份验证。将 MFA 添加到 Cognito 用户池中。
- C. 在咨询机构的 AWS 账户中创建一个 IAM 角色。定义一个信任策略，要求使用 MFA。在信任策略中，将公司的生产账户指定为主体。将信任策略附加到该角色。
- D. 在公司的生产账户中创建一个 IAM 角色。定义一个信任策略，要求使用 MFA。在信任策略中，将咨询机构的 AWS 账户指定为主体。将信任策略附加到该角色。

▼ 答案:

D

1. 考察的知识点

IAM 角色与信任策略的配置

跨账户访问的实现

多因素认证 (MFA) 的强制要求

避免使用长期凭证的最佳实践

2. 选项分析

A. 创建一个 IAM 组。为每个咨询顾问创建一个 IAM 用户。将每个用户添加到该组中。为每个咨询顾问启用 MFA。

错误：虽然可以为每个用户启用 MFA，但此方法使用了长期凭证（IAM 用户），违反了公司禁止使用长期凭证的要求。

B. 配置 Amazon Cognito，以针对咨询机构的身份提供商（IdP）进行身份验证。将 MFA 添加到 Cognito 用户池中。

错误：Amazon Cognito 通常用于应用程序用户身份验证，而不是跨账户访问的场景。此选项不符合题目要求的生产账户访问场景。

C. 在咨询机构的 AWS 账户中创建一个 IAM 角色。定义一个信任策略，要求使用 MFA。在信任策略中，将公司的生产账户指定为主体。将信任策略附加到该角色。

错误：信任策略的主体应该是允许访问的账户，而不是生产账户。此选项的信任关系方向错误。

D. 在公司的生产账户中创建一个 IAM 角色。定义一个信任策略，要求使用 MFA。在信任策略中，将咨询机构的 AWS 账户指定为主体。将信任策略附加到该角色。
正确：此方法符合跨账户访问的最佳实践。通过在生产账户中创建 IAM 角色并定义信任策略，允许咨询机构的账户进行访问，同时强制要求 MFA。

▼ 49

▼ 英文:

A company uses AWS Lambda functions to implement application logic. The company uses an organization in AWS Organizations to manage hundreds of AWS accounts. The company needs to implement a solution to continuously monitor the Lambda functions for vulnerabilities in all accounts. The solution must publish detected issues to a dashboard. Lambda functions that are being tested or are in development must not appear on the dashboard. Which combination of steps will meet these requirements? (Choose two.)

A. Designate a delegated Amazon GuardDuty administrator account in the organization's management account. Use the GuardDuty Summary dashboard to obtain an overview of Lambda functions that have vulnerabilities.

B. Designate a delegated Amazon Inspector administrator account in the organization's management account. Use the Amazon Inspector dashboard to obtain an overview of Lambda functions that have vulnerabilities.

C. Apply tags of "test" or "development" to all Lambda functions that are in testing or development. Use a suppression filter that suppresses findings that contain these tags.

D. Enable AWS Shield Advanced in the organization's management account. Use Amazon CloudWatch to build a dashboard for Lambda functions that have vulnerabilities

E. Enable Lambda Protection in GuardDuty for all accounts. Auto-enable Lambda Protection for new accounts. Apply a tag to the Lambda functions that are in testing or development. Use

GuardDutyExclusion as the tag key and LambdaStandardScanning as the tag value.

▼ 中文:

一家公司使用 AWS Lambda 函数来实现应用逻辑。该公司使用 AWS Organizations 中的一个组织来管理数百个 AWS 账户。该公司需要实施一个解决方案，以持续监控所有账户中的 Lambda 函数是否存在漏洞。该解决方案必须将检测到的问题发布到一个仪表板上。正在测试或开发中的 Lambda 函数不得出现在仪表板上。

哪种步骤组合可以满足这些要求？（选择两项）

- A.在组织的管理账户中指定一个委派的 Amazon GuardDuty 管理员账户。使用 GuardDuty Summary 仪表板获取存在漏洞的 Lambda 函数的概览。
- B.在组织的管理账户中指定一个委派的 Amazon Inspector 管理员账户。使用 Amazon Inspector 仪表板获取存在漏洞的 Lambda 函数的概览。
- C.为所有正在测试或开发中的 Lambda 函数应用“test”或“development”标签。使用抑制过滤器来抑制包含这些标签的发现结果。
- D.在组织的管理账户中启用 AWS Shield Advanced。使用 Amazon CloudWatch 构建一个显示存在漏洞的 Lambda 函数的仪表板。
- E.为所有账户启用 GuardDuty 中的 Lambda Protection。为新账户自动启用 Lambda Protection。为正在测试或开发中的 Lambda 函数应用一个标签。使用 GuardDutyExclusion 作为标签键，LambdaStandardScanning 作为标签值。

▼ 答案:

BC

1. 考察的知识点

Amazon Inspector的功能及其在组织中的使用。
如何通过标签和抑制过滤器来排除特定资源的扫描结果。
AWS Organizations的管理账户和委派账户的使用。
如何构建监控和漏洞检测的解决方案。

2. 选项分析

A.

错误：Amazon GuardDuty主要用于检测恶意活动和异常行为，而不是专门用于检测Lambda函数的漏洞。

虽然GuardDuty可以提供一些安全信息，但它不是专门设计用于Lambda

函数的漏洞扫描。

B.

正确：Amazon Inspector支持对Lambda函数进行漏洞扫描，并可以通过仪表板提供检测结果。

委派Amazon Inspector管理员账户是跨账户管理的最佳实践。

C.

正确：通过标签和抑制过滤器，可以排除测试或开发阶段的Lambda函数，从而满足题目要求。

这是AWS中常见的资源管理和过滤方法。

D.

错误：AWS Shield Advanced主要用于保护应用免受DDoS攻击，而不是用于漏洞检测。

虽然可以使用CloudWatch构建仪表板，但它无法直接检测Lambda函数的漏洞。

E.

错误：GuardDuty的Lambda Protection功能主要用于检测恶意活动，而不是漏洞扫描。

题目要求的是漏洞检测，而不是恶意活动检测，因此此选项不符合要求。

▼ 50

▼ 英文:

A company has an organization in AWS Organizations that includes dedicated accounts

for each of its business units. The company is collecting all AWS CloudTrail logs from the

accounts in a single Amazon S3 bucket in the top-level account. The company's IT

governance team has access to the top-level account. A security engineer needs to allow

each business unit to access its own CloudTrail logs.

The security engineer creates an IAM role in the top-level account for each of the other

accounts. For each role, the security engineer creates an IAM policy to allow read-only

permissions to objects in the S3 bucket with the prefix of the respective logs.

Which action must the security engineer take each business unit account to allow an IAM user in the account to read the logs?

- A. Attach a policy to the IAM user to allow the user to assume the role that was created in the top-level account.
- B. Create an SCP that grants permissions to the top-level account.
- C. Use the root account of the business unit account to assume the role that was created in the top-level account. Specify the role's ARN in the policy.
- D. Forward the credentials of the IAM role in the top-level account to the IAM user in the business unit account.

▼ 中文:

一家公司在 AWS Organizations 中設有一個組織，其中包含每個業務部門的專用帳戶。該公司正在將這些帳戶中的所有 AWS CloudTrail 日誌收集到頂級帳戶中單一 Amazon S3 儲存桶中。該公司的 IT 治理團隊可以存取該頂級帳戶。一位安全工程師需要允許每個業務部門存取自己的 CloudTrail 日誌。安全工程師在頂級帳戶中為每個其他帳戶建立一個 IAM 角色。對於每個角色，安全工程師都會建立一個 IAM 策略，以允許對 S3 儲存桶中帶有對應日誌前綴的物件擁有唯讀權限。

- A. 將政策附加到 IAM 用戶，以允許該用戶承擔在頂級帳戶中建立的角色。在策略中指定角色的 ARN。
- B. 建立向頂級帳戶授予權限的 SCP。
- C. 使用業務部門帳戶的根帳戶代入在頂級帳戶中建立的角色。在策略中指定該角色的 ARN。
- D. 將頂級帳戶中的 IAM 角色的憑證轉發給業務部門帳戶中的 IAM 使用者。

▼ 答案:

A

頂級帳戶（集中日誌）

頂級帳戶（或稱管理帳戶/日誌帳戶）中設定了：

1. 一個 **Amazon S3 儲存桶**，用來存放所有 CloudTrail 日誌。

2. 針對每個業務部門帳戶建立的 IAM 角色（假設名稱為

`BusinessUnitXReadOnlyRole`）。

- 這些角色的 **IAM 信任關係** 必須允許對應的業務部門帳戶（AWS 帳戶 ID）擔任（Assume）此角色。
- 這些角色附帶的 **IAM 政策** 授予對 S3 儲存桶中特定業務部門日誌前綴（例如：`s3:GetObject` on `arn:aws:s3:::cloudtrail-logs-bucket/AWSLogs/BusinessUnitXAccountID/*`）的唯讀權限。

業務部門帳戶（需要存取日誌）

業務部門帳戶中的安全工程師需要允許特定使用者存取這些日誌。

A. 將政策附加到 IAM 用戶，以允許該用戶承擔在頂級帳戶中建立的角色。在策略中指定角色的 ARN。

- 這是正確的方法。
- 在業務部門帳戶中，安全工程師會建立一個 **IAM 使用者**（或將政策附加到現有的使用者/群組/角色）。
- 該使用者附帶的 **IAM 政策** 必須包含 `sts:AssumeRole` 動作，並將資源（Resource）設定為頂級帳戶中為其部門建立的角色 ARN。
- 有了這個權限，業務部門的使用者就可以透過呼叫 **AWS STS AssumeRole API** 來暫時取得頂級帳戶中角色的憑證，進而使用這些憑證存取 S3 中的日誌。

為什麼其他選項是錯的？

B. 建立向頂級帳戶授予權限的 SCP。

- **SCP (Service Control Policies)** 用於限制 Organizations 內所有成員帳戶可以使用的**最大**權限集。它**不能**授予權限；它只能設定護欄。即使建立了 SCP，業務部門帳戶中的使用者仍需要 IAM 政策來實際執行 `AssumeRole`。

C. 使用業務部門帳戶的根帳戶代入在頂級帳戶中建立的角色。在策略中指定該角色的 ARN。

- **使用根帳戶 (Root User)** 進行日常操作或跨帳戶存取是**嚴重的安全風險**，且通常是違反最佳實踐的。應始終使用具備所需最小權限的 IAM 實體（使用者或角色）。

D. 將頂級帳戶中的 IAM 角色的憑證轉發給業務部門帳戶中的 IAM 使用者。

- IAM 角色憑證（Access Key ID 和 Secret Access Key）是**臨時的**，且**不應該被轉發**。這是一個**嚴重的安全疏失**。正確的方法是讓使用者在需要時**代入角色**（Assume Role），由 AWS STS 服務提供臨時憑證。

▼ 51

▼ 英文:

A company has configured an organization in AWS Organizations for its AWS accounts. AWS CloudTrail is enabled in all AWS Regions.

A security engineer must implement a solution to prevent CloudTrail from being disabled.

Which solution will meet this requirement?

- A. Enable CloudTrail log file integrity validation from the organization's management account.
- B. Enable server-side encryption with AWS KMS keys (SSE-KMS) for CloudTrail logs. Create a KMS key. Attach a policy to the key to prevent decryption of the logs.
- C. Create an SCP that includes an explicit Deny rule for the StopLogging action and the DeleteTrail action. Attach the SCP to the root OU.
- D. Create IAM policies for all the company's users to prevent the users from performing the DescribeTrails action and the GetTrailStatus action.

▼ 中文:

一家公司在其 AWS 帳戶中為 AWS Organizations 配置了一個組織。AWS CloudTrail 在所有 AWS 區域中均已啟用。

一名安全工程師必須實施一個解決方案，以防止 CloudTrail 被禁用。哪種解決方案可以满足此要求？

- A. 從組織的管理帳戶啟用 CloudTrail 日志文件完整性驗證。
- B. 為 CloudTrail 日志啟用使用 AWS KMS 密鑰（SSE-KMS）的服務器端加密。創建一個 KMS 密鑰。將策略附加到該密鑰以防止日志解密。
- C. 創建一個包含顯式 Deny 規則的 SCP，用於 StopLogging 操作和 DeleteTrail 操作。將 SCP 附加到根 OU。

D.为公司所有用户创建 IAM 策略，以防止用户执行 DescribeTrails 操作和 GetTrailStatus 操作。

▼ 答案:

C

1. 考察的知识点本题考察的是AWS Organizations中的服务控制策略（SCP）的使用，以及如何保护AWS CloudTrail不被禁用。
涉及的知识点包括：SCP的功能与作用、CloudTrail的StopLogging和DeleteTrail操作的保护机制。

2. 选项分析

A.

错误：启用日志文件完整性验证可以确保日志文件未被篡改，但它无法防止CloudTrail本身被禁用。

B.

错误：启用KMS加密和附加策略可以保护日志的解密，但它无法防止CloudTrail被禁用。

C.

正确：SCP可以在组织级别强制执行策略，显式拒绝StopLogging和DeleteTrail操作可以有效防止CloudTrail被禁用。

D.

错误：限制DescribeTrails和GetTrailStatus操作无法防止CloudTrail被禁用，因为这些操作与禁用CloudTrail无关。

▼ 52

▼ 英文:

A company runs its microservices architecture in Kubernetes containers on AWS by using Amazon Elastic Kubernetes Service (Amazon EKS) and Amazon Aurora. The company has an organization in AWS Organizations to manage hundreds of AWS accounts that host different microservices.

The company needs to implement a monitoring solution for logs from all AWS resources across all accounts. The solution must include automatic detection of security-related issues.

Which solution will meet these requirements with the LEAST operational effort?

A. Designate an Amazon GuardDuty administrator account in the organization's management account. Enable GuardDuty

for all accounts. Enable EKS Protection and RDS Protection in the GuardDuty administrator account.

B. Designate a monitoring account. Share Amazon CloudWatch logs from all accounts with the monitoring account.

Configure Aurora to publish all logs to CloudWatch. Use Amazon Inspector in the monitoring account to evaluate the CloudWatch logs

C. Create a central Amazon S3 bucket in the organization's management account. Configure AWS CloudTrail in all AWS accounts to deliver CloudTrail logs to the S3 bucket. Configure Aurora to publish all logs to CloudTrail. Use Amazon Athena to query the CloudTrail logs in the S3 bucket for security issues.

D. Designate a monitoring account. Share Amazon CloudWatch logs from all accounts with the monitoring account.

Subscribe an Amazon Kinesis data stream to the CloudWatch logs. Create AWS Lambda functions to process log records in the data stream to detect security issues.

▼ 中文:

一家公司通过使用 Amazon Elastic Kubernetes Service (Amazon EKS) 和 Amazon Aurora，在 AWS 上的 Kubernetes 容器中运行其微服务架构。该公司在 AWS Organizations 中拥有一个组织，用于管理托管不同微服务的数百个 AWS 账户。

该公司需要为所有账户中的所有 AWS 资源的日志实施一个监控解决方案。该解决方案必须包括自动检测与安全相关的问题。

哪种解决方案能够以最少的操作工作量满足这些要求？

A.在组织的管理账户中指定一个 Amazon GuardDuty 管理员账户。为所有账户启用 GuardDuty。在 GuardDuty 管理员账户中启用 EKS Protection 和 RDS Protection。

B.指定一个监控账户。从所有账户共享 Amazon CloudWatch 日志到监控账户。配置 Aurora 将所有日志发布到CloudWatch。在监控账户中使用 Amazon Inspector 评估 CloudWatch 日志。

C.在组织的管理账户中创建一个中央 Amazon S3 存储桶。在所有 AWS 账户中配置 AWS CloudTrail，将 CloudTrail 日志传送到 S3 存储桶。配置 Aurora 将所有日志发布到 CloudTrail。使用 Amazon Athena 查询 S3 存储桶中的 CloudTrail日志以发现安全问题。

D.指定一个监控账户。从所有账户共享 Amazon CloudWatch 日志到监控账户。将一个 Amazon Kinesis 数据流订阅到CloudWatch 日志。创建 AWS Lambda 函数以处理数据流中的日志记录以检测安全问题。

▼ 答案:

A

1. 考察的知识点

Amazon GuardDuty的功能，包括EKS Protection和RDS Protection。

[跨账户监控和日志管理的最佳实践。](#)

AWS Organizations的集中管理能力。

自动化安全问题检测的解决方案。

2. 选项分析

A. Designate an Amazon GuardDuty administrator account in the organization's management account. Enable GuardDuty for all accounts. Enable EKS Protection and RDS Protection in the GuardDuty administrator account.

分析：

Amazon GuardDuty是AWS的托管威胁检测服务，能够自动检测安全问题。

通过AWS Organizations，可以集中管理GuardDuty并为所有账户启用保护。

EKS Protection和RDS Protection是GuardDuty的扩展功能，专门用于检测Kubernetes和Aurora相关的安全问题。

此选项操作简单，自动化程度高，符合“最少的操作努力”要求。

结论：正确。

B. Designate a monitoring account. Share Amazon CloudWatch logs from all accounts with the monitoring account. Configure Aurora to publish all logs to CloudWatch. Use Amazon Inspector in the monitoring account to evaluate the CloudWatch logs.

分析：

Amazon Inspector主要用于评估EC2实例和容器镜像的安全性，而不是直接分析CloudWatch日志。

需要手动配置日志共享和分析，操作复杂度较高。

不符合“最少的操作努力”要求。

结论：错误。

C. Create a central Amazon S3 bucket in the organization's management account. Configure AWS CloudTrail in all AWS accounts to deliver CloudTrail logs to the S3 bucket. Configure

Aurora to publish all logs to CloudTrail. Use Amazon Athena to query the CloudTrail logs in the S3 bucket for security issues.

分析：

此选项依赖于手动查询CloudTrail日志，无法实现自动化安全问题检测。

需要配置多个服务（S3、CloudTrail、Athena），操作复杂度较高。

不符合“最少的操作努力”要求。

结论：错误。

D. Designate a monitoring account. Share Amazon CloudWatch logs from all accounts with the monitoring account. Subscribe an Amazon Kinesis data stream to the CloudWatch logs. Create AWS Lambda functions to process log records in the data an Amazon Kinesis data stream to the CloudWatch logs. Create AWS Lambda functions to process log records in the data stream to detect security issues.

分析：

此选项需要手动创建和管理Kinesis数据流以及Lambda函数，操作复杂度较高。

虽然可以实现安全问题检测，但不如GuardDuty的自动化程度高。

不符合“最少的操作努力”要求。

结论：错误。

▼ 53

▼ 英文:

A security engineer has been asked to troubleshoot inbound connectivity to a web server. This single web server is not receiving inbound connections from the internet, whereas all other web servers are functioning properly.

The architecture includes network ACLs, security groups, and a virtual security appliance. In addition, the development team has implemented Application Load Balancers (ALBs) to distribute the load across all web servers. It is a requirement that traffic between the web servers and the internet flow through the virtual security appliance.

The security engineer has verified the following:

1. The rule set in the security groups is correct.
2. The rule set in the network ACLs is correct.

3. The rule set in the virtual appliance is correct.

Which of the following are other valid items to troubleshoot in this scenario? (Choose two.)

- A. Verify that the 0.0.0.0/0 route in the route table for the web server subnet points to a NAT gateway.
- B. Verify which security group is applied to the particular web server's elastic network interface (ENI).
- C. Verify that the 0.0.0.0/0 route in the route table for the web server subnet points to the virtual security appliance.

Most Voted

- D. Verify the registered targets in the ALB. Most Voted
- E. Verify that the 0.0.0.0/0 route in the public subnet points to a NAT gateway.

▼ 中文:

一位安全工程师被要求排查一个网页服务器的入站连接问题。这个单独的网页服务器无法接收来自互联网的入站连接，而其他所有网页服务器都运行正常。架构包括网络ACL、安全组和虚拟安全设备。此外，开发团队已实施了 Application Load Balancers (ALBs) 来分配所有网页服务器的负载。要求网页服务器与互联网之间的流量必须通过虚拟安全设备。

安全工程师已验证以下内容：

- 1. 安全组中的规则集是正确的。
- 2. 网络ACL中的规则集是正确的。
- 3. 虚拟设备中的规则集是正确的。

在这种情况下，以下哪些是其他有效的排查项？（选择两个）

- A. 验证网页服务器子网的路由表中0.0.0.0/0路由是否指向NAT网关。
- B. 验证应用于特定网页服务器的弹性网络接口（ENI）的安全组。
- C. 验证网页服务器子网的路由表中0.0.0.0/0路由是否指向虚拟安全设备。
- D. 验证ALB中的注册目标。
- E. 验证公共子网中的0.0.0.0/0路由是否指向NAT网关。

▼ 答案:

CD

1. 考察的知识点

网络路由配置：如何正确配置子网的路由表以确保流量能够到达目标。

安全组和网络接口：如何验证安全组是否正确应用到特定资源。

负载均衡器配置：如何检查ALB的注册目标是否正确。

虚拟安全设备的流量路径：确保流量通过虚拟安全设备。

2. 选项分析

A. Verify that the 0.0.0.0/0 route in the route table for the web server subnet points to a NAT gateway.

错误：NAT网关通常用于出站流量，而题目明确提到问题是入站流量的问题，因此此选项与问题无关。

B. Verify which security group is applied to the particular web server's elastic network interface (ENI).

错误：题目已经明确指出安全组的规则集是正确的，因此检查安全组不会解决问题。

C. Verify that the 0.0.0.0/0 route in the route table for the web server subnet points to the virtual security appliance.

正确：题目要求流量必须通过虚拟安全设备，因此需要验证路由表是否正确指向虚拟安全设备。

D. Verify the registered targets in the ALB.

正确：如果目标实例未正确注册到ALB，流量将无法分发到该实例，因此需要验证ALB的注册目标。

E. Verify that the 0.0.0.0/0 route in the public subnet points to a NAT gateway.

错误：公共子网的路由表指向NAT网关通常用于出站流量，与入站流量问题无关。

▼ 54

▼ 英文:

A company has a strict policy against using root credentials. The company's security team wants to be alerted as soon as possible when root credentials are used to sign in to the AWS Management Console.

How should the security team achieve this goal?

A. Use AWS Lambda to periodically query AWS CloudTrail for console login events and send alerts using Amazon Simple Notification Service (Amazon SNS).

B. Use Amazon EventBridge to monitor console logins and direct them to Amazon Simple Notification Service (Amazon SNS).

C. Use Amazon Athena to query AWS IAM Identity Center logs and send alerts using Amazon Simple Notification Service (Amazon SNS) for root login events.

D. Configure AWS Resource Access Manager to review the access logs and send alerts using Amazon Simple Notification Service (Amazon SNS).

▼ 中文:

一家公司有严格的政策禁止使用 root 凭证。公司的安全团队希望在使用 root 凭证登录 AWS Management Console 时尽快收到警报。安全团队应该如何实现这一目标？

A.使用 AWS Lambda 定期查询 AWS CloudTrail 的控制台登录事件，并使用 Amazon Simple Notification Service (Amazon SNS) 发送警报。

B.使用 Amazon EventBridge 监控控制台登录，并将其定向到 Amazon Simple Notification Service (Amazon SNS)。

C.使用 Amazon Athena 查询 AWS IAM Identity Center 日志，并使用 Amazon Simple Notification Service (Amazon SNS) 发送 root 登录事件的警报。

D.配置 AWS Resource Access Manager 审查访问日志，并使用 Amazon Simple Notification Service (Amazon SNS) 发送警报。

▼ 答案:

B

1. 考察的知识点

本题考察的是AWS安全监控与事件响应的能力，特别是如何监控和检测AWS根账户的登录行为。

涉及的服务包括AWS CloudTrail、Amazon EventBridge、Amazon SNS等。

2. 选项分析

A. 使用 AWS Lambda 定期查询 AWS CloudTrail 的控制台登录事件，并使用 Amazon SNS 发送警报。

错误：虽然可以通过AWS Lambda定期查询CloudTrail日志来实现监控，但这种方法效率较低且不符合“尽快”触发警报的要求。

CloudTrail日志是事件记录的基础，但直接使用Lambda定期查询并不是最佳实践。

B. 使用 Amazon EventBridge 监控控制台登录，并将其定向到 Amazon SNS。

正确：Amazon EventBridge可以实时捕获事件（如根账户登录事件），并将事件路由到Amazon SNS以触发警报。

这种方法是实时的，符合“尽快”触发警报的要求。

C. 使用 Amazon Athena 查询 AWS IAM Identity Center 日志，并使用 Amazon SNS 发送 root 登录事件的警报。

错误：IAM Identity Center日志与根账户登录无关，且Athena查询是手动或定期的，无法实时触发警报。

此选项不适用于监控根账户登录事件。

D. 配置 AWS Resource Access Manager 审查访问日志，并使用 Amazon SNS 发送警报。

错误：AWS Resource Access Manager用于资源共享管理，与监控根账户登录事件无关。

此选项完全不适用于本题场景。

▼ 55

▼ 英文:

A company wants to store all objects that contain sensitive data in an Amazon S3 bucket. The company will use server-side encryption to encrypt the S3 bucket. The company's operations team manages access to the company's S3 buckets. The company's security team manages access to encryption keys. The company wants to separate the duties of the two teams to ensure that configuration errors by only one of these teams will not compromise the data by granting unauthorized access to plaintext data.

Which solution will meet this requirement?

A. Ensure that the operations team configures default bucket encryption on the S3 bucket to use server-side encryption with Amazon S3 managed encryption keys (SSE-S3). Ensure that the security team creates an IAM policy that controls access to use the encryption keys.

B. Ensure that the operations team creates a bucket policy that requires requests to use server-side encryption with AWS KMS keys (SSE-KMS) that are customer managed. Ensure that the security team creates a key policy that controls access to the encryption keys.

- C. Ensure that the operations team creates a bucket policy that requires requests to use server-side encryption with Amazon S3 managed keys (SSE-S3). Ensure that the security team creates an IAM policy that controls access to the encryption keys.
- D. Ensure that the operations team creates a bucket policy that requires requests to use server-side encryption with customer-provided encryption keys (SSE-C). Ensure that the security team stores the customer-provided keys in AWS Key Management Service (AWS KMS). Ensure that the security team creates a key policy that controls access to the encryption keys.

▼ 中文:

一家公司希望将所有包含敏感数据的对象存储在一个 Amazon S3 bucket 中。该公司将使用服务器端加密来加密 S3 bucket。公司的运营团队负责管理公司 S3 bucket 的访问权限。公司的安全团队负责管理加密密钥的访问权限。

该公司希望将两个团队的职责分开，以确保只有其中一个团队的配置错误不会通过授予未授权访问明文数据来危及数据安全。哪种解决方案可以满足这一要求？

- A. 确保运营团队在 S3 bucket 上配置默认 bucket 加密，以使用 Amazon S3 管理的加密密钥 (SSE-S3) 进行服务器端加密。确保安全团队创建一个 IAM 策略来控制对加密密钥的访问。
- B. 确保运营团队创建一个 bucket 策略，要求请求使用客户管理的 AWS KMS 密钥 (SSE-KMS) 进行服务器端加密。确保安全团队创建一个密钥策略来控制对加密密钥的访问。
- C. 确保运营团队创建一个 bucket 策略，要求请求使用 Amazon S3 管理的密钥 (SSE-S3) 进行服务器端加密。确保安全团队创建一个 IAM 策略来控制对加密密钥的访问。
- D. 确保运营团队创建一个 bucket 策略，要求请求使用客户提供的加密密钥 (SSE-C) 进行服务器端加密。确保安全团队将客户提供的密钥存储在 AWS Key Management Service (AWS KMS) 中。确保安全团队创建一个密钥策略来控制对加密密钥的访问。

▼ 答案:

B

1. 考察的知识点

Amazon S3 的服务器端加密选项 (SSE-S3, SSE-KMS, SSE-C)。
如何使用 AWS KMS 管理加密密钥。

IAM 策略与 Key Policy 的职责分离。
如何通过 Bucket Policy 强制加密要求。

2. 选项分析

- A. 错误：SSE-S3 使用 Amazon S3 管理的加密密钥，无法实现密钥管理职责的分离，因为加密密钥由 S3 自动管理，安全团队无法控制密钥的访问权限。
- B. 正确：SSE-KMS 使用 AWS KMS 管理的加密密钥，支持客户管理的密钥。通过 Bucket Policy 强制加密要求，安全团队可以通过 Key Policy 控制对加密密钥的访问权限，从而实现职责分离。
- C. 错误：SSE-S3 使用 Amazon S3 管理的加密密钥，与选项 A 的问题相同，无法实现密钥管理职责的分离。
- D. 错误：SSE-C 使用客户提供的加密密钥，但客户提供的密钥无法直接存储在 AWS KMS 中。此选项的描述不符合 AWS 的实际功能。

▼ 56

▼ 英文:

A security engineer is designing security controls for a fleet of Amazon EC2 instances that run sensitive workloads in a VPC.
The security engineer needs to implement a solution to detect and mitigate software vulnerabilities on the EC2 instances.
Which solution will meet this requirement?

- A. Scan the EC2 instances by using Amazon Inspector. Apply security patches and updates by using AWS Systems Manager Patch Manager.
- B. Install host-based firewall and antivirus software on each EC2 instance. Use AWS Systems Manager Run Command to update the firewall and antivirus software.
- C. Install the Amazon CloudWatch agent on the EC2 instances. Enable detailed logging. Use Amazon EventBridge to review the software logs for anomalies.
- D. Scan the EC2 instances by using Amazon GuardDuty Malware Protection. Apply security patches and updates by using AWS Systems Manager Patch Manager.

▼ 中文:

一名安全工程师正在为运行敏感工作负载的 Amazon EC2 实例设计安全控制，这些实例位于一个 VPC 中。安全工程师需要实施一个解决方案，以检测

并缓解 EC2 实例上的软件漏洞。

哪种解决方案可以满足此要求？

- A. 使用 Amazon Inspector 扫描 EC2 实例。使用 AWS Systems Manager Patch Manager 应用安全补丁和更新。
- B. 在每个 EC2 实例上安装基于主机的防火墙和杀毒软件。使用 AWS Systems Manager Run Command 更新防火墙和杀毒软件。
- C. 在 EC2 实例上安装 Amazon CloudWatch agent。启用详细日志记录。使用 Amazon EventBridge 审查软件日志中的异常。
- D. 使用 Amazon GuardDuty Malware Protection 扫描 EC2 实例。使用 AWS Systems Manager Patch Manager 应用安全补丁和更新。

▼ 答案:

A

1. 考察的知识点

Amazon Inspector的功能：用于扫描EC2实例以检测软件漏洞和安全问题。

AWS Systems Manager Patch Manager的功能：用于自动化补丁管理和更新。

如何设计安全控制以检测和缓解EC2实例上的软件漏洞。

2. 选项分析

A.

正确：Amazon Inspector是专门设计用于扫描EC2实例以检测软件漏洞的服务。

正确：AWS Systems Manager Patch Manager可以自动化补丁管理，确保实例保持最新状态。

此选项全面覆盖了检测和缓解软件漏洞的需求。

B.

错误：虽然安装防火墙和杀毒软件可以提供一定的保护，但它们并不能直接检测软件漏洞。

错误：AWS Systems Manager Run Command主要用于执行命令，而不是专门用于漏洞扫描或补丁管理。

C.

错误：CloudWatch和EventBridge主要用于监控和事件管理，而不是专门用于漏洞扫描或补丁管理。

错误：此选项未提及如何应用补丁来缓解漏洞。

D.

错误：Amazon GuardDuty主要用于检测恶意活动和威胁，而不是专门用于软件漏洞扫描。

正确：AWS Systems Manager Patch Manager可以应用补丁，但此选项的漏洞检测部分不够准确。

▼ 57

▼ 英文:

A company stores sensitive data in AWS Secrets Manager. A security engineer needs to design a solution to generate a notification email when anomalous GetSecretValue API calls occur. The security engineer has configured an Amazon EventBridge rule for all Secrets Manager events that AWS CloudTrail delivers.

Which solution will meet these requirements?

A. Configure CloudTrail as the target of the EventBridge rule. Set up an attribute filter on the IncomingBytes attribute and enable anomaly detection. Create an Amazon Simple Notification Service (Amazon SNS) topic. Configure a CloudTrail alarm that uses the SNS topic to send the notification.

B. Configure CloudTrail as the target of the EventBridge rule. Set up an attribute filter on the IncomingBytes attribute and enable anomaly detection. Create an Amazon Simple Queue Service (Amazon SQS) queue. Configure a CloudTrail alarm that uses the SQS queue to send the notification.

C. Configure Amazon CloudWatch Logs as the target of the EventBridge rule. Set up a metric filter on the IncomingBytes metric and enable anomaly detection. Create an Amazon Simple Notification Service (Amazon SNS) topic. Configure a CloudWatch alarm that uses the SNS topic to send the notification.

D. Configure Amazon CloudWatch Logs as the target of the EventBridge rule. Use CloudWatch Logs Insights query syntax to search for anomalous GetSecretValue API calls. Create an Amazon Simple Queue Service (Amazon SQS) queue. Configure a CloudWatch alarm that uses the SQS queue to send the notification.

▼ 中文:

一家公司将敏感数据存储在 AWS Secrets Manager 中。一名安全工程师需要设计一个解决方案，当发生异常的 GetSecretValue API 调用时生成通知电子邮件。安全工程师已经为 AWS CloudTrail 传递的所有 Secrets Manager

事件配置了一个 Amazon EventBridge 规则。

哪种解决方案可以满足这些要求？

A.将 CloudTrail 配置为 EventBridge 规则的目标。设置 IncomingBytes 属性上的属性过滤器并启用异常检测。创建一个Amazon Simple Notification Service (Amazon SNS) 主题。配置一个使用 SNS 主题发送通知的 CloudTrail 警报。

B.将 CloudTrail 配置为 EventBridge 规则的目标。设置 IncomingBytes 属性上的属性过滤器并启用异常检测。创建一个Amazon Simple Queue Service (Amazon SQS) 队列。配置一个使用 SQS 队列发送通知的 CloudTrail 警报。

C.将 Amazon CloudWatch Logs 配置为 EventBridge 规则的目标。设置 IncomingBytes 指标上的指标过滤器并启用异常检测。创建一个 Amazon Simple Notification Service (Amazon SNS) 主题。配置一个使用 SNS 主题发送通知的CloudWatch 警报。

D.将 Amazon CloudWatch Logs 配置为 EventBridge 规则的目标。使用 CloudWatch Logs Insights 查询语法搜索异常的GetSecretValue API 调用。创建一个 Amazon Simple Queue Service (Amazon SQS) 队列。配置一个使用 SQS 队列发送通知的 CloudWatch 警报。

▼ 答案:

C

1. 考察的知识点

Amazon EventBridge规则的配置与目标选择。

CloudWatch Logs与CloudWatch Alarms的使用。

如何设置指标过滤器和启用异常检测。

Amazon SNS与SQS的通知机制。

2. 选项分析

A. Configure CloudTrail as the target of the EventBridge rule...

错误：CloudTrail本身不能直接作为EventBridge规则的目标。

EventBridge规则需要将事件发送到支持的目标（如 CloudWatch Logs、SNS等）。

错误：IncomingBytes属性是一个指标，应该通过CloudWatch Logs的指标过滤器来处理，而不是直接在CloudTrail中设置。

B. Configure CloudTrail as the target of the EventBridge rule...

错误：与选项A类似，CloudTrail不能直接作为EventBridge规则的目标。

错误：虽然SQS可以用来接收通知，但题目要求的是发送通知邮件，SNS

更适合此场景。

C. Configure Amazon CloudWatch Logs as the target of the EventBridge rule...

正确：CloudWatch Logs是EventBridge规则的有效目标，可以接收事件并设置指标过滤器。

正确：IncomingBytes指标可以通过CloudWatch Logs的指标过滤器进行监控，并启用异常检测。

正确：SNS是发送通知邮件的最佳选择，符合题目要求。

D. Configure Amazon CloudWatch Logs as the target of the EventBridge rule...

错误：虽然CloudWatch Logs Insights可以查询日志，但题目要求的是基于指标的异常检测，而不是日志查询。

错误：SQS用于队列消息传递，不适合发送通知邮件。

▼ 58

▼ 英文:

A company is using AWS Organizations with the default SCP. The company needs to restrict AWS usage for all AWS accounts that are in a specific OU.

Except for some desired global services, the AWS usage must occur only in the eu-west-1 Region for all accounts in the OU. A security engineer must create an SCP that applies the restriction to existing accounts and any new accounts in the OU.

Which SCP will meet these requirements?

A.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Deny",
      "NotAction": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}

```

B.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Allow",
      "Action": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}

```

C.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Deny",
      "NotAction": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}

```

D.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Allow",
      "NotAction": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}

```

▼ 中文:

一家公司正在使用AWS Organizations并启用了默认的SCP。该公司需要限制特定OU中所有AWS账户的AWS使用权限。

除了某些所需的全球服务外，所有OU中的账户必须仅在eu-west-1区域内使用AWS服务。一名安全工程师必须创建一个SCP，以将此限制应用于现有账

户以及OU中的任何新账户。
哪个SCP能够满足这些要求？

A.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Deny",
      "NotAction": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}
```

B.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Allow",
      "Action": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}
```

C.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Deny",
      "NotAction": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}
```

D.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Allow",
      "NotAction": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}
```

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS Organizations中的服务控制策略（SCP）的使用，特别是如何限制账户的区域访问权限。

涉及到SCP的语法、策略继承规则以及如何应用到特定OU中的账户。

2. 选项分析

A: 分析选项A的内容，解释为什么正确或错误。

B: 分析选项B的内容，解释为什么正确或错误。

C: 分析选项C的内容，解释为什么正确或错误。

D: 分析选项D的内容，解释为什么正确或错误。

▼ 59

▼ 英文:

A company is planning to migrate its applications to AWS in a single AWS Region. The company's applications will use a combination of Amazon EC2 instances, Elastic Load Balancing (ELB) load balancers, and Amazon S3 buckets. The company wants to complete the migration as quickly as possible. All the applications must meet the following requirements:

- Data must be encrypted at rest.
- Data must be encrypted in transit.
- Endpoints must be monitored for anomalous network traffic.

Which combination of steps should a security engineer take to meet these requirements with the LEAST effort? (Choose three.)

- A. Install the Amazon Inspector agent on EC2 instances by using AWS Systems Manager Automation.
- B. Enable Amazon GuardDuty in all AWS accounts.
- C. Create VPC endpoints for Amazon EC2 and Amazon S3. Update VPC route tables to use only the secure VPC endpoints.
- D. Configure AWS Certificate Manager (ACM). Configure the load balancers to use certificates from ACM.
- E. Use AWS Key Management Service (AWS KMS) for key management. Create an S3 bucket policy to deny any PutObject command with a condition for x-amz-meta-side-encryption.
- F. Use AWS Key Management Service (AWS KMS) for key management. Create an S3 bucket policy to deny any PutObject command with a condition for x-amz-server-side-encryption.

▼ 中文:

一家公司计划将其应用程序迁移到单一的 AWS 区域。公司的应用程序将使用 Amazon EC2 实例、Elastic Load Balancing (ELB) 负载均衡器和 Amazon S3 存储桶的组合。公司希望尽快完成迁移。所有应用程序必须满足以下要求：

- 数据必须在静态状态下加密。
- 数据必须在传输过程中加密。
- 必须监控端点是否存在异常的网络流量。

安全工程师应该采取哪些步骤，以最少的努力满足这些要求？（选择三项）

- A. 使用 AWS Systems Manager Automation 在 EC2 实例上安装 Amazon Inspector agent。
- B. 在所有 AWS 账户中启用 Amazon GuardDuty。
- C. 为 Amazon EC2 和 Amazon S3 创建 VPC 端点。更新 VPC 路由表以仅使用安全的 VPC 端点。
- D. 配置 AWS Certificate Manager (ACM)。配置负载均衡器以使用来自 ACM 的证书。
- E. 使用 AWS Key Management Service (AWS KMS) 进行密钥管理。创建一个 S3 存储桶策略，以拒绝任何带有 x-amzmeta-side-encryption 条件的 PutObject 命令。
- F. 使用 AWS Key Management Service (AWS KMS) 进行密钥管理。创建一个 S3 存储桶策略，以拒绝任何带有 x-amzserver-side-encryption 条件的 PutObject 命令。

▼ 答案:

BDF

1. 考察的知识点

数据加密：包括数据在传输中和静止时的加密。

网络安全：监控网络流量以检测异常行为。

安全配置：使用 AWS 服务（如 ACM、KMS、GuardDuty）实现安全性要求。

2. 选项分析

A. Install the Amazon Inspector agent on EC2 instances by using AWS Systems Manager Automation.

分析：Amazon Inspector 主要用于评估 EC2 实例的漏洞和安全问题，但题目要求是监控网络流量和加密数据，而不是漏洞扫描。因此此选项与题目要求不直接相关。错误。

B. Enable Amazon GuardDuty in all AWS accounts.

分析：Amazon GuardDuty 是一个威胁检测服务，可以监控网络流量并检测异常行为，符合题目中“监控网络流量”的要

求。正确。

C. Create VPC endpoints for Amazon EC2 and Amazon S3. Update VPC route tables to use only the secure VPC endpoints.

分析：VPC端点可以提高安全性，但它主要用于确保流量在AWS网络内传输，而不是直接满足加密数据或监控网络流量的要求。此选项与题目要求不完全匹配。错误。

D. Configure AWS Certificate Manager (ACM). Configure the load balancers to use certificates from ACM.

分析：ACM可以管理SSL/TLS证书，用于加密数据在传输中的安全性，符合题目中“数据必须加密在传输中”的要求。正确。

E. Use AWS Key Management Service (AWS KMS) for key management. Create an S3 bucket policy to deny any PutObject command with a condition for x-amz-meta-side-encryption.

分析：此选项提到的x-amz-meta-side-encryption是一个错误的条件，AWS通常使用x-amz-server-side-encryption来强制服务端加密。此选项不符合题目要求。错误。

F. Use AWS Key Management Service (AWS KMS) for key management. Create an S3 bucket policy to deny any PutObject command with a condition for x-amz-server-side-encryption.

分析：使用AWS KMS进行密钥管理，并通过S3存储桶策略强制服务端加密，符合题目中“数据必须加密在静止时”的要求。正确。

▼ 60

▼ 英文:

A security engineer is working with a development team to design a supply chain application that stores sensitive inventory data in an Amazon S3 bucket. The application will use an AWS Key Management Service (AWS KMS) customer managed key to encrypt the data in Amazon S3.

The inventory data in Amazon S3 will be shared with hundreds of vendors. All vendors will use AWS principals from their own AWS accounts to access the data in Amazon S3. The vendor list might change weekly. The security engineer needs to find a solution that supports cross-account access.

Which solution is the MOST operationally efficient way to manage access control for the customer managed key?

- A. Use KMS grants to manage key access. Programmatically create and revoke grants to manage vendor access.
- B. Use an IAM role to manage key access. Programmatically update the IAM role policies to manage vendor access.
- C. Use KMS key policies to manage key access. Programmatically update the KMS key policies to manage vendor access.
- D. Use delegated access across AWS accounts by using IAM roles to manage key access. Programmatically update the IAM trust policy to manage cross-account vendor access.

▼ 中文:

一位安全工程师正在与开发团队合作设计一个供应链应用程序，该应用程序将敏感的库存数据存储在 Amazon S3 存储桶中。该应用程序将使用 AWS Key Management Service (AWS KMS) 客户托管密钥来加密 Amazon S3 中的数据。

Amazon S3 中的库存数据将与数百个供应商共享。所有供应商将使用来自其自身 AWS 账户的 AWS 主体来访问 Amazon S3 中的数据。供应商列表可能每周都会发生变化。安全工程师需要找到一种支持跨账户访问的解决方案。

哪种解决方案是管理客户托管密钥访问控制最具操作效率的方式？

- A. 使用 KMS 授权来管理密钥访问。以编程方式创建和撤销授权来管理供应商访问。
- B. 使用 IAM 角色来管理密钥访问。以编程方式更新 IAM 角色策略来管理供应商访问。
- C. 使用 KMS 密钥策略来管理密钥访问。以编程方式更新 KMS 密钥策略来管理供应商访问。
- D. 通过使用 IAM 角色在 AWS 账户之间使用委托访问来管理密钥访问。以编程方式更新 IAM 信任策略来管理跨账户供应商访问。

▼ 答案:

A

1. 考察的知识点

Amazon S3 数据加密与 AWS KMS 的集成。

跨账户访问控制的最佳实践。

如何使用 KMS 授权 (Grants)、IAM 角色、KMS 密钥策略等方式管理密钥访问。

操作效率与动态管理的能力。

2. 选项分析

A. 使用 KMS 授权来管理密钥访问。以编程方式创建和撤销授权来管理供

应商访问。

正确：KMS 授权 (Grants) 是一种轻量级的方式，可以动态地为特定 AWS 主体（如供应商账户中的 IAM 用户或角色）授予对 KMS 密钥的访问权限。

操作效率高：可以通过编程方式快速创建和撤销授权，无需修改复杂的策略。

支持动态变化的供应商列表：每次供应商列表更新时，只需调整授权即可，无需修改密钥策略或 IAM 策略。

B. 使用 IAM 角色来管理密钥访问。以编程方式更新 IAM 角色策略来管理供应商访问。

错误：IAM 角色策略的管理复杂度较高，尤其是当供应商列表频繁变化时，更新策略可能会变得繁琐。

不适合动态变化的场景：IAM 角色策略的更新需要更多的操作步骤，且可能会影响其他依赖该角色的服务。

C. 使用 KMS 密钥策略来管理密钥访问。以编程方式更新 KMS 密钥策略来管理供应商访问。

错误：虽然 KMS 密钥策略可以实现跨账户访问，但其管理复杂度较高，尤其是在供应商列表频繁变化的情况下。

操作效率低：每次更新密钥策略都需要重新定义策略文档，可能会导致错误或不一致。

D. 通过使用 IAM 角色在 AWS 账户之间使用委托访问来管理密钥访问。以编程方式更新 IAM 信任策略来管理跨账户供应商访问。

错误：虽然 IAM 信任策略可以实现跨账户访问，但其管理复杂度较高，尤其是在供应商列表频繁变化的情况下。

不适合动态变化的场景：信任策略的更新需要更多的操作步骤，且可能会影响其他依赖该角色的服务。

▼ 61

▼ 英文:

A company runs an application on a fleet of Amazon EC2 instances behind an Application Load Balancer (ALB). A security engineer needs to provide secure access to the application without requiring the use of a VPN. Users should be able to access the application only when they meet specific security conditions, including a defined device posture.

Which solution will meet these requirements?

- A. Create an AWS WAF web ACL. Configure a custom response to block traffic that does not align with the defined device posture.
- B. Configure AWS Verified Access. Add the application by creating an endpoint for the ALB.
- C. Configure Amazon Verified Permissions. Use a policy-based access control (PBAC) policy to perform authorization.
- D. Configure Amazon Verified Permissions. Add the application by creating an endpoint for the ALB.

▼ 中文:

一家公司在一个位于Application Load Balancer (ALB)后面的Amazon EC2实例群组上运行一个应用程序。一名安全工程师需要提供对该应用程序的安全访问，而无需使用VPN。用户只有在满足特定的安全条件（包括定义的设备状态）时才能访问该应用程序。

哪种解决方案可以满足这些需求？

- A. 创建一个AWS WAF web ACL。配置一个自定义响应以阻止不符合定义设备状态的流量。
- B. 配置AWS Verified Access。通过为ALB创建一个端点来添加应用程序。
- C. 配置Amazon Verified Permissions。使用基于策略的访问控制 (PBAC) 策略进行授权。
- D. 配置Amazon Verified Permissions。通过为ALB创建一个端点来添加应用程序。

▼ 答案:

B

1. 考察的知识点

本题主要考察AWS Verified Access的功能和使用场景。

涉及安全访问控制、设备状态检查以及如何在不使用VPN的情况下提供安全访问。

2. 选项分析

A. Create an AWS WAF web ACL. Configure a custom response to block traffic that does not align with the defined device posture.

错误：AWS WAF主要用于防护Web应用免受常见的攻击（如SQL注入、跨站脚本攻击等），但它无法直接检查设备状态或定义设备姿态。

虽然可以通过自定义规则阻止某些流量，但无法满足题目中“定义设备姿

态”的要求。

B. Configure AWS Verified Access. Add the application by creating an endpoint for the ALB.

正确：AWS Verified Access是专门设计用于提供基于设备状态和用户身份的安全访问控制的服务。

它允许用户在[不使用VPN的情况下安全访问应用程序，并支持设备姿态检查](#)。

通过为ALB创建一个端点，可以将应用程序集成到Verified Access中，从而满足题目要求。

C. Configure Amazon Verified Permissions. Use a policy-based access control (PBAC) policy to perform authorization.

错误：Amazon Verified Permissions是一个用于管理和执行基于策略的访问控制的服务，但它不支持设备姿态检查。

虽然PBAC可以定义复杂的授权规则，但它无法满足题目中关于设备状态的要求。

D. Configure Amazon Verified Permissions. Add the application by creating an endpoint for the ALB.

错误：与选项C类似，Amazon Verified Permissions不支持设备姿态检查。

创建ALB端点并不能解决题目中关于设备状态的要求。

▼ 62

▼ 英文:

A company needs to retain data that is stored in Amazon CloudWatch Logs log groups. The company must retain this data for 90 days. The company must receive notification in AWS Security Hub when log group retention is not compliant with this requirement. Which solution will provide the appropriate notification?

- A. Create a Security Hub custom action to assess the log group retention period.
- B. Create a data protection policy in CloudWatch Logs to assess the log group retention period.
- C. Create a Security Hub automation rule. Configure the automation rule to assess the log group retention period.
- D. Use the AWS Config managed rule that assesses the log group retention period. Ensure that AWS Config integration is enabled in Security Hub.

▼ 中文:

一家公司需要保留存储在 Amazon CloudWatch Logs 日志组中的数据。公司必须将这些数据保留 90 天。公司必须在日志组保留期不符合此要求时，在 AWS Security Hub 中接收通知。

哪种解决方案可以**提供适当的通知**？

- A. 创建一个 Security Hub 自定义操作以评估日志组保留期。
- B. 在 CloudWatch Logs 中创建一个数据保护策略以评估日志组保留期。
- C. 创建一个 Security Hub 自动化规则。配置自动化规则以评估日志组保留期。
- D. 使用 AWS Config 托管规则来评估日志组保留期。确保在 Security Hub 中启用了 AWS Config 集成。

▼ 答案:

D

1. 考察的知识点

本题考察的是AWS Config与AWS Security Hub的集成使用，以及如何通过托管规则评估资源的合规性。

涉及CloudWatch Logs的日志保留策略和通知机制。

2. 选项分析

A. 创建一个 Security Hub 自定义操作以评估日志组保留期。

错误：Security Hub的自定义操作主要用于手动触发操作，而不是自动评估资源的合规性。

此选项未提及如何具体实现自动化评估和通知功能。

B. 在 CloudWatch Logs 中创建一个数据保护策略以评估日志组保留期。

错误：CloudWatch Logs的数据保护策略主要用于**保护日志数据免受意外删除或覆盖**，而不是用于评估日志组的保留期。

此选项与题目要求的通知机制无关。

C. 创建一个 Security Hub 自动化规则。配置自动化规则以评估日志组保留期。

错误：Security Hub的自动化规则可以用于处理发现的安全问题，但它不能直接评估资源的合规性。

此选项未提及如何具体实现对日志组保留期的评估。

D. 使用 AWS Config 托管规则来评估日志组保留期。确保在 Security Hub 中启用了 AWS Config 集成。

正确：AWS Config提供托管规则，可以自动评估资源的合规性，包括 CloudWatch Logs的日志保留期。

Security Hub可以与AWS Config集成，从而接收合规性评估结果并生成通知。

▼ 63

▼ 英文:

A company needs to prevent Amazon S3 objects from being shared with IAM identities outside of the company's organization in AWS Organizations. A security engineer is creating and deploying an SCP to accomplish this goal. The company has enabled the S3 Block Public Access feature on all of its S3 buckets. What should the SCP do to meet these requirements?

- A. Deny the S3:* action with a Condition element that comprises an operator of StringNotEquals, a key of aws:ResourceOrgID, and a value of S{aws:PrincipalOrgID}.
- B. Deny the S3:PutAccountPublicAccessBlock action with a Condition element that comprises an operator of StringLike, a key of aws:PrincipalArn, and the values of the external IAM principals.
- C. Allow the S3:* action with a Condition element that comprises an operator of StringNotEquals, a key of aws:PrincipalOrgID, and a value of S{aws:PrincipalOrgID}.
- D. Deny the S3:* action with a Condition element that comprises an operator of StringLike, a key of aws:PrincipalArn, and the values of the external IAM principal

▼ 中文:

一家公司需要防止 Amazon S3 对象被共享给 AWS Organizations 中公司组织外的 IAM 身份。一位安全工程师正在创建并部署一个 SCP 来实现这一目标。公司已经在其所有 S3 存储桶上启用了 S3 Block Public Access 功能。SCP 应该如何满足这些要求？

- A.使用包含以下内容的 Condition 元素拒绝 S3:* 操作：运算符为 StringNotEquals，键为 aws:ResourceOrgID，值为S{aws:PrincipalOrgID}。
- B.使用包含以下内容的 Condition 元素拒绝 S3:PutAccountPublicAccessBlock 操作：运算符为 StringLike，键为 aws:PrincipalArn，值为外部 IAM 主体。
- C.使用包含以下内容的 Condition 元素允许 S3:* 操作：运算符为 StringNotEquals，键为 aws:PrincipalOrgID，值为 S{aws:PrincipalOrgID}。

D.使用包含以下内容的 Condition 元素拒绝 S3:* 操作：运算符为 StringLike，键为 aws:PrincipalArn，值为外部 IAM 主体。

▼ 答案:

A

1. 考察的知识点

本题考察的是 AWS Organizations 中的服务控制策略 (SCP) 的使用，以及如何通过 SCP 限制 Amazon S3 对象的访问权限。

重点知识点包括 SCP 的语法、条件元素 (Condition)、操作符 (Operator)、以及如何使用 aws:ResourceOrgID 和aws:PrincipalOrgID 来限制跨组织的访问。

2. 选项分析

A. Deny the S3:* action with a Condition element that comprises an operator of StringNotEquals, a key of aws:ResourceOrgID, and a value of S{aws PrincipalOrgID}.

此选项通过 SCP 拒绝所有 S3 操作 (S3:)，并使用条件元素检查资源的组织 ID (aws:ResourceOrgID) 是否与主体的组织 ID (aws:PrincipalOrgID) 不匹配。

这种方式确保只有属于同一 AWS Organizations 的 IAM 身份可以访问 S3 对象，符合题目要求。

此选项是正确的。

B. Deny the S3:PutAccountPublicAccessBlock action with a Condition element that comprises an operator of StringLike, a key of aws:PrincipalArn, and the values of the external IAM principals.

此选项试图通过拒绝 S3:PutAccountPublicAccessBlock 操作来限制外部 IAM 身份，但这与题目要求无关。

题目要求限制 S3 对象的访问，而不是限制公共访问块的设置。

此选项是错误的。

C. Allow the S3: action with a Condition element that comprises an operator of StringNotEquals, a key of aws:PrincipalOrgID, and a value of S{aws:PrincipalOrgID}.

此选项试图允许所有 S3 操作 (S3:)，但仅在主体的组织 ID 不匹配时应用条件。

这种逻辑与题目要求不符，因为题目要求阻止外部 IAM 身份访问，而不是允许操作。

此选项是错误的。

D. Deny the S3: action with a Condition element that comprises an operator of StringLike, a key of aws:PrincipalArn, and the

values of the external IAM principals.

此选项试图通过 SCP 拒绝所有 S3 操作 (S3:*)，并使用条件元素检查主体 ARN (aws:PrincipalArn) 是否匹配外部 IAM 身份。

虽然可以限制外部 IAM 身份，但这种方式需要明确列出所有外部 IAM 身份 ARN，管理起来非常复杂且不符合题目要求。

此选项是错误的。

▼ 64

▼ 英文:

A security engineer is implementing authentication for a multi-account environment by using federated access with SAML 2.0.

The security engineer has configured AWS IAM Identity Center as an identity provider (IdP). The security engineer also has created IAM roles to grant access to the AWS accounts.

A federated user reports an authentication failure when the user attempts to authenticate with the new system.

What should the security engineer do to troubleshoot this issue in the MOST operationally efficient way?

A. Review the SAML IdP logs to identify errors. Check AWS CloudTrail to verify the API calls that the user made.

B. Review the SAML IdP logs to identify errors. Use the IAM policy simulator to validate access to the IAM roles.

C. Use IAM access advisor to review recent service access. Use the IAM policy simulator to validate access to the IAM roles.

D. Recreate the SAML IdP in a separate account to confirm the behavior that the user is experiencing.

▼ 中文:

一名安全工程师正在通过使用支持SAML 2.0的联合访问为多账户环境实施身份验证。安全工程师已将AWS IAM Identity Center配置为身份提供方 (IdP)。安全工程师还创建了IAM角色以授予对AWS账户的访问权限。

一名联合用户报告在尝试使用新系统进行身份验证时发生身份验证失败。安全工程师应该采取什么措施以最具操作效率的方式排查此问题？

A. 查看SAML IdP日志以识别错误。检查AWS CloudTrail以验证用户发出的API调用。

B. 查看SAML IdP日志以识别错误。使用IAM策略模拟器验证对IAM角色的访

问权限。

C. 使用IAM访问顾问查看最近的服务访问情况。使用IAM策略模拟器验证对IAM角色的访问权限。

D. 在一个单独的账户中重新创建SAML IdP以确认用户遇到的行为。

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS IAM Identity Center（原AWS SSO）与SAML 2.0集成的故障排查能力。

涉及SAML IdP日志分析、CloudTrail API调用验证，以及IAM策略模拟器的使用。

2. 选项分析

A. Review the SAML IdP logs to identify errors. Check AWS CloudTrail to verify the API calls that the user made.

正确：SAML IdP日志可以帮助识别身份验证失败的原因，例如配置错误或用户凭证问题。

正确：CloudTrail可以验证用户是否成功发起了API调用，帮助确认问题是否出在身份验证阶段或后续授权阶段。

此选项提供了全面的故障排查方法，且操作效率较高。

B. Review the SAML IdP logs to identify errors. Use the IAM policy simulator to validate access to the IAM roles.

部分正确：SAML IdP日志可以帮助识别身份验证问题。

错误：IAM策略模拟器主要用于验证IAM策略的权限，而不是直接用于排查身份验证问题。此选项忽略了CloudTrail的作用。

C. Use IAM access advisor to review recent service access. Use the IAM policy simulator to validate access to the IAM roles.

错误：IAM访问顾问（Access Advisor）用于查看用户最近访问的服务，与身份验证故障排查无关。

错误：IAM策略模拟器无法直接解决身份验证问题。

D. Recreate the SAML IdP in a separate account to confirm the behavior that the user is experiencing.

错误：重新创建SAML IdP在另一个账户中是一个低效且不必要的操作，无法直接解决当前问题。

▼ 65

▼ 英文:

A company stores sensitive data in an Amazon S3 bucket. The company encrypts the data at rest by using server-side encryption with Amazon S3 managed keys (SSE-S3).

A security engineer must prevent any modifications to the data in the S3 bucket.

Which solution will meet this requirement?

- A. Configure S3 bucket policies to deny DELETE and PUT object permissions.
- B. Configure S3 Object Lock in compliance mode with S3 bucket versioning enabled. °
- C. Change the encryption on the S3 bucket to use AWS Key Management Service (AWS KMS) customer managed keys.
- D. Configure the S3 bucket with multi-factor authentication (MFA) delete protection.

▼ 中文:

一家公司将敏感数据存储在一个 Amazon S3 bucket 中。公司使用服务器端加密和 Amazon S3 管理密钥 (SSE-S3) 对静态数据进行加密。

一名安全工程师必须防止对 S3 bucket 中的数据进行任何修改。

哪种解决方案可以满足此要求？

- A.配置 S3 bucket 策略以拒绝 DELETE 和 PUT 对象权限。
- B. 在启用 S3 bucket 版本控制的情况下，以合规模式配置 S3 Object Lock。
- C. 将 S3 bucket 的加密更改为使用 AWS Key Management Service (AWS KMS) 客户管理密钥。
- D. 使用多重身份验证 (MFA) 删除保护配置 S3 bucket。

▼ 答案:

B

1. 考察的知识点

Amazon S3 数据保护机制，包括加密、访问控制和防篡改功能。

S3 Object Lock 的功能及其合规模式的应用。

S3 bucket 版本控制的作用。

2. 选项分析

A. 配置 S3 bucket 策略以拒绝 DELETE 和 PUT 对象权限。

分析：通过 bucket 策略可以限制 DELETE 和 PUT 操作，但这并不能完全防止数据被篡改，因为管理员仍然可以修改策略或绕过限制。

结论：错误。

B. 在启用 S3 bucket 版本控制的情况下，以合规模式配置 S3 Object Lock。

分析：S3 Object Lock 的合规模式可以防止任何用户（包括管理员）删除或修改对象，且需要启用版本控制以支持此功能。

结论：正确。

C. 将 S3 bucket 的加密更改为使用 AWS Key Management Service (AWS KMS) 客户管理密钥。

分析：更改加密方式可以增强数据保护，但这与防止数据修改无关。加密仅保护数据的机密性，而不是完整性。

结论：错误。

D. 使用多重身份验证 (MFA) 删除保护配置 S3 bucket。

分析：MFA 删除保护可以防止未经授权的删除操作，但它不能防止 PUT 操作或其他形式的修改。

结论：错误。

▼ 66

▼ 英文:

A company is developing a new serverless application that uses AWS Lambda functions. The company uses AWS CloudFormation to deploy the Lambda functions.

The company's developers are trying to debug a Lambda function that is deployed. The developers cannot debug the Lambda function because the Lambda function is not logging its output to Amazon CloudWatch Logs.

Which combination of steps should a security engineer take to resolve this issue? (Choose two.)

A. Check the role that is defined in the CloudFormation template and is passed to the Lambda function. Ensure that the role has a trust policy that allows the sts:AssumeRole action by the service principal lambda [amazonaws.com](https://www.amazonaws.com)

B. Check the execution role that is configured in the CloudFormation template for the Lambda function. Ensure that the execution role has the necessary permissions to write to CloudWatch Logs.

C. Check the Lambda function configuration in the CloudFormation template. Ensure that the Lambda function has an AWS X-Ray tracing configuration that is set to Active mode or PassThrough mode.

D. Check the resource policy that is configured in the CloudFormation template for the Lambda function. Ensure that the resource policy has the necessary permissions to write to CloudWatch Logs.

E. Check the role that the developers use to debug the Lambda function. Ensure that the role has a trust policy that allows the sts:AssumeRole action by the service principal [lambda.amazonaws.com](https://docs.aws.amazon.com/lambda/latest/dg/lambda-roles.html).

▼ 中文:

一家公司正在开发一个新的无服务器应用程序，该应用程序使用 AWS Lambda 函数。该公司使用 AWS CloudFormation 来部署 Lambda 函数。该公司的开发人员正在尝试调试已部署的 Lambda 函数。开发人员无法调试 Lambda 函数，因为 Lambda 函数没有将其输出记录到 Amazon CloudWatch Logs。

安全工程师应采取哪些步骤组合来解决此问题？（选择两个。）

A. 检查在 CloudFormation 模板中定义并传递给 Lambda 函数的角色。确保该角色具有允许服务主体 [lambda.amazonaws.com](https://docs.aws.amazon.com/lambda/latest/dg/lambda-roles.html) 执行 sts:AssumeRole 操作的信任策略。

B. 检查在 CloudFormation 模板中为 Lambda 函数配置的执行角色。确保执行角色具有写入 CloudWatch Logs 的必要权限。

C. 检查 CloudFormation 模板中的 Lambda 函数配置。确保 Lambda 函数具有设置为 Active 模式或 PassThrough 模式的 AWS X-Ray 跟踪配置。

D. 检查在 CloudFormation 模板中为 Lambda 函数配置的资源策略。确保资源策略具有写入 CloudWatch Logs 的必要权限。

E. 检查开发人员用于调试 Lambda 函数的角色。确保该角色具有允许服务主体 [lambda.amazonaws.com](https://docs.aws.amazon.com/lambda/latest/dg/lambda-roles.html) 执行 sts:AssumeRole 操作的信任策略。

▼ 答案:

AB

1. 考察的知识点

Lambda 函数的执行角色配置与权限管理。

CloudFormation 模板中角色的信任策略与权限设置。

CloudWatch Logs 的写入权限。

2. 选项分析

A. 检查在 CloudFormation 模板中定义并传递给 Lambda 函数的角色。确保该角色具有允许服务主体

[lambda.amazonaws.com](#) 执行 sts:AssumeRole 操作的信任策略。

正确：Lambda 函数需要一个 IAM 角色，并且该角色必须具有信任策略，允许服务主体 [lambda.amazonaws.com](#) 执行 sts:AssumeRole 操作。这是 Lambda 函数能够运行的基本要求。

B. 检查在 CloudFormation 模板中为 Lambda 函数配置的执行角色。确保执行角色具有写入 CloudWatch Logs 的必要权限。

正确：Lambda 函数的执行角色需要具备写入 CloudWatch Logs 的权限（例如 logs:CreateLogGroup 和 logs:PutLogEvents），否则无法将日志输出到 CloudWatch Logs。

C. 检查 CloudFormation 模板中的 Lambda 函数配置。确保 Lambda 函数具有设置为 Active 模式或 PassThrough 模式的 AWS X-Ray 跟踪配置。

错误：AWS X-Ray 跟踪配置与日志写入到 CloudWatch Logs 无关。X-Ray 用于分布式跟踪，而不是日志记录。

D. 检查在 CloudFormation 模板中为 Lambda 函数配置的资源策略。确保资源策略具有写入 CloudWatch Logs 的必要权限。

错误：Lambda 函数的日志写入权限是通过执行角色的 IAM 策略配置，而不是通过资源策略配置。

E. 检查开发人员用于调试 Lambda 函数的角色。确保该角色具有允许服务主体 [lambda.amazonaws.com](#) 执行 sts:AssumeRole 操作的信任策略。

错误：开发人员的角色与 Lambda 函数的执行角色无关。Lambda 函数的运行依赖于其自身的执行角色，而不是开发人员的角色。

▼ 67

▼ 英文:

A company uses a collaboration application. A security engineer needs to configure automated alerts from AWS Security Hub in the us-west-2 Region for the application. The security engineer wants to receive an alert in a channel in the application every time Security Hub receives a new finding.

The security engineer creates an AWS Lambda function to convert the

message to the format that the application requires. The Lambda function also sends the message to the application's API. The security engineer configures a corresponding Amazon EventBridge rule that specifies the Lambda function as the target. After the EventBridge rule is implemented, the channel begins to constantly receive alerts from Security Hub. Many of the alerts are Amazon Inspector alerts that do not require any action. The security engineer wants to stop the Amazon Inspector alerts.

Which solution will meet this requirement with the LEAST operational effort?

- A. Update the Lambda function code to find pattern matches of events from Amazon Inspector and to suppress the findings.
- B. Create a Security Hub custom action that automatically sends findings from all services except Amazon Inspector to the EventBridge event bus
- C. Modify the value of the ProductArn attribute in the event pattern of the EventBridge rule to "anything-but":
["arn:aws:securityhub:us-west-2::product/aws/inspector"].
- D. Create an Amazon Simple Notification Service (Amazon SNS) topic to send messages to the application. Set a filter policy on the topic subscriptions to reject any messages that contain the product/aws/inspector string.

▼ 中文:

一家公司使用一个协作应用程序。安全工程师需要在 us-west-2 区域的 AWS Security Hub 中为该应用程序配置自动警报。安全工程师希望每次 Security Hub 接收到新的发现时，都能在应用程序的一个频道中收到警报。

安全工程师创建了一个 AWS Lambda 函数，将消息转换为应用程序所需的格式。该 Lambda 函数还将消息发送到应用程序的 API。安全工程师配置了一个相应的 Amazon EventBridge 规则，并将 Lambda 函数指定为目标。在实施 EventBridge 规则后，该频道开始不断从 Security Hub 接收警报。许多警报是来自 Amazon Inspector 的警报，这些警报不需要任何操作。安全工程师希望停止接收 Amazon Inspector 的警报。

哪种解决方案能够以**最少的操作工作量满足此要求**？

- A.更新 Lambda 函数代码，以匹配来自 Amazon Inspector 的事件模式，并抑制这些发现。

- B. 创建一个 Security Hub 自定义操作，自动将来自所有服务（除 Amazon Inspector 外）的发现发送到 EventBridge 事件总线。
- C. 修改 EventBridge 规则事件模式中 ProductArn 属性的值为 "anything-but":["arn:aws:securityhub:us-west2::product/aws/inspector"]。
- D. 创建一个 Amazon Simple Notification Service (Amazon SNS) 主题以将消息发送到应用程序。在主题订阅上设置过滤策略，以拒绝任何包含 product/aws/inspector 字符串的消息。

▼ 答案:

C

1. 考察的知识点

Amazon EventBridge规则的事件模式过滤功能。
AWS Security Hub与Amazon Inspector的集成。
如何通过最小化操作来优化事件处理流程。

2. 选项分析

A. 更新 Lambda 函数代码，以匹配来自 Amazon Inspector 的事件模式，并抑制这些发现。

错误：虽然可以通过修改Lambda函数代码来过滤Amazon Inspector的事件，但这种方法需要额外的开发工作和维护成本，违背了“最少操作努力”的要求。

B. 创建一个 Security Hub 自定义操作，自动将来自所有服务（除 Amazon Inspector 外）的发现发送到 EventBridge事件总线。

错误：Security Hub的自定义操作需要手动配置，并且无法直接实现对特定服务的排除。这种方法复杂且不符合“最少操作努力”的要求。

C. 修改 EventBridge 规则事件模式中 ProductArn 属性的值为 "anything-but":["arn:aws:securityhub:us-west2::product/aws/inspector"]。

正确：EventBridge规则支持事件模式过滤，可以通过“anything-but”条件轻松排除Amazon Inspector的事件。这种方法直接且无需额外开发工作，符合“最少操作努力”的要求。

D. 创建一个 Amazon SNS 主题以将消息发送到应用程序。在主题订阅上设置过滤策略，以拒绝任何包含product/aws/inspector 字符串的消息。

错误：虽然SNS过滤策略可以实现类似的功能，但需要额外创建SNS主题和配置订阅过滤，增加了操作复杂性，不符合“最少操作努力”的要求。

▼ 68

▼ 英文:

A company has an organization in AWS Organizations. The organization consists of multiple OUs. The company must prevent IAM principals from outside the organization from accessing the organization's Amazon S3 buckets. The solution must not affect the existing access that the OUs have to the S3 buckets. Which solution will meet these requirements?

- A. Configure S3 Block Public Access for all S3 buckets.
- B. Configure S3 Block Public Access for all AWS accounts.
- C. Deploy an SCP that includes the "aws:ResourceOrgPaths": "\${aws:PrincipalOrgPaths}" condition.
- D. Deploy an SCP that includes the "aws:ResourceOrgID": "\${aws:PrincipalOrgID}" condition.

▼ 中文:

一家公司在 AWS Organizations 中有一个组织。该组织由多个 OU 组成。公司必须防止组织外部的 IAM 主体访问组织的 Amazon S3 存储桶。解决方案不得影响 OU 对 S3 存储桶的现有访问权限。哪种解决方案可以满足这些要求？

- A. 为所有 S3 存储桶配置 S3 Block Public Access。
- B. 为所有 AWS 账户配置 S3 Block Public Access。
- C. 部署一个包含 "aws:ResourceOrgPaths": "\${aws:PrincipalOrgPaths}" 条件的 SCP。
- D. 部署一个包含 "aws:ResourceOrgID": "\${aws:PrincipalOrgID}" 条件的 SCP。

▼ 答案:

D

1. 考察的知识点

本题考察的是 AWS Organizations 中的服务控制策略（SCP）的使用，以及如何限制 IAM 主体的访问权限。同时涉及 Amazon S3 的访问控制和跨账户访问的管理。

2. 选项分析

A. 配置 S3 Block Public Access 为所有 S3 存储桶

错误：S3 Block Public Access 主要用于防止公共访问，而不是限制 IAM 主体的跨账户访问。

此选项无法满足题目要求，因为它不会限制 IAM 主体来自组织外部的访问。

B. 配置 S3 Block Public Access 为所有 AWS 账户

错误：S3 Block Public Access是针对存储桶级别的设置，而不是针对账户级别的设置。

此选项无法实现题目要求的限制IAM主体的跨账户访问。

C. 部署一个包含 "aws:ResourceOrgPaths":

"\${aws:PrincipalOrgPaths}" 条件的 SCP

错误：虽然"aws:ResourceOrgPaths"可以用于限制资源路径，但它并不是最佳选择来限制IAM主体的跨账户访问。

此选项无法直接满足题目要求，因为它没有明确限制IAM主体是否属于组织。

D. 部署一个包含 "aws:ResourceOrgID": "\${aws:PrincipalOrgID}" 条件的 SCP

正确：此选项使用了"aws:ResourceOrgID"和"aws:PrincipalOrgID"条件，确保只有属于同一组织的IAM主体可以访问资源。此解决方案直接满足题目要求，同时不会影响组织内部的访问权限。

▼ 69

▼ 英文:

A company needs to implement data lifecycle management for Amazon RDS snapshots. The company will use AWS Backup to manage the snapshots.

The company must retain RDS automated snapshots for 5 years and will use Amazon S3 for long-term archival storage.

Which solution will meet these requirements?

A. Use AWS Backup to apply a 5-year retention tag to the RDS snapshots.

B. Enable versioning on the S3 bucket that AWS Backup uses for the RDS snapshots. Configure a 5-year retention period.

C. Create an S3 Lifecycle policy. Include a 5-year retention period for the S3 bucket that AWS Backup uses for the RDS snapshots.

D. Create a backup plan in AWS Backup. Configure a 5-year retention period. Most Voted

▼ 中文:

一家公司需要为 Amazon RDS 快照实施数据生命周期管理。该公司将使用 AWS Backup 来管理快照。

该公司必须保留 RDS 自动快照 5 年，并将使用 Amazon S3 进行长期归档存

储。

哪种解决方案可以满足这些要求？

- A. 使用 AWS Backup 为 RDS 快照应用 5 年保留标签。
- B. 在 AWS Backup 用于 RDS 快照的 S3 存储桶上启用版本控制。配置 5 年保留期。
- C. 创建一个 S3 生命周期策略。为 AWS Backup 用于 RDS 快照的 S3 存储桶包含 5 年保留期。
- D. 在 AWS Backup 中创建一个备份计划。配置 5 年保留期。

▼ 答案:

D

1. 考察的知识点

本题考察的是AWS Backup的功能和配置，包括如何使用AWS Backup管理Amazon RDS快照的生命周期。

涉及的知识点包括备份计划的创建、快照的生命周期管理，以及如何配置长期存储和保留策略。

2. 选项分析

A. 使用 AWS Backup 为 RDS 快照应用 5 年保留标签。

错误：AWS Backup不通过“标签”来管理快照的生命周期，而是通过备份计划和保留策略来实现。

B. 在 AWS Backup 用于 RDS 快照的 S3 存储桶上启用版本控制。配置 5 年保留期。

错误：AWS Backup管理的RDS快照并不直接存储在S3中，且版本控制与快照生命周期管理无关。

C. 创建一个 S3 生命周期策略。为 AWS Backup 用于 RDS 快照的 S3 存储桶包含 5 年保留期。

错误：AWS Backup管理的RDS快照并不直接依赖S3生命周期策略。

AWS Backup有自己的保留策略，独立于S3生命周期管理。

D. 在 AWS Backup 中创建一个备份计划。配置 5 年保留期。

正确：AWS Backup允许用户创建备份计划，并配置快照的保留策略。通过备份计划可以实现5年的保留需求。

▼ 70

▼ 英文:

A company's security policy requires all Amazon EC2 instances to use the Amazon Time Sync Service. AWS CloudTrail trails are

enabled in all of the company's AWS accounts. VPC flow logs are enabled for all VPCs.

A security engineer must identify any EC2 instances that attempt to use Network Time Protocol (NTP) servers on the internet.

Which solution will meet these requirements?

- A. Monitor CloudTrail logs for API calls to non-standard time servers.
- B. Monitor CloudTrail logs for API calls to the Amazon Time Sync Service.
- C. Monitor VPC flow logs for traffic to non-standard time servers.
- D. Monitor VPC flow logs for traffic to the Amazon Time Sync Service.

▼ 中文:

一家公司安全策略要求所有 Amazon EC2 实例使用 Amazon Time Sync Service。AWS CloudTrail trails 在公司所有的 AWS 账户中已启用。VPC flow logs 已在所有 VPC 中启用。

一名安全工程师必须识别任何尝试使用互联网上的 Network Time Protocol (NTP) 服务器的 EC2 实例。

哪种解决方案可以满足这些要求？

- A. 监控 CloudTrail 日志中针对非标准时间服务器的 API 调用。
- B. 监控 CloudTrail 日志中针对 Amazon Time Sync Service 的 API 调用。
- C. 监控 VPC flow logs 中针对非标准时间服务器的流量。
- D. 监控 VPC flow logs 中针对 Amazon Time Sync Service 的流量。

▼ 答案:

C

1. 考察的知识点

Amazon Time Sync Service的使用和配置。

VPC Flow Logs的功能和应用场景。

CloudTrail的功能和日志分析能力。

如何监控EC2实例的网络行为以确保符合安全策略。

2. 选项分析

A. Monitor CloudTrail logs for API calls to non-standard time servers.

CloudTrail主要用于记录API调用和管理操作，而不是直接监控网络流量。

EC2实例使用NTP服务器时不会通过API调用，因此无法通过CloudTrail日志检测到此行为。

此选项错误。

B. Monitor CloudTrail logs for API calls to the Amazon Time Sync Service.

Amazon Time Sync Service是EC2实例默认的时间同步服务，但使用此服务不涉及API调用。

CloudTrail无法记录EC2实例与时间服务器的网络交互，因此此选项不适合解决问题。

此选项错误。

C. Monitor VPC flow logs for traffic to non-standard time servers.

VPC Flow Logs可以记录网络流量，包括EC2实例与外部NTP服务器的通信。

通过分析VPC Flow Logs，可以识别出EC2实例是否尝试连接非标准时间服务器。

此选项正确。

D. Monitor VPC flow logs for traffic to the Amazon Time Sync Service.

Amazon Time Sync Service是AWS提供的标准时间服务器，符合公司的安全策略。

监控与Amazon Time Sync Service的流量没有意义，因为目标是识别非标准时间服务器的使用。此选项错误。

▼ 71

▼ 英文:

A company has a multi-account strategy that uses an organization in AWS Organizations with all features enabled. The company has enabled trusted access for AWS Account Management. New accounts are provisioned through AWS Control Tower Account Factory.

The company must ensure that all new accounts in the organization become AWS Security Hub member accounts.

Which solution will meet these requirements with the LEAST development effort?

A. Enable Security Hub in the organization's management account. Create an AWS Step Functions workflow. Create an

Amazon EventBridge rule to invoke the workflow when a CreateAccount event occurs.

B. Enable Security Hub in the organization's management account. Wait for all new accounts to complete automatic onboarding.

C. Enable Security Hub in the organization's management account. Create an AWS Lambda function to enable Security Hub for new accounts. Invoke the Lambda function by using an AWS Control Tower lifecycle event that occurs when a new account is provisioned.

D. Use the organization's management account to designate a Security Hub delegated administrator account. In the delegated administrator account, create a configuration policy to enable Security Hub. Associate the configuration policy with the organization root.

▼ 中文:

一家公司采用了多账户策略，使用启用了所有功能的 AWS Organizations 组织。该公司已为 AWS Account Management 启用了可信访问。新账户通过 AWS Control Tower Account Factory 进行创建。

该公司必须确保组织中的所有新账户成为 AWS Security Hub 成员账户。哪种解决方案能够以最少的工作量满足这些要求？

A. 在组织的管理账户中启用 Security Hub。创建一个 AWS Step Functions 工作流。当发生 CreateAccount 事件时，创建一个 Amazon EventBridge 规则以调用该工作流。

B. 在组织的管理账户中启用 Security Hub。等待所有新账户完成自动入驻。

C. 在组织的管理账户中启用 Security Hub。创建一个 AWS Lambda 函数以为新账户启用 Security Hub。使用 AWS Control Tower 生命周期事件在新账户创建时调用 Lambda 函数。

D. 使用组织的管理账户指定一个 Security Hub 委托管理员账户。在委托管理员账户中创建一个配置策略以启用使用组织的管理账户指定一个 Security Hub 委托管理员账户。在委托管理员账户中创建一个配置策略以启用 Security Hub。将配置策略与组织根关联。

▼ 答案:

D

1. 考察的知识点

AWS Organizations 的功能，包括委托管理员账户的使用。

AWS Security Hub的自动成员账户管理和配置策略。
如何通过最少的开发工作实现自动化和合规性。

2. 选项分析

A. 在组织的管理账户中启用 Security Hub。创建一个 AWS Step Functions 工作流。当发生 CreateAccount 事件时，创建一个 Amazon EventBridge 规则以调用该工作流。

正确性分析：此选项需要额外开发工作，包括创建 Step Functions 工作流和 EventBridge 规则。这增加了复杂性，不符合“最少开发工作”的要求。

结论：错误。

B. 在组织的管理账户中启用 Security Hub。等待所有新账户完成自动入驻。

正确性分析：此选项假设新账户会自动加入 Security Hub，但没有明确提到如何确保所有新账户都成为成员账户。缺乏主动性和控制。

结论：错误。

C. 在组织的管理账户中启用 Security Hub。创建一个 AWS Lambda 函数以为新账户启用 Security Hub。使用 AWS

Control Tower 生命周期事件在新账户创建时调用 Lambda 函数。

正确性分析：此选项需要额外开发工作，包括创建 Lambda 函数和处理 Control Tower 生命周期事件。这增加了复杂性，不符合“最少开发工作”的要求。

结论：错误。

D. 使用组织的管理账户指定一个 Security Hub 委托管理员账户。在委托管理员账户中创建一个配置策略以启用 Security Hub。将配置策略与组织根关联。

正确性分析：此选项利用了 AWS Organizations 的内置功能，通过委托管理员账户和配置策略实现自动化。这是最少开发工作且符合要求的解决方案。

结论：正确。

▼ 72

▼ 英文:

A company uses Amazon Elastic Kubernetes Service (Amazon EKS) clusters to run its Kubernetes-based applications. The company uses Amazon GuardDuty to protect the applications. EKS Protection is enabled in GuardDuty. However, the corresponding GuardDuty feature is not monitoring the Kubernetes-based applications.

Which solution will cause GuardDuty to monitor the Kubernetes-based applications?

- A. Enable VPC flow logs for the VPC that hosts the EKS clusters.
- B. Assign the CloudWatchEventsFullAccess AWS managed policy to the EKS clusters.
- C. Ensure that the AmazonGuardDutyFullAccess AWS managed policy is attached to the GuardDuty service role.
- D. Enable the control plane logs in Amazon EKS. Ensure that the logs are ingested into Amazon CloudWatch.

▼ 中文:

一家公司使用 Amazon Elastic Kubernetes Service (Amazon EKS) 集群来运行其基于 Kubernetes 的应用程序。该公司使用 Amazon GuardDuty 来保护这些应用程序。

在 GuardDuty 中启用了 EKS Protection。然而，相应的 GuardDuty 功能并未监控基于 Kubernetes 的应用程序。

哪种解决方案可以使 GuardDuty 监控基于 Kubernetes 的应用程序？

- A. 为托管 EKS 集群的 VPC 启用 VPC 流日志。
- B. 为 EKS 集群分配 CloudWatchEventsFullAccess AWS 托管策略。
- C. 确保 AmazonGuardDutyFullAccess AWS 托管策略已附加到 GuardDuty 服务角色。
- D. 在 Amazon EKS 中启用控制平面日志。确保日志已被导入到 Amazon CloudWatch。

▼ 答案:

D

A. Enable VPC flow logs for the VPC that hosts the EKS clusters.

错误：VPC 流日志主要用于监控网络流量，而不是 Kubernetes 控制平面活动。EKS Protection 需要控制平面日志，而非 VPC 流日志。

B. Assign the CloudWatchEventsFullAccess AWS managed policy to the EKS clusters.

错误：CloudWatchEventsFullAccess 策略与 GuardDuty 的 EKS Protection 功能无关。此策略用于管理 CloudWatch Events，而不是启用或监控 EKS 控制平面日志。

C. Ensure that the AmazonGuardDutyFullAccess AWS managed policy is attached to the GuardDuty service role.

错误：虽然 AmazonGuardDutyFullAccess 策略允许 GuardDuty 执行其功能，但它并不能直接启用或监控 EKS 控制平面日

志。此选项与问题无关。

D. Enable the control plane logs in Amazon EKS. Ensure that the logs are ingested into Amazon CloudWatch.

正确：GuardDuty 的 EKS Protection 功能依赖于 EKS 控制平面日志来监控 Kubernetes 应用程序。启用控制平面日志并将其导入到 CloudWatch 是正确的解决方案。

▼ 73

▼ 英文:

A company needs to log object-level activity in its Amazon S3 buckets. The company also needs to validate the integrity of the log file by using a digital signature.

Which solution will meet these requirements?

A. Create an AWS CloudTrail trail with log file validation enabled. Enable data events. Specify Amazon S3 as the data event type.

B. Create a new S3 bucket for S3 server access logs. Configure the existing S3 buckets to send their S3 server access logs to the new S3 bucket.

C. Create an Amazon CloudWatch Logs log group. Configure the existing S3 buckets to send their S3 server access logs to the log group.

D. Create a new S3 bucket for S3 server access logs with log file validation enabled. Enable data events. Specify Amazon S3 as the data event type.

▼ 中文:

一家公司需要记录其 Amazon S3 存储桶中的对象级活动。该公司还需要使用数字签名验证日志文件的完整性。

哪种解决方案可以满足这些要求？

A. 创建一个启用了日志文件验证的 AWS CloudTrail 跟踪。启用数据事件。将 Amazon S3 指定为数据事件类型。

B. 为 S3 服务器访问日志创建一个新的 S3 存储桶。配置现有的 S3 存储桶将其 S3 服务器访问日志发送到新的 S3 存储桶。

C. 创建一个 Amazon CloudWatch Logs 日志组。配置现有的 S3 存储桶将其 S3 服务器访问日志发送到该日志组。

D. 为启用了日志文件验证的 S3 服务器访问日志创建一个新的 S3 存储桶。启用数据事件。将 Amazon S3 指定为数据事件类型。

▼ 答案:

A

1. 考察的知识点

Amazon S3 数据事件的记录与日志管理。

AWS CloudTrail 的日志文件验证功能。

如何实现对象级别活动的记录和日志完整性验证。

2. 选项分析

A. Create an AWS CloudTrail trail with log file validation enabled.

Enable data events. Specify Amazon S3 as the data event type.

正确：AWS CloudTrail 支持记录对象级别的活动（数据事件），并且可以启用日志文件验证以确保日志的完整性。

启用数据事件并指定 Amazon S3 作为数据事件类型，可以满足记录对象级别活动的需求。

此选项完全符合题目要求。

B. Create a new S3 bucket for S3 server access logs. Configure the existing S3 buckets to send their S3 server access logs to the new S3 bucket.

错误：S3 服务器访问日志记录的是存储桶级别的活动，而不是对象级别的活动。

此选项无法满足记录对象级别活动的需求。

C. Create an Amazon CloudWatch Logs log group. Configure the existing S3 buckets to send their S3 server access logs to the log group.

错误：CloudWatch Logs 不支持直接记录 S3 对象级别的活动。

此选项无法满足题目要求的对象级别活动记录和日志完整性验证。

D. Create a new S3 bucket for S3 server access logs with log file validation enabled. Enable data events. Specify Amazon S3 as the data event type.

错误：S3 服务器访问日志记录的是存储桶级别的活动，而不是对象级别的活动。

虽然提到了启用数据事件，但与 S3 服务器访问日志结合使用并不符合题目要求。

▼ 74

▼ 英文:

A company has a new web-based account management system for an online game. Players create a unique username and

password to log in to the system.

The company has implemented an AWS WAF web ACL for the system. The web ACL includes the core rule set (CRS) AWS managed rule group on the Application Load Balancer that serves the system.

The company's security team finds that the system was the target of a credential stuffing attack. Credentials that were exposed in other breaches were used to try to log in to the system. The security team must implement a solution to reduce the chance of a successful credential stuffing attack in the future. The solution also must minimize impact on legitimate users of the system. Which combination of actions will meet these requirements? (Choose two.)

- A. Create an Amazon CloudWatch custom metric to analyze the number of successful login responses from a single IP address.
- B. Add the account takeover prevention (ATP) AWS managed rule group to the web ACL. Configure the rule group to inspect login requests to the system. Block any requests that have the `aws:waf:managed:aws:atp:signal:credential_compromised` label.
- C. Configure a default web ACL action that requires all users to solve a CAPTCHA puzzle when they log in.
- D. Implement IP-based match rules in the web ACL for any IP addresses that generate many successful login responses. Block any IP addresses that generate many successful logins.
- E. Create a custom block response that redirects users to a secure workflow to reset their password inside the system.

▼ 中文:

一家公司为一款在线游戏开发了一个新的基于网页的账户管理系统。玩家需要创建一个唯一的用户名和密码来登录该系统。

该公司为系统实施了一个AWS WAF web ACL。web ACL在服务该系统的Application Load Balancer上包含核心规则集（CRS）AWS托管规则组。公司的安全团队发现该系统成为了凭证填充攻击的目标。攻击者使用在其他数据泄露事件中暴露的凭证尝试登录系统。

安全团队必须实施一个解决方案，以减少未来凭证填充攻击成功的可能性。该解决方案还必须尽量减少对系统合法用户的影响。

以下哪种操作组合可以满足这些要求？（选择两项）

- A.创建一个Amazon CloudWatch自定义指标，用于分析来自单个IP地址的成功登录响应数量。
- B.将账户接管防护（ATP）AWS托管规则组添加到web ACL中。配置规则组以检查系统的登录请求。阻止任何带有aws:waf:managed:aws:atp:signal:credential_compromised标签的请求。
- C.配置一个默认web ACL操作，要求所有用户在登录时解决一个CAPTCHA谜题。
- D.在web ACL中为任何产生大量成功登录响应的IP地址实施基于IP的匹配规则。阻止任何产生大量成功登录的IP地址。
- E.创建一个自定义阻止响应，将用户重定向到系统内部的安全工作流程以重置其密码。

▼ 答案:

BE

1. 考察的知识点

AWS WAF的功能与规则组的使用，包括核心规则集（CRS）和账户接管防护（ATP）规则组。

如何应对凭证填充攻击（Credential Stuffing Attack）。

如何在保护系统安全的同时，尽量减少对合法用户的影响。

2. 选项分析

A.

错误：虽然监控成功登录响应可以帮助识别潜在的攻击行为，但仅创建CloudWatch自定义指标并不能直接阻止凭证填充攻击。

此选项没有直接提供防护措施，只是提供监控功能。

B.

正确：ATP规则组专门设计用于防止账户接管攻击，包括凭证填充攻击。

通过阻止带有

“aws:waf:managed:aws:atp:signal:credential_compromised”标签的请求，可以有效减少凭证填充攻击的成功率。

C.

错误：虽然CAPTCHA可以有效防止自动化攻击，但要求所有用户解决CAPTCHA会对合法用户造成较大的影响，违背了“最小化对合法用户影响”的要求。

D.

错误：基于IP地址的匹配规则可能会误伤合法用户，尤其是共享IP地址的用户。

此外，凭证填充攻击通常使用分布式IP地址，单纯依赖IP规则可能效果有限。

E.

正确：此选项提供了一个安全的解决方案，允许用户在检测到凭证泄露时重置密码，从而减少凭证填充攻击的成功率。

同时，这种方法对合法用户的影响较小，因为只有在检测到问题时才会触发重定向。

▼ 75

▼ 英文:

A company is running workloads on AWS. The workloads are in separate AWS accounts for development, testing, and production. All the company's developers can access the development account. A subset of the developers can access the testing account and the production account.

The company is spending too much time managing individual credentials for every developer across every environment. A security engineer must implement a more scalable solution that the company can use when a developer needs different access. The solution must allow developers to access resources across multiple accounts. The solution also must minimize credential sharing.

Which solution will meet these requirements?

A. Use AWS Identity and Access Management Access Analyzer to identify the permissions that the developers need on each account. Configure IAM Access Analyzer to automatically provision the correct access for each developer.

B. Create an Amazon Simple Workflow Service (Amazon SWF) workflow. Instruct the developers to use the workflow to request access to other accounts when additional access is necessary.

C. Create IAM roles in the testing account and production account. Add a policy that allows the sts:AssumeRole action to the roles. Create IAM roles in the development account for the developers who have access to the testing and production accounts. Add these roles to the trust policy on the new roles in the testing and production accounts.

D. Create service accounts in the testing environment and production environment. Give the access keys for the service accounts to developers who require access to the testing account and the production account. Rotate the access keys for the service accounts periodically.

▼ 中文:

一家公司正在 AWS 上运行工作负载。这些工作负载分别位于用于开发、测试和生产的独立 AWS 账户中。所有公司的开发人员都可以访问开发账户。一部分开发人员可以访问测试账户和生产账户。

公司在为每个开发人员管理每个环境的单独凭证方面花费了太多时间。安全工程师必须实施一个更具可扩展性的解决方案，以便公司在开发人员需要不同访问权限时使用。该解决方案必须允许开发人员访问多个账户中的资源。该解决方案还必须最大限度地减少凭证共享。

哪种解决方案可以满足这些要求？

A.使用 AWS Identity and Access Management Access Analyzer 来识别开发人员在每个账户中需要的权限。配置 IAM Access Analyzer 以自动为每个开发人员提供正确的访问权限。

B.创建一个 Amazon Simple Workflow Service (Amazon SWF) 工作流。指示开发人员在需要额外访问权限时使用该工作流来请求访问其他账户。

C.在测试账户和生产账户中创建 IAM 角色。向这些角色添加允许 sts:AssumeRole 操作的策略。在开发账户中为可以访问测试账户和生产账户的开发人员创建 IAM 角色。将这些角色添加到测试账户和生产账户中新角色的信任策略中。

D.在测试环境 and 生产环境中创建服务账户。将服务账户的访问密钥提供给需要访问测试账户和生产账户的开发人员。定期轮换服务账户的访问密钥。

▼ 答案:

C

1. 考察的知识点

跨账户访问的最佳实践：使用IAM角色和信任策略。

安全性：避免共享长期凭证，使用临时凭证（如STS）。

可扩展性：通过IAM角色实现动态权限管理。

2. 选项分析

A. 使用 AWS Identity and Access Management Access Analyzer 来识别开发人员在每个账户中需要的权限。配置 IAM Access Analyzer 以自动为每个开发人员提供正确的访问权限。

错误：IAM Access Analyzer的主要功能是分析权限和识别过度权限，而不是自动为用户配置访问权限。它无法直接解决跨账户访问问题。

B. 创建一个 Amazon Simple Workflow Service (Amazon SWF) 工作流。指示开发人员在需要额外访问权限时使用该工作流来请求访问其他账户。

错误：Amazon SWF是一个工作流服务，适用于任务自动化和编排，而不是权限管理。此选项无法直接解决跨账户访问问题，也不符合最小化凭证共享的要求。

C. 在测试账户和生产账户中创建 IAM 角色。向这些角色添加允许 sts:AssumeRole 操作的策略。在开发账户中为可以访问测试账户和生产账户的开发人员创建 IAM 角色。将这些角色添加到测试账户和生产账户中新角色的信任策略中。

正确：此选项使用IAM角色和STS临时凭证来实现跨账户访问。开发人员可以通过AssumeRole操作获取临时凭证，避免长期凭证的共享问题，同时信任策略确保了安全性和可扩展性。

D. 在测试环境 and 生产环境中创建服务账户。将服务账户的访问密钥提供给需要访问测试账户和生产账户的开发人员。定期轮换服务账户的访问密钥。

错误：共享服务账户的访问密钥违反了安全最佳实践。即使定期轮换密钥，也无法避免凭证共享带来的安全风险。

▼ 76

▼ 英文:

A company is operating an open-source software platform that is internet facing. The legacy software platform no longer receives security updates. The software platform operates using Amazon Route 53 weighted load balancing to send traffic to two Amazon EC2 instances that connect to an Amazon RDS cluster. A recent report suggests this software platform is vulnerable to SQL injection attacks, with samples of attacks provided. The company's security engineer must secure this system against SQL injection attacks within 24 hours. The security engineer's solution must involve the least amount of effort and maintain normal operations during implementation. What should the security engineer do to meet these requirements?

A. Create an Application Load Balancer with the existing EC2 instances as a target group. Create an AWS WAF web ACL

containing rules that protect the application from this attack, then apply it to the ALB. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to the ALB. Update security groups on the EC2 instances to prevent direct access from the internet.

B. Create an Amazon CloudFront distribution specifying one EC2 instance as an origin. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the distribution. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to CloudFront.

C. Obtain the latest source code for the platform and make the necessary updates. Test the updated code to ensure that the vulnerability has been mitigated, then deploy the patched version of the platform to the EC2 instances

D. Update the security group that is attached to the EC2 instances, removing access from the internet to the TCP port used by the SQL database. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the EC2 instances. Test to ensure the vulnerability has been mitigated, then restore the security group to the original setting.

▼ 中文:

一家公司正在运营一个面向互联网的开源软件平台。该遗留软件平台不再接收安全更新。该软件平台使用 Amazon Route 53 加权负载均衡将流量发送到两个连接到 Amazon RDS 集群的 Amazon EC2 实例。最近的一份报告表明，该软件平台容易受到 SQL 注入攻击，并提供了攻击样本。公司的安全工程师必须在 24 小时内保护该系统免受 SQL 注入攻击。[安全工程师的解决方案必须涉及最少的工作量，并在实施期间保持正常运行。](#)

安全工程师应该怎么做才能满足这些要求？

A. 创建一个 Application Load Balancer，并将现有的 EC2 实例作为目标组。创建一个包含保护应用程序免受此类攻击规则的 AWS WAF web ACL，然后将其应用到 ALB。测试以确保漏洞已被缓解，然后将 Route 53 记录重定向到 ALB。更新 EC2 实例上的安全组以防止直接从互联网访问。

B. 创建一个 Amazon CloudFront 分配，指定一个 EC2 实例作为源。创建一个包含保护应用程序免受此类攻击规则的 AWS WAF web ACL，然后将其应

用到分配。测试以确保漏洞已被缓解，然后将 Route 53 记录重定向到 CloudFront。

C. 获取该平台的最新源代码并进行必要的更新。测试更新后的代码以确保漏洞已被缓解，然后将修补后的平台版本部署到 EC2 实例。

D. 更新附加到 EC2 实例的安全组，移除对 SQL 数据库使用的 TCP 端口的互联网访问权限。创建一个包含保护应用程序免受此类攻击规则的 AWS WAF web ACL，然后将其应用到 EC2 实例。测试以确保漏洞已被缓解，然后将安全组恢复到原始设置。

▼ 答案:

A

1. 考察的知识点

SQL注入攻击的防护措施。

AWS WAF的使用及其与资源的集成。

Amazon Route 53的流量管理和重定向。

应用负载均衡器（ALB）的配置与安全组的管理。

2. 选项分析

A. 创建一个 Application Load Balancer，并将现有的 EC2 实例作为目标组。创建一个包含保护应用程序免受此类攻击规则的 AWS WAF web ACL，然后将其应用到 ALB。测试以确保漏洞已被缓解，然后将 Route 53 记录重定向到

ALB。更新 EC2 实例上的安全组以防止直接从互联网访问。

正确：此选项使用了AWS WAF来防护SQL注入攻击，并通过ALB将流量集中管理，确保正常运行。更新安全组以防止直接访问进一步增强了安全性。

符合题目要求：最少的努力、快速实施、维持正常操作。

B. 创建一个 Amazon CloudFront 分配，指定一个 EC2 实例作为源。创建一个包含保护应用程序免受此类攻击规则

的 AWS WAF web ACL，然后将其应用到分配。测试以确保漏洞已被缓解，然后将 Route 53 记录重定向到

CloudFront。

错误：虽然CloudFront可以与AWS WAF集成，但使用CloudFront作为解决方案需要额外的配置和测试，可能无法在24小时内完成。不符合题目要求：增加了复杂性，可能影响正常操作。

C. 获取该平台的最新源代码并进行必要的更新。测试更新后的代码以确保漏洞已被缓解，然后将修补后的平台版本部署到 EC2 实例。

错误：更新源代码需要开发资源和时间，无法在24小时内完成。

不符合题目要求：无法快速实施，且可能影响正常操作。

D. 更新附加到 EC2 实例的安全组，移除对 SQL 数据库使用的 TCP 端口的互联网访问权限。创建一个包含保护应

用程序免受此类攻击规则的 AWS WAF web ACL，然后将其应用到 EC2 实例。测试以确保漏洞已被缓解，然后将安全组恢复到原始设置。

错误：AWS WAF无法直接应用到EC2实例，必须通过ALB或CloudFront等资源进行集成。

不符合题目要求：安全组的修改无法直接防护SQL注入攻击

▼ 77

▼ 英文:

A company runs an application that sends logs to a log group in Amazon CloudWatch Logs. The email addresses of the application users are in the logs. The company's developers need to view the logs in CloudWatch Logs. A security engineer must ensure that the developers who

access the log group cannot see the user email addresses.

Which solution will meet this requirement?

A. Use Amazon Macie to scan the log group. Configure Macie to use a custom data identifier that uses a regular expression to identify an email address pattern. Activate automated data discovery in Macie.

B. Create an AWS Key Management Service (AWS KMS) key. Configure the log group to use the key to encrypt the logs.

Configure the key policy to deny access to the IAM role that the developers assume to use CloudWatch Logs.

C. Create a subscription filter for the log group. Configure the log subscription to send the log data to an AWS Lambda function. Program the Lambda function to parse the log entries and to mask values that are email addresses

D. Configure a data protection policy for the log group. Specify the AWS managed data identifier of EmailAddress for the type of data to mask. Activate data protection for the log group.

▼ 中文:

一家公司运行一个应用程序，该应用程序将日志发送到 Amazon CloudWatch Logs 中的日志组。应用程序用户的电子邮件地址包含在日志中。

公司的开发人员需要查看 CloudWatch Logs 中的日志。一名安全工程师必须确保访问日志组开发人员无法看到用户的电子邮件地址。

哪种解决方案可以满足此要求？

- A. 使用 Amazon Macie 扫描日志组。配置 Macie 使用一个自定义数据标识符，该标识符使用正则表达式识别电子邮件地址模式。在 Macie 中激活自动数据发现。
- B. 创建一个 AWS Key Management Service (AWS KMS) 密钥。配置日志组使用该密钥加密日志。配置密钥策略以拒绝开发人员使用 CloudWatch Logs 的 IAM 角色的访问权限。
- C. 为日志组创建一个订阅过滤器。配置日志订阅将日志数据发送到一个 AWS Lambda 函数。编写 Lambda 函数以解析日志条目并屏蔽电子邮件地址的值。
- D. 为日志组配置数据保护策略。指定 EmailAddress 的 AWS 托管数据标识符作为需要屏蔽的数据类型。为日志组激活为日志组配置数据保护策略。指定 EmailAddress 的 AWS 托管数据标识符作为需要屏蔽的数据类型。为日志组激活数据保护。

▼ 答案:

D

1. 考察的知识点

CloudWatch Logs 的日志数据保护功能。

如何屏蔽敏感数据（如电子邮件地址）以满足安全合规性要求。

AWS 服务（如 Lambda、Macie、KMS）的适用场景和功能限制。

2. 选项分析

A. 使用 Amazon Macie 扫描日志组。

Macie 主要用于发现和保护存储在 Amazon S3 中的敏感数据，而不是直接处理 CloudWatch Logs 中的数据。

虽然可以使用正则表达式创建自定义数据标识符，但 Macie 无法直接屏蔽 CloudWatch Logs 中的数据。此选项不符合要求，因此错误。

B. 使用 AWS KMS 加密日志。

使用 KMS 加密日志可以保护数据的机密性，但加密并不会屏蔽日志中的具体字段（如电子邮件地址）。即使开发人员无法解密日志，他们仍然无法查看日志内容，这与题目要求不符。此选项不符合要求，因此错误。

C. 使用 AWS Lambda 解析和屏蔽日志。

通过订阅过滤器将日志数据发送到Lambda函数并屏蔽敏感字段是可行的，但这种方法需要额外的开发和维护工作。题目要求的是一种直接的解决方案，而不是自定义开发的方式。此选项虽然可行，但不是最佳解决方案，因此错误。

D. 配置数据保护策略。

CloudWatch Logs支持数据保护策略，可以使用AWS托管数据标识符（如EmailAddress）自动屏蔽敏感数据。此方法直接满足题目要求，无需额外开发或复杂配置。

▼ 78

▼ 英文:

A security engineer is implementing a logging solution for a company's AWS environment. The security engineer has configured an AWS CloudTrail trail in the company's AWS account. The logs are stored in an Amazon S3 bucket for a third-party service provider to monitor. The service provider has a designated IAM role to access the S3 bucket. The company requires all logs to be encrypted at rest with a customer managed key. The security engineer uses AWS Key Management Service (AWS KMS) to create the customer managed key and key policy. The security engineer also configures CloudTrail to use the key to encrypt the trail.

When the security engineer implements this configuration, the service provider no longer can read the logs.

What should the security engineer do to allow the service provider to read the logs?

- A. Ensure that the S3 bucket policy allows access to the service provider's role to decrypt objects.
- B. Add a statement to the key policy to allow the service provider's role the kms:Decrypt action for the key.
- C. Add the AWSKeyManagementServicePowerUser AWS managed policy to the service provider's role.
- D. Migrate the key to AWS Certificate Manager (ACM) to create a shared endpoint for access to the key.

▼ 中文:

一名安全工程师正在为公司的 AWS 环境实施日志解决方案。安全工程师已在公司 AWS 账户中配置了一个 AWS CloudTrail trail。日志存储在一个 Amazon S3 bucket 中，供第三方服务提供商进行监控。服务提供商有一个指定的 IAM role 用于访问该 S3 bucket。

公司要求所有日志必须使用客户管理密钥进行静态加密。安全工程师使用 AWS Key Management Service (AWS KMS) 创建了客户管理密钥和密钥策略。安全工程师还配置了 CloudTrail 使用该密钥来加密 trail。当安全工程师实施此配置时，服务提供商无法再读取日志。

安全工程师应该怎么做以允许服务提供商读取日志？

- A. 确保 S3 bucket policy 允许服务提供商的 role 解密对象。
- B. 在密钥策略中添加一个语句，允许服务提供商的 role 对密钥执行 kms:Decrypt 操作。
- C. 将 AWSKeyManagementServicePowerUser AWS 托管策略添加到服务提供商的 role。
- D. 将密钥迁移到 AWS Certificate Manager (ACM)，以创建一个共享的密钥访问端点。

▼ 答案:

B

1. 考察的知识点

AWS CloudTrail日志加密与存储

AWS Key Management Service (KMS)的使用与权限管理IAM角色与权限策略的配置

如何正确配置KMS密钥策略以允许第三方访问加密资源

2. 选项分析

A. Ensure that the S3 bucket policy allows access to the service provider's role to decrypt objects.

错误：S3 bucket policy仅控制对S3对象的访问权限，但无法授予对KMS密钥的解密权限。

即使S3 bucket policy允许服务提供商的角色访问对象，服务提供商仍然需要KMS密钥的解密权限才能读取加密的日志。

B. Add a statement to the key policy to allow the service provider's role the kms:Decrypt action for the key.

正确：KMS密钥策略控制对密钥的访问权限。服务提供商的角色需要被显式授予kms:Decrypt权限才能解密使用该密钥

加密的日志。

这是解决问题的正确方法，因为问题的核心是服务提供商无法解密日志，

而不是无法访问S3对象。

C. Add the AWSKeyManagementServicePowerUser AWS managed policy to the service provider's role.

错误：AWSKeyManagementServicePowerUser是一个托管策略，授予广泛的KMS权限，但它不会自动解决特定密钥的权限问题。

此外，服务提供商的角色可能不需要如此广泛的权限，这可能违反最小权限原则。

D. Migrate the key to AWS Certificate Manager (ACM) to create a shared endpoint for access to the key.

错误：ACM用于管理SSL/TLS证书，而不是管理KMS密钥。

将KMS密钥迁移到ACM是不可行的，因为两者的用途和功能完全不同。

▼ 79

▼ 英文:

A company runs workloads on Amazon EC2 instances. The company needs to continually monitor the EC2 instances for software vulnerabilities and must display the findings in AWS Security Hub. The company must not install agents on the EC2 instances.

Which solution will meet these requirements?

A. Enable Amazon Inspector. Set the scan mode to hybrid scanning. Enable the integration for Amazon Inspector in Security Hub.

B. Use Security Hub to enable the AWS Foundational Security Best Practices standard. Wait for Security Hub to generate the findings.

C. Enable Amazon GuardDuty. Initiate on-demand malware scans by using GuardDuty Malware Protection. Enable the integration for GuardDuty in Security Hub.

D. Use AWS Config managed rules to detect EC2 software vulnerabilities. Ensure that Security Hub has the AWS Config integration enabled.

▼ 中文:

一家公司在 Amazon EC2 实例上运行工作负载。该公司需要持续监控 EC2 实例的**软件漏洞**，并必须在 AWS Security Hub中显示发现结果。公司不得在

EC2 实例上安装代理。

哪种解决方案可以满足这些要求？

- A. 启用 Amazon Inspector。将扫描模式设置为混合扫描。启用 Amazon Inspector 在 Security Hub 中的集成。
- B. 使用 Security Hub 启用 AWS Foundational Security Best Practices 标准。等待 Security Hub 生成发现结果。
- C. 启用 Amazon GuardDuty。通过使用 GuardDuty Malware Protection 启动按需恶意软件扫描。启用 GuardDuty 在 Security Hub 中的集成。
- D. 使用 AWS Config 托管规则检测 EC2 软件漏洞。确保 Security Hub 已启用 AWS Config 集成。

▼ 答案:

A

1. 考察的知识点

Amazon Inspector的功能和使用场景。

如何将Amazon Inspector与AWS Security Hub集成。

无代理（agentless）解决方案的实现。

2. 选项分析

A. Enable Amazon Inspector. Set the scan mode to hybrid scanning. Enable the integration for Amazon Inspector in Security Hub.

Amazon Inspector是一种自动化的安全评估服务，可以扫描EC2实例以检测软件漏洞。

它支持无代理扫描（agentless），符合题目要求。

Amazon Inspector可以与AWS Security Hub集成，将扫描结果直接显示在Security Hub中。

此选项完全符合题目要求，因此是正确答案。

B. Use Security Hub to enable the AWS Foundational Security Best Practices standard. Wait for Security Hub to generate the findings.

AWS Foundational Security Best Practices标准是Security Hub的一部分，用于检查AWS资源的安全配置。

它不直接扫描EC2实例的软件漏洞，因此不符合题目要求。

此选项错误。

C. Enable Amazon GuardDuty. Initiate on-demand malware scans by using GuardDuty Malware Protection. Enable the integration for GuardDuty in Security Hub.

Amazon GuardDuty是一种威胁检测服务，主要用于检测恶意活动和异常行为。

GuardDuty Malware Protection可以扫描EC2实例的恶意软件，但它不是专门用于检测软件漏洞。

此选项不符合题目要求，因此错误。

D. Use AWS Config managed rules to detect EC2 software vulnerabilities. Ensure that Security Hub has the AWS Config integration enabled.

AWS Config主要用于检查资源的配置是否符合预定义规则。

它不直接检测EC2实例的软件漏洞，因此不符合题目要求。

此选项错误。

▼ 80

▼ 英文:

A company runs a custom online gaming application. The company uses Amazon Cognito for user authentication and authorization.

A security engineer wants to use AWS to implement fine-grained authorization on resources in the custom application. The security engineer must implement a solution that uses the user attributes that exist in Cognito. The company has already set up a user pool and an identity pool in Cognito.

Which solution will meet these requirements?

A. Create a set of IAM roles and IAM policies. Configure the Cognito identity pool to assign users to the IAM roles.

B. Create a policy store in Amazon Verified Permissions. Configure Cognito as the identity source. Map Cognito access tokens to the Verified Permissions schema.

C. Create customer managed permissions by using AWS Resource Access Manager (AWS RAM). Configure the Cognito identity pool to assign users to the customer managed permissions.

D. Create a set of IAM users and IAM policies. Configure the Cognito user pool to assign users to the IAM users.

▼ 中文:

一家公司运行一个定制的在线游戏应用程序。该公司使用 Amazon Cognito 进行用户身份验证和授权。

一位安全工程师希望使用 AWS 在定制应用程序的资源上实施细粒度的授权。

安全工程师必须实施一个解决方案，该解决方案使用 Cognito 中存在的用户属性。该公司已经在 Cognito 中设置了用户池和身份池。哪种解决方案可以满足这些要求？

- A. 创建一组 IAM 角色和 IAM 策略。配置 Cognito 身份池以将用户分配到 IAM 角色。
- B. 在 Amazon Verified Permissions 中创建一个策略存储。配置 Cognito 作为身份源。将 Cognito 访问令牌映射到 Verified Permissions 架构。
- C. 使用 AWS Resource Access Manager (AWS RAM) 创建客户管理权限。配置 Cognito 身份池以将用户分配到客户管理权限。
- D. 创建一组 IAM 用户和 IAM 策略。配置 Cognito 用户池以将用户分配到 IAM 用户。

▼ 答案:

B

1. 考察的知识点

- Amazon Cognito 的用户认证与授权功能。
- 如何使用 AWS 服务实现细粒度的资源授权。
- Amazon Verified Permissions 的功能与使用场景。

2. 选项分析

A.

正确性分析：此选项描述了使用 IAM 角色和策略的方式来授权用户。这种方法可以实现基于角色的授权，但无法直接实现基于用户属性的细粒度授权。

结论：错误。

B.

正确性分析：Amazon Verified Permissions 支持基于用户属性的细粒度授权。将 Cognito 配置为身份源并映射访问令牌到 Verified Permissions 架构，可以实现所需的细粒度授权。

结论：正确。

C.

正确性分析：AWS RAM 主要用于跨账户共享资源，而不是实现基于用户属性的细粒度授权。此选项与题目要求不符。结论：错误。

D.

正确性分析：IAM 用户通常用于管理 AWS 账户中的长期凭证，而不是用于动态授权应用程序用户。此选项与题目要求不符。

结论：错误。

▼ 81

▼ 英文:

A company wants to automate the creation of a security report. The company has an AWS Lambda function that gathers data from Amazon Inspector findings stored in AWS Security Hub in the us-west-2 Region. The Lambda function then needs to create a daily report by using an Amazon EventBridge schedule. A security engineer discovers that the Lambda function is failing to create the report. The security engineer must implement a solution that corrects the issue and provides least privilege permissions.

Which solution will meet these requirements?

- A. Create a resource-based policy that allows Security Hub access to the ARN of the Lambda function.
- B. Attach the `AWSSecurityHubReadOnlyAccess` AWS managed policy to the Lambda function's execution role.
- C. Grant the Lambda function's execution role read-only permissions to access Amazon Inspector and Security Hub.
- D. Create a custom IAM policy that grants the Security Hub `Get*`, `List*`, `Batch*`, and `Describe*` permissions on the `arn:aws:securityhub:us-west-2::product/aws/inspector/*` resource. Attach the policy to the Lambda function's execution role.

▼ 中文:

一家公司希望自动化生成安全报告。该公司有一个 AWS Lambda 函数，用于从存储在 us-west-2 区域的 AWS Security Hub 中的 Amazon Inspector 发现中收集数据。然后，Lambda 函数需要通过使用 Amazon EventBridge 计划创建每日报告。

一名安全工程师发现 Lambda 函数无法创建报告。安全工程师必须实施一个解决方案来纠正问题，并提供最小权限的访问权限。

哪个解决方案可以满足这些要求？

一家公司希望自动化生成安全报告。该公司有一个 AWS Lambda 函数，用于从存储在 us-west-2 区域的 AWS Security Hub 中的 Amazon Inspector 发现中收集数据。然后，Lambda 函数需要通过使用 Amazon EventBridge 计划创建每日报告。

一名安全工程师发现 Lambda 函数无法创建报告。安全工程师必须实施一个解决方案来纠正问题，并提供最小权限的访问权限。

哪个解决方案可以满足这些要求？

- A. 创建一个基于资源的策略，允许 Security Hub 访问 Lambda 函数的 ARN。
- B. 将 AWSSecurityHubReadOnlyAccess AWS 托管策略附加到 Lambda 函数的执行角色。
- C. 授予 Lambda 函数的执行角色只读权限以访问 Amazon Inspector 和 Security Hub。
- D. 创建一个自定义 IAM 策略，授予 Security Hub 对 `arn:aws:securityhub:us-west-2::product/aws/inspector/*` 资源的 `Get*`、`List*`、`Batch*` 和 `Describe*` 权限。将该策略附加到 Lambda 函数的执行角色。

▼ 答案:

B

1. 考察的知识点

理解 AWS Lambda 的执行角色权限管理。

熟悉 AWS Security Hub 和 Amazon Inspector 的权限模型。

掌握最小权限原则（Least Privilege）。

了解 AWS 托管策略的使用场景。

2. 选项分析

A. Create a resource-based policy that allows Security Hub access to the ARN of the Lambda function.

错误：资源基于策略通常用于授予其他服务或账户对资源的访问权限，但此场景中需要的是 Lambda 函数的执行角色

权限，而不是资源基于策略。

此外，Security Hub 不需要直接访问 Lambda 函数的 ARN。

B. Attach the AWSSecurityHubReadOnlyAccess AWS managed policy to the Lambda function's execution role.

正确：AWSSecurityHubReadOnlyAccess 是 AWS 托管策略，专门用于提供对 Security Hub 的只读访问权限。

此策略包含了 Lambda 函数所需的权限，符合最小权限原则。

C. Grant the Lambda function's execution role read-only permissions to access Amazon Inspector and Security Hub.

错误：虽然此选项提到授予只读权限，但没有明确说明如何实现这些权限。

相比之下，选项 B 提供了一个现成的 AWS 托管策略，避免了手动创建权

限的复杂性。

D. Create a custom IAM policy that grants the Security Hub Get*, List*, Batch*, and Describe* permissions on the `arn:aws:securityhub:us-west-2::product/aws/inspector/*` resource. Attach the policy to the Lambda function's execution role.

错误：虽然自定义策略可以满足权限需求，但创建和维护自定义策略增加了复杂性。

使用 AWS 托管策略（如选项 B）更简单且符合最佳实践

▼ 82

▼ 英文:

A company must retain backup copies of Amazon RDS DB instances and Amazon Elastic Block Store (Amazon EBS) volumes.

The company must retain the backup copies in data centers that are several hundred miles apart.

Which solution will meet these requirements with the LEAST operational overhead?

A. Configure AWS Backup to create the backups according to the needed schedule. In the backup plan, specify multiple Availability Zones as backup destinations.

B. Configure Amazon Data Lifecycle Manager to create the backups. Configure the Amazon Data Lifecycle Manager policy to copy the backups to an Amazon S3 bucket. Enable replication on the S3 bucket.

C. Configure AWS Backup to create the backups according to the needed schedule. Create a destination backup vault in a different AWS Region. Configure AWS Backup to copy the backups to the destination backup vault.

D. Configure Amazon Data Lifecycle Manager to create the backups. Create an AWS Lambda function to copy the backups to a different AWS Region. Use Amazon EventBridge to invoke the Lambda function on a schedule.

▼ 中文:

一家公司必须保留 Amazon RDS 数据库实例和 Amazon Elastic Block Store (Amazon EBS) 卷的备份副本。公司必须将备份副本保存在相距数百英里的数据中心中。

哪种解决方案能够以最低的操作开销满足这些要求？

- A.配置 AWS Backup 根据所需的计划创建备份。在备份计划中，指定多个可用区作为备份目标。
- B. 配置 Amazon Data Lifecycle Manager 创建备份。配置 Amazon Data Lifecycle Manager 策略，将备份复制到一个Amazon S3 存储桶。启用 S3 存储桶的复制功能。
- C. 配置 AWS Backup 根据所需的计划创建备份。在不同的 AWS 区域中创建一个目标备份库。配置 AWS Backup 将备份复制到目标备份库。
- D. 配置 Amazon Data Lifecycle Manager 创建备份。创建一个 AWS Lambda 函数将备份复制到不同的 AWS 区域。使用Amazon EventBridge 按计划调用 Lambda 函数。

▼ 答案:

C

1. 考察的知识点跨区域备份的实现方法。

AWS Backup的功能和配置，包括备份计划和跨区域备份。

Amazon Data Lifecycle Manager的功能和限制。

如何实现低操作开销的备份解决方案。

2. 选项分析

A. 配置 AWS Backup 根据所需的计划创建备份。在备份计划中，指定多个可用区作为备份目标。

错误：AWS Backup无法直接指定多个可用区作为备份目标。备份的存储位置是备份库（Backup Vault），而不是具体的可用区。

此外，跨区域备份需要明确配置目标区域，而不是仅仅依赖可用区。

B. 配置 Amazon Data Lifecycle Manager 创建备份。配置 Amazon Data Lifecycle Manager 策略，将备份复制到一个Amazon S3 存储桶。启用 S3 存储桶的复制功能。

错误：Amazon Data Lifecycle Manager主要用于管理EBS快照生命周期，但它无法直接将快照复制到S3存储桶。

虽然启用S3存储桶的复制功能可以实现跨区域存储，但这需要额外的配置和管理，增加了操作开销。

C. 配置 AWS Backup 根据所需的计划创建备份。在不同的 AWS 区域中创建一个目标备份库。配置 AWS Backup 将备份复制到目标备份库。

正确：AWS Backup支持跨区域备份，可以通过配置备份计划将备份复制到目标区域的备份库。

这种方法操作开销最低，因为AWS Backup提供了内置的跨区域备份功能，无需额外的脚本或服务。

D. 配置 Amazon Data Lifecycle Manager 创建备份。创建一个 AWS Lambda 函数将备份复制到不同的 AWS 区域。使用 Amazon

EventBridge 按计划调用 Lambda 函数。

错误：这种方法需要额外开发和维护Lambda函数以及EventBridge规则，增加了操作开销。

虽然可以实现跨区域备份，但与AWS Backup的内置功能相比，这种方法复杂且不优雅。

▼ 83

▼ 英文:

A security engineer has noticed an unusually high amount of traffic coming from a single IP address. This was discovered by analyzing the Application Load Balancer's access logs.

How can the security engineer limit the number of requests from a specific IP address without blocking the IP address?

- A. Add a rule to the Application Load Balancer to route the traffic originating from the IP address in question and show a static webpage.
- B. Implement a rate-based rule with AWS WAF.
- C. Use AWS Shield to limit the originating traffic hit rate.
- D. Implement the GeoLocation feature in Amazon Route 53.

▼ 中文:

一位安全工程师注意到来自单个 IP 地址的流量异常高。这是通过分析 Application Load Balancer 的访问日志发现的。

安全工程师如何限制来自特定 IP 地址的请求数量而不完全阻止该 IP 地址？

- A. 为 Application Load Balancer 添加一个规则，将来自该 IP 地址的流量路由到一个静态网页。
- B. 使用 AWS WAF 实现基于速率的规则。
- C. 使用 AWS Shield 限制源流量的命中速率。
- D. 在 Amazon Route 53 中实现 GeoLocation 功能。

▼ 答案:

B

1. 考察的知识点

本题考察的是如何使用AWS服务来限制特定IP地址的请求速率，而不是完全阻止该IP地址的访问。

涉及的知识点包括AWS WAF的功能、Application Load Balancer规则、AWS Shield的能力以及Amazon Route 53的GeoLocation功能。

2. 选项分析

A. Add a rule to the Application Load Balancer to route the traffic originating from the IP address in question and show a static webpage.

错误：此选项仅能将流量路由到一个静态网页，但无法限制请求的速率。它并不解决问题的核心，即限制请求频率。

B. Implement a rate-based rule with AWS WAF.

正确：AWS WAF支持基于速率的规则，可以限制特定IP地址的请求速率，而不是完全阻止该IP地址的访问。这正是题目要求的解决方案。

C. Use AWS Shield to limit the originating traffic hit rate.

错误：AWS Shield主要用于保护应用免受DDoS攻击，但它并不提供直接的速率限制功能。此选项不符合题目要求。

D. Implement the GeoLocation feature in Amazon Route 53.

错误：Amazon Route 53的GeoLocation功能用于基于地理位置路由流量，与限制特定IP地址的请求速率无关。

▼ 84

▼ 英文:

A company runs workloads that are spread across hundreds of Amazon EC2 instances. During a recent security incident, an EC2 instance was compromised and ran malware code until the company manually terminated the instance.

The company is now using Amazon GuardDuty to detect malware on EC2 instances. A security engineer needs to implement a solution that automates a response when GuardDuty determines that an instance is infected. The solution must mitigate the incident and must comply with the AWS Well-Architected Framework guidance for incident response.

Which solution will meet these requirements?

A. Configure AWS Systems Manager Run Command to run when a GuardDuty scan determines that an instance is infected.

Use Run Command to remove all network adapters from the operating system of the infected instance. Use Run Command to also add a tag of "Infected" to the instance.

B. Create an AWS Lambda function that runs when a GuardDuty scan determines that an instance is infected. Program the Lambda function to delete all elastic network interfaces that are

associated with the instance. Program the Lambda function to also add a tag of "Infected" to the instance.

C. Create an AWS Lambda function that runs when a GuardDuty scan determines that an instance is infected. Program the Lambda function to detach all Amazon Elastic Block Store (Amazon EBS) volumes from the instance. Program the Lambda function to also add a tag of "Infected" to the EBS volumes and to terminate the instance afterward.

D. Define a separate VPC to isolate EC2 instances. Define a security group that does not allow any network traffic. Create an AWS Lambda function that runs when a GuardDuty scan determines that an instance is infected. Program the Lambda function to move the instance into the separate VPC and to assign the security group to the instance.

▼ 中文:

一家公司运行的工作负载分布在数百个 Amazon EC2 实例上。在最近的一次安全事件中，一个 EC2 实例被攻破并运行了恶意代码，直到公司手动终止了该实例。

该公司现在使用 Amazon GuardDuty 来检测 EC2 实例上的恶意软件。一名安全工程师需要实施一个解决方案，当 GuardDuty 确定某个实例被感染时能够自动响应。[该解决方案必须缓解事件并符合 AWS Well-Architected Framework 关于事件响应的指导原则。](#)

哪种解决方案可以满足这些要求？

A.配置 AWS Systems Manager Run Command，当 GuardDuty 扫描确定某个实例被感染时运行。使用 Run Command 从被感染实例的操作系统中移除所有网络适配器。还使用 Run Command 为实例添加一个标签 "Infected"。

B.创建一个 AWS Lambda 函数，当 GuardDuty 扫描确定某个实例被感染时运行。编写 Lambda 函数以删除与该实例关联的所有弹性网络接口。还编写 Lambda 函数为实例添加一个标签 "Infected"

C.创建一个 AWS Lambda 函数，当 GuardDuty 扫描确定某个实例被感染时运行。编写 Lambda 函数以分离该实例的所有 Amazon Elastic Block Store (Amazon EBS) 卷。还编写 Lambda 函数为 EBS 卷添加一个标签 "Infected"，并随后终止该实例。

D.定义一个单独的 VPC 来隔离 EC2 实例。定义一个不允许任何网络流量的安全组。创建一个 AWS Lambda 函数，当 GuardDuty 扫描确定某个实例被

感染时运行。编写 Lambda 函数将实例移动到单独的 VPC，并为实例分配该安全组。

▼ 答案:

C

1. 考察的知识点

Amazon GuardDuty的功能和事件触发机制。

AWS Lambda的自动化响应能力。

符合AWS Well-Architected Framework的安全事件响应设计。

如何隔离受感染的EC2实例并防止进一步传播。

2. 选项分析

A. Configure AWS Systems Manager Run Command...

正确性分析：使用AWS Systems Manager Run Command可以执行操作，但移除网络适配器并添加标签的方式并不完全符合AWS Well-Architected Framework的最佳实践，因为它没有彻底隔离实例或终止实例。

错误原因：此方法无法完全防止恶意代码的进一步传播或影响其他资源。

B. Create an AWS Lambda function...

正确性分析：删除弹性网络接口可以隔离实例，但仅删除网络接口并添加标签不足以完全解决问题。实例仍然在运行，可能继续执行恶意代码。

错误原因：此方法没有终止实例或处理存储卷，无法完全符合事件响应的要求。

C. Create an AWS Lambda function...

正确性分析：分离EBS卷并终止实例是一个全面的解决方案，**可以防止恶意代码进一步传播，同时标记受影响的资源以便后续分析。**

正确原因：此方法符合AWS Well-Architected Framework的指导，提供了有效的隔离和事件响应。

D. Define a separate VPC...

正确性分析：将实例移动到隔离的VPC并分配无流量的安全组可以隔离实例，但此方法复杂且可能需要额外的网络配置，无法快速响应事件。

错误原因：此方法的实现复杂度较高，且没有终止实例或处理存储卷，可能导致恶意代码继续运行。

▼ 85

▼ 英文:

A public subnet contains two Amazon EC2 instances. The subnet has a custom network ACL. A security engineer is designing a solution to improve the subnet security.

The solution must allow outbound traffic to an internet service that uses TLS through port 443. The solution also must deny inbound traffic that is destined for MySQL port 3306.

Which network ACL rule set meets these requirements?

- A. Use inbound rule 100 to allow traffic on TCP port 443. Use inbound rule 200 to deny traffic on TCP port 3306. Use outbound rule 100 to allow traffic on TCP port 443.
- B. Use inbound rule 100 to deny traffic on TCP port 3306. Use inbound rule 200 to allow traffic on TCP port range 1024-65535. Use outbound rule 100 to allow traffic on TCP port 443.
- C. Use inbound rule 100 to allow traffic on TCP port range 1024-65535. Use inbound rule 200 to deny traffic on TCP port 3306. Use outbound rule 100 to allow traffic on TCP port 443.
- D. Use inbound rule 100 to deny traffic on TCP port 3306. Use inbound rule 200 to allow traffic on TCP port 443. Use outbound rule 100 to allow traffic on TCP port 443.

▼ 中文:

一个公共子网包含两个 Amazon EC2 实例。该子网有一个自定义网络 ACL。某安全工程师正在设计一个解决方案以提高子网的安全性。

该解决方案必须允许通过端口 443 使用 TLS 的互联网服务的出站流量。该解决方案还必须拒绝目标为 MySQL 端口 3306 的入站流量。哪个网络 ACL 规则集满足这些要求？

- A. 使用入站规则 100 允许 TCP 端口 443 上的流量。使用入站规则 200 拒绝 TCP 端口 3306 上的流量。使用出站规则 100 允许 TCP 端口 443 上的流量。
- B. 使用入站规则 100 拒绝 TCP 端口 3306 上的流量。使用入站规则 200 允许 TCP 端口范围 1024-65535 上的流量。使用出站规则 100 允许 TCP 端口 443 上的流量。
- C. 使用入站规则 100 允许 TCP 端口范围 1024-65535 上的流量。使用入站规则 200 拒绝 TCP 端口 3306 上的流量。使用出站规则 100 允许 TCP 端口 443 上的流量。

D.使用入站规则 100 拒绝 TCP 端口 3306 上的流量。使用入站规则 200 允许 TCP 端口 443 上的流量。使用出站规则使用入站规则 100 拒绝 TCP 端口 3306 上的流量。使用入站规则 200 允许 TCP 端口 443 上的流量。使用出站规则100 允许 TCP 端口 443 上的流量。

▼ 答案:

B

1. 考察的知识点

网络ACL (Network ACL) 的规则配置与优先级。

入站和出站流量的控制规则。

如何允许特定端口的流量并拒绝其他端口的流量。

2. 选项分析

A:

入站规则 100 允许 TCP 端口 443 上的流量：错误，因为入站流量不需要允许 443 端口，TLS 流量是出站流量。

入站规则 200 拒绝 TCP 端口 3306 上的流量：正确，符合要求。

出站规则 100 允许 TCP 端口 443 上的流量：正确，符合要求。

整体错误：入站规则 100 不需要允许 443 端口。

B:

入站规则 100 拒绝 TCP 端口 3306 上的流量：正确，符合要求。

入站规则 200 允许 TCP 端口范围 1024-65535 上的流量：正确，允许响应流量（例如 TLS 的返回流量）。

出站规则 100 允许 TCP 端口 443 上的流量：正确，符合要求。

整体正确：所有规则均符合要求。

C:

入站规则 100 允许 TCP 端口范围 1024-65535 上的流量：错误，因为入站规则优先级不正确，应该先拒绝 3306。

入站规则 200 拒绝 TCP 端口 3306 上的流量：正确，但优先级错误。

出站规则 100 允许 TCP 端口 443 上的流量：正确，符合要求。

整体错误：入站规则优先级配置不正确。

D:

入站规则 100 拒绝 TCP 端口 3306 上的流量：正确，符合要求。

入站规则 200 允许 TCP 端口 443 上的流量：错误，因为入站流量不需要允许 443 端口。

出站规则 100 允许 TCP 端口 443 上的流量：正确，符合要求。

整体错误：入站规则 200 不需要允许 443 端口。

▼ 86

▼ 英文:

A company is investigating actions that an IAM role performed. The company must find out when the role last accessed AWS Security Hub and when the role last used the DeleteInsight action in Security Hub.

Which solution will provide this information?

- A. Use the checks for the security category in AWS Trusted Advisor. Search for the role and examine the actions taken.
- B. Use the Access Advisor tab in AWS Identity and Access Management (IAM). Search for Security Hub and the actions taken.
- C. Use AWS Identity and Access Management (IAM) to generate a credential report. Search the report for Security Hub activity.
- D. Create an analyzer in AWS Identity and Access Management Access Analyzer. Examine the findings for the role's actions in Security Hub.

▼ 中文:

一家公司正在调查一个IAM角色执行的操作。该公司必须找出该角色上次访问AWS Security Hub的时间，以及该角色上次在Security Hub中使用DeleteInsight操作的时间。

哪种解决方案可以提供此信息？

- A.使用AWS Trusted Advisor中的安全类别检查。搜索该角色并检查执行的操作。
- B.使用AWS Identity and Access Management (IAM)中的Access Advisor标签。搜索Security Hub和执行的操作。
- C.使用AWS Identity and Access Management (IAM)生成凭证报告。在报告中搜索Security Hub活动。
- D.在AWS Identity and Access Management Access Analyzer中创建一个分析器。检查该角色在Security Hub中的操作发现。

▼ 答案:

B

1. 考察的知识点

本题考察的是AWS Identity and Access Management (IAM)的功能，特别是如何追踪IAM角色的访问活动。

涉及的服务包括IAM Access Advisor、IAM Credential Report、AWS Trusted Advisor和IAM Access Analyzer。

2. 选项分析

A. 使用AWS Trusted Advisor中的安全类别检查。搜索该角色并检查执行的操作。

错误：AWS Trusted Advisor主要用于提供账户安全、成本优化、性能和服务限制的建议，但它不提供关于IAM角色具体操作的详细历史记录。

B. 使用AWS Identity and Access Management (IAM)中的Access Advisor标签。搜索Security Hub和执行的的操作。

正确：IAM Access Advisor可以显示某个角色最近访问的服务及其时间戳。这正是题目要求的功能。

C. 使用AWS Identity and Access Management (IAM)生成凭证报告。在报告中搜索Security Hub活动。

错误：IAM Credential Report主要用于列出账户和IAM用户的凭证状态（例如密码是否启用、访问密钥是否活动），而不是追踪角色的具体操作。

D. 在AWS Identity and Access Management Access Analyzer中创建一个分析器。检查该角色在Security Hub中的操作发现。

错误：IAM Access Analyzer用于分析资源策略以确定资源是否可以被外部实体访问，它不提供关于角色操作的时间戳或历史记录。

▼ 87

▼ 英文:

A company hosts its microservices application on Amazon Elastic Kubernetes Service (Amazon EKS). The company has set up continuous deployments to update the application on demand. A security engineer must implement a solution to provide automatic detection of anomalies in application logs in near real time. The solution also must send notifications about these anomalies to the security team.

Which solution will meet these requirements?

A. Configure Amazon CloudWatch Container Insights to collect and aggregate EKS application logs. Create a CloudWatch alarm to monitor for anomalies. Configure the alarm to launch an AWS Lambda function to alert the security team when anomalies are detected.

B. Configure Amazon EKS to send application logs to Amazon CloudWatch. Create a CloudWatch alarm based on a log group metric

filter. Specify anomaly detection as the threshold type. Configure the alarm to use Amazon Simple Notification Service (Amazon SNS) to alert the security team.

C. Configure Amazon EKS to export logs to Amazon S3. Use Amazon Athena queries to analyze the logs for anomalies. Use Amazon QuickSight to visualize and monitor user access requests for anomalies. Configure Amazon Simple Notification Service (Amazon SNS) notifications to alert the security team.

D. Configure AWS App Mesh to monitor the traffic to the microservices in Amazon EKS. Integrate App Mesh with AWS CloudTrail for logging. Use Amazon Detective to analyze the logs for anomalies and to alert the security team when anomalies are detected.

▼ 中文:

一家公司在 Amazon Elastic Kubernetes Service (Amazon EKS) 上托管其微服务应用程序。该公司已经设置了持续部署，以按需更新应用程序。一名安全工程师必须实施一个解决方案，以在接近实时的情况下自动检测应用程序日志中的异常。该解决方案还必须向安全团队发送有关这些异常的通知。哪种解决方案可以满足这些要求？

A.配置 Amazon CloudWatch Container Insights 来收集和聚合 EKS 应用程序日志。创建一个 CloudWatch alarm 来监控异常。配置该 alarm 启动一个 AWS Lambda 函数，当检测到异常时向安全团队发出警报。

B.配置 Amazon EKS 将应用程序日志发送到 Amazon CloudWatch。基于日志组的 metric filter 创建一个 CloudWatch alarm。指定 anomaly detection 作为阈值类型。配置该 alarm 使用 Amazon Simple Notification Service (Amazon SNS) 向安全团队发出警报。

C.配置 Amazon EKS 将日志导出到 Amazon S3。使用 Amazon Athena 查询分析日志中的异常。使用 Amazon QuickSight可视化并监控用户访问请求中的异常。配置 Amazon Simple Notification Service (Amazon SNS) 通知以向安全团队发出警报。

D.配置 AWS App Mesh 来监控 Amazon EKS 中微服务的流量。将 App Mesh 与 AWS CloudTrail 集成以进行日志记录。使用 Amazon Detective 分析日志中的异常，并在检测到异常时向安全团队发出警报。

▼ 答案:

B

题目分析与解答

1. 考察的知识点

Amazon EKS日志管理与监控
Amazon CloudWatch日志分析与告警
异常检测与通知机制
使用Amazon SNS进行通知

2. 选项分析

A. 配置 Amazon CloudWatch Container Insights 来收集和聚合 EKS 应用程序日志。创建一个 CloudWatch alarm 来监控异常。配置该 alarm 启动一个 AWS Lambda 函数，当检测到异常时向安全团队发出警报。

分析：

CloudWatch Container Insights主要用于监控容器性能指标（如CPU、内存等），而不是直接分析日志中的异常。

虽然可以通过Lambda函数发送通知，但题目要求的是“自动检测日志中的异常”，而不是性能指标异常。

此选项未提到如何实现日志的异常检测，因此不符合要求。

结论：错误。

B. 配置 Amazon EKS 将应用程序日志发送到 Amazon CloudWatch。基于日志组的 metric filter 创建一个 CloudWatch alarm。指定 anomaly detection 作为阈值类型。配置该 alarm 使用 Amazon Simple Notification Service (Amazon SNS) 向安全团队发出警报。

分析：

此选项直接提到将EKS日志发送到CloudWatch，并使用metric filter和anomaly detection功能来检测日志中的异常。

CloudWatch支持基于日志组的metric filter，并可以设置异常检测阈值。通过SNS发送通知是符合题目要求的解决方案。

结论：正确。

C. 配置 Amazon EKS 将日志导出到 Amazon S3。使用 Amazon Athena 查询分析日志中的异常。使用 Amazon QuickSight 可视化并监控用户访问请求中的异常。配置 Amazon Simple Notification Service (Amazon SNS) 通知以向安全团队发出警报。

分析：

将日志导出到S3并使用Athena查询是一种有效的日志分析方法，但它不是“实时”或“近实时”的解决方案。

QuickSight主要用于数据可视化，而不是实时异常检测。

此选项未满足“自动检测日志中的异常”的要求。

结论：错误。

D. 配置 AWS App Mesh 来监控 Amazon EKS 中微服务的流量。将 App Mesh 与 AWS CloudTrail 集成以进行日志记录。使用 Amazon Detective 分析日志中的异常，并在检测到异常时向安全团队发出警报。

分析：

App Mesh主要用于监控服务间的流量，而不是直接分析应用日志。Amazon Detective用于调查安全事件，而不是实时检测日志中的异常。此选项未满足“自动检测日志中的异常”的要求。结论：错误。

▼ 88

▼ 英文:

A company is migrating container workloads from a data center to Amazon Elastic Container Service (Amazon ECS) clusters. The company must implement a solution to detect potential threats in the workloads and to improve the security posture of the container clusters.

Which solution will meet these requirements?

- A. Configure Amazon Inspector on the VPC that is running the ECS clusters.
- B. Enable Amazon GuardDuty Runtime Monitoring on the ECS clusters.
- C. Audit Amazon ECS API access by using Amazon CloudWatch logs to identify unauthorized access.
- D. Create container clusters in the same VPC. Use VPC flow logs to centrally monitor network traffic.

▼ 中文:

一家公司正在将容器工作负载从数据中心迁移到 Amazon Elastic Container Service (Amazon ECS) 集群。该公司必须实施一种解决方案来检测工作负载中的潜在威胁，并改善容器集群的安全状况。

哪种解决方案可以满足这些要求？

- A.在运行 ECS 集群的 VPC 上配置 Amazon Inspector。
- B.在 ECS 集群上启用 Amazon GuardDuty Runtime Monitoring。
- C. 使用 Amazon CloudWatch logs 审核 Amazon ECS API 访问，以识别未经授权的访问。
- D. 在同一 VPC 中创建容器集群。使用 VPC flow logs 集中监控网络流量。

▼ 答案:

B

1. 考察的知识点

本题考察的是 AWS 安全服务的使用，特别是与容器安全相关的服务，包括 Amazon GuardDuty 和 Amazon Inspector。

重点在于如何检测潜在威胁并改善容器集群的安全态势。

2. 选项分析

A. 配置 Amazon Inspector 在运行 ECS 集群的 VPC 上：

Amazon Inspector 是一个自动化的安全评估服务，主要用于检测 EC2 实例和容器镜像中的漏洞和错误配置。

然而，Amazon Inspector 并不直接监控运行时的容器活动或 ECS 集群的安全态势，因此此选项不符合题目要求。

错误原因：无法满足检测运行时威胁的需求。

B. 启用 Amazon GuardDuty Runtime Monitoring 在 ECS 集群上：

Amazon GuardDuty Runtime Monitoring 是专门设计用于检测容器运行时威胁的功能。

它可以监控 ECS 集群中的容器活动，识别潜在的安全威胁，并提供相关的安全建议。

正确原因：直接满足题目要求，能够检测运行时威胁并改善安全态势。

C. 使用 Amazon CloudWatch logs 审核 ECS API 访问：

CloudWatch Logs 可以记录 ECS API 的访问日志，但它主要用于监控 API 调用，而不是检测容器运行时的威胁。

此选项无法直接改善容器集群的安全态势。

错误原因：不符合题目要求的运行时威胁检测需求。

D. 在同一 VPC 中创建容器集群并使用 VPC flow logs 监控网络流量：

VPC Flow Logs 可以记录网络流量，但它主要用于网络层面的监控，而不是容器运行时的安全威胁检测。

此选项无法直接改善容器集群的安全态势。

错误原因：不符合题目要求的运行时威胁检测需求。

▼ 89

▼ 英文:

A security engineer needs to implement a solution to determine whether a company's Amazon EC2 instances are being used to mine cryptocurrency. The solution must provide notifications of cryptocurrency-related activity to an Amazon Simple Notification Service (Amazon SNS) topic.

Which solution will meet these requirements?

- A. Create AWS Config custom rules by using Guard custom policy. Configure the AWS Config rules to detect when an EC2 instance queries a DNS domain name that is associated with cryptocurrency-related activity. Configure AWS Config to initiate alerts to the SNS topic
- B. Enable Amazon GuardDuty. Create an Amazon EventBridge rule to send alerts to the SNS topic when GuardDuty creates a finding that is associated with cryptocurrency-related activity.
- C. Enable Amazon Inspector. Create an Amazon EventBridge rule to send alerts to the SNS topic when Amazon Inspector creates a finding that is associated with cryptocurrency-related activity
- D. Enable VPC flow logs. Send the flow logs to an Amazon S3 bucket. Set up a query in Amazon Athena to detect when an EC2 instance queries a DNS domain name that is associated with cryptocurrency-related activity. Configure the Athena query to initiate alerts to the SNS topic.

▼ 中文:

一名安全工程师需要实施一个解决方案，以确定公司的 Amazon EC2 实例是否被用于挖掘加密货币。该解决方案必须向一个 Amazon Simple Notification Service (Amazon SNS) 主题提供与加密货币相关活动的通知。哪个解决方案可以满足这些要求？

- A.使用 Guard 自定义策略创建 AWS Config 自定义规则。配置 AWS Config 规则以检测 EC2 实例何时查询与加密货币相关活动相关的 DNS 域名。配置 AWS Config 以向 SNS 主题发出警报。
- B.启用 Amazon GuardDuty。创建一个 Amazon EventBridge 规则，当 GuardDuty 创建与加密货币相关活动相关的发现时，将警报发送到 SNS 主题。
- C.启用 Amazon Inspector。创建一个 Amazon EventBridge 规则，当 Amazon Inspector 创建与加密货币相关活动相关的发现时，将警报发送到 SNS 主题。
- D.启用 VPC 流日志。将流日志发送到一个 Amazon S3 存储桶。在 Amazon Athena 中设置一个查询，以检测 EC2 实例何时查询与加密货币相关活动相关的 DNS 域名。配置 Athena 查询以向 SNS 主题发出警报。

▼ 答案:

B

1. 考察的知识点

Amazon GuardDuty的功能和用途，特别是其检测恶意活动（如加密货币挖矿）的能力。

Amazon EventBridge的规则配置，用于将GuardDuty的发现转发到Amazon SNS。

如何实现自动化安全监控和通知。

2. 选项分析

A. 使用 Guard 自定义策略创建 AWS Config 自定义规则

错误：AWS Config主要用于资源配置合规性检查，而不是实时检测恶意活动。虽然可以通过自定义规则检测某些行为，但它不适合用于检测加密货币挖矿活动。

B. 启用 Amazon GuardDuty，创建 EventBridge 规则发送警报到 SNS

正确：Amazon GuardDuty是专门设计用于检测恶意活动的服务，包括加密货币挖矿。通过EventBridge规则，可以将GuardDuty的发现转发到SNS以实现通知。

C. 启用 Amazon Inspector，创建 EventBridge 规则发送警报到 SNS

错误：Amazon Inspector主要用于评估应用程序的安全漏洞和合规性，而不是检测运行时的恶意活动（如加密货币挖矿）。

D. 启用 VPC 流日志，使用 Athena 查询检测 DNS 域名

错误：虽然可以通过VPC流日志和Athena查询检测某些行为，但这种方法需要复杂的配置和手动查询，不适合实时检测和通知加密货币挖矿活动。

▼ 90

▼ 英文:

A company controls user access by using IAM users and groups in AWS accounts across an organization in AWS Organizations.

The company uses an external identity provider (IdP) for workforce single sign-on (SSO).

The company needs to implement a solution to provide a single management portal to access accounts within the organization. The solution must support the external IdP as a federation source.

Which solution will meet these requirements?

A. Enable AWS IAM Identity Center. Specify the external IdP as the identity source.

- B. Enable federation with AWS Identity and Access Management (IAM). Specify the external IdP as the identity source.
- C. Migrate to Amazon Verified Permissions. Implement fine-grained access to AWS by using policy-based access control (PBAC).
- D. Migrate users to AWS Directory Service. Use AWS Control Tower to centralize security across the organization.

▼ 中文:

一家公司通过使用 IAM 用户和组在 AWS Organizations 中的 AWS 账户中控制用户访问权限。该公司使用外部身份提供商 (IdP) 进行员工单点登录 (SSO)。

该公司需要实施一个解决方案，以提供一个单一的管理门户来访问组织内的账户。该解决方案必须支持外部 IdP 作为联合源。哪种解决方案可以满足这些需求？

- A. 启用 AWS IAM Identity Center。指定外部 IdP 作为身份源。
- B. 启用 AWS Identity and Access Management (IAM) 的联合功能。指定外部 IdP 作为身份源。
- C. 迁移到 Amazon Verified Permissions。通过使用基于策略的访问控制 (PBAC) 实现对 AWS 的细粒度访问。
- D. 将用户迁移到 AWS Directory Service。使用 AWS Control Tower 在整个组织中集中安全管理。

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS IAM Identity Center（原AWS SSO）的功能和配置，特别是如何与外部身份提供商（IdP）集成以实现跨账户的单点登录（SSO）。

还涉及AWS Organizations的账户管理和集中化访问控制的知识。

2. 选项分析

A. Enable AWS IAM Identity Center. Specify the external IdP as the identity source.

正确：AWS IAM Identity Center（原AWS SSO）支持与外部身份提供商（IdP）集成，允许用户通过单一管理门户访问多个AWS账户。

IAM Identity Center可以直接配置外部IdP作为身份源，并支持AWS Organizations中的账户集中管理。

B. Enable federation with AWS Identity and Access Management (IAM). Specify the external IdP as the identity source.

错误：虽然IAM支持联合身份认证，但它不提供单一管理门户功能，也不直接支持跨账户的集中化访问管理。

IAM联合身份认证通常需要额外的配置和自定义开发，无法满足题目中“单一管理门户”的要求。

C. Migrate to Amazon Verified Permissions. Implement fine-grained access to AWS by using policy-based access control (PBAC).

错误：Amazon Verified Permissions是用于应用程序的权限管理服务，而不是用于AWS账户访问管理。

它不支持与外部IdP集成，也不提供单一管理门户功能。

D. Migrate users to AWS Directory Service. Use AWS Control Tower to centralize security across the organization.

错误：AWS Directory Service主要用于与Microsoft Active Directory集成，而不是直接支持外部IdP。

AWS Control Tower虽然可以帮助集中化管理，但它不提供单一管理门户功能，也不直接支持外部IdP作为身份源。

▼ 91

▼ 英文:

A company must create annual snapshots of Amazon Elastic Block Store (Amazon EBS) volumes. The company must retain the snapshots for 10 years. The company will use AWS Key Management Service (AWS KMS) to encrypt the EBS volumes and snapshots.

The encryption keys must be rotated automatically every year.

Snapshots that were created in previous years must be readable after rotation of the encryption keys.

Which type of KMS keys should the company use for encryption to meet these requirements?

A. Asymmetric AWS managed KMS keys with key material created by AWS KMS.

B. Symmetric customer managed KMS keys with key material created by AWS KMS

C. Symmetric customer managed KMS keys with custom imported key material

D. Asymmetric AWS managed KMS keys with custom imported key material

▼ 中文:

一家公司必须创建 Amazon Elastic Block Store (Amazon EBS) 卷的年度快照。该公司必须保留这些快照 10 年。公司将使用 AWS Key Management Service (AWS KMS) 来加密 EBS 卷和快照。

加密密钥必须每年自动轮换。在加密密钥轮换后，以往年份创建的快照必须可读。

公司应该使用哪种类型的 KMS 密钥进行加密以满足这些要求？

A. 由 AWS KMS 创建密钥材料的非对称 AWS 托管 KMS 密钥

B. 由 AWS KMS 创建密钥材料的对称客户托管 KMS 密钥

C. 使用自定义导入密钥材料的对称客户托管 KMS 密钥

D. 使用自定义导入密钥材料的非对称 AWS 托管 KMS 密钥

▼ 答案:

B

1. 考察的知识点

Amazon EBS加密与快照管理。

AWS Key Management Service (KMS)密钥类型及其特性。

密钥轮换与数据可读性。

2. 选项分析

A. Asymmetric AWS managed KMS keys with key material created by AWS KMS

非对称密钥主要用于数字签名和加密，而不是用于EBS卷加密。

非对称密钥不支持自动轮换。

因此此选项错误。

B. Symmetric customer managed KMS keys with key material created by AWS KMS

对称密钥是EBS卷加密的推荐选择。

对称客户托管密钥支持自动轮换，并且在密钥轮换后仍然可以解密之前的数据。

此选项正确。

C. Symmetric customer managed KMS keys with custom imported

key material

虽然对称密钥可以用于EBS加密，但使用自定义导入的密钥材料不支持自动轮换。

因此此选项错误。

D. Asymmetric AWS managed KMS keys with custom imported key material

非对称密钥不适用于EBS卷加密。

自定义导入的密钥材料不支持自动轮换。

因此此选项错误。

▼ 92

▼ 英文:

A company has hundreds of AWS accounts and uses AWS Organizations. The company plans to create many different IAM roles and policies for its product team, security team, and platform team. Some IAM policies will be shared across teams.

A security engineer needs to implement a solution to logically group together the IAM roles of each team. The solution must allow only the platform team to delegate IAM permissions to AWS services.

Which solution will meet these requirements?

A. Set up an IAM path with the IAM roles for each team. Deploy an SCP that denies the iam:PassRole permission to all entities except the IAM path of the platform team.

B. Apply different tags for each team to the IAM roles. Deploy an SCP that denies the sts:AssumeRole permission to all entities except the roles of the platform team.

C. Apply different tags for each team to the IAM policies. Deploy an SCP that denies the iam:PassRole permission to all entities except the policies of the platform team.

D. Set up an IAM path with the IAM roles for each team. Use IAM permissions boundaries to deny the sts:AssumeRole permission to the IAM roles for the product team and the security team.

▼ 中文:

一家公司拥有数百个AWS账户，并使用AWS Organizations。该公司计划为其产品团队、安全团队和平台团队创建许多不同的IAM角色和策略。一些IAM

策略将在团队之间共享。

一位安全工程师需要实施一个解决方案，以逻辑上将每个团队的IAM角色分组。该解决方案必须仅允许平台团队将IAM权限委托给AWS服务。哪种解决方案可以满足这些要求？

A.为每个团队的IAM角色设置IAM路径。部署一个SCP，拒绝所有实体的iam:PassRole权限，除了平台团队的IAM路径。

B.为IAM角色应用不同的标签以区分每个团队。部署一个SCP，拒绝所有实体的sts:AssumeRole权限，除了平台团队的角色。

C.为IAM策略应用不同的标签以区分每个团队。部署一个SCP，拒绝所有实体的iam:PassRole权限，除了平台团队的策略。

D.为每个团队的IAM角色设置IAM路径。使用IAM权限边界拒绝产品团队和安全团队IAM角色的sts:AssumeRole权限。

▼ 答案:

A

1. 考察的知识点

IAM路径的使用：如何通过IAM路径组织和管理IAM角色。

服务控制策略 (SCP)：如何使用SCP限制权限并实现跨账户的权限管理。

iam:PassRole权限：如何控制IAM角色的委托权限。

2. 选项分析

A.

正确：IAM路径可以用来逻辑分组IAM角色，方便管理和区分团队角色。

正确：SCP可以限制权限，部署一个SCP来拒绝所有实体的iam:PassRole权限，确保只有平台团队可以委托IAM权限给AWS服务。
此选项满足题目要求：逻辑分组角色并限制权限委托。

B.

错误：虽然标签可以区分团队，但标签不是逻辑分组IAM角色的最佳方法。

错误：题目要求限制iam:PassRole权限，而非sts:AssumeRole权限。

C.

错误：IAM策略不能直接用于逻辑分组IAM角色。

错误：题目要求限制IAM角色的权限，而非IAM策略的权限。

D.

错误：IAM权限边界用于限制IAM角色的权限，但无法实现跨账户的权限管理。

错误：题目要求限制iam:PassRole权限，而非sts:AssumeRole权限。

▼ 英文:

A company's developers are using AWS Lambda function URLs to invoke functions directly. The company must ensure that developers cannot configure or deploy unauthenticated functions in production accounts. The company wants to meet this requirement by using AWS Organizations. The solution must not require additional work for the developers.

Which solution will meet these requirements?

- A. Require the developers to configure all function URL to support cross-origin resource sharing (CORS) when the functions are called from a different domain.
- B. Use an AWS WAF delegated administrator account to view and block unauthenticated access to function URLs in production accounts, based on the OU of accounts that are using the functions.
- C. Use SCPs to allow all `lambda:CreateFunctionUrlConfig` and `lambda:UpdateFunctionUrlConfig` actions that have a `lambda:FunctionUrlAuthType` condition key value of `AWS_IAM`.
- D. Use SCPs to deny all `lambda:CreateFunctionUrlConfig` and `lambda:UpdateFunctionUrlConfig` actions that have a `lambda:FunctionUrlAuthType` condition key value of `NONE`

▼ 中文:

一家公司的开发人员正在使用 AWS Lambda 函数 URL 直接调用函数。公司必须确保开发人员无法在生产账户中配置或部署未经身份验证的函数。公司希望通过使用 AWS Organizations 来满足这一要求。解决方案必须不需要开发人员额外的工作。

哪种解决方案可以满足这些要求？

- A. 要求开发人员在函数从不同域调用时配置所有函数 URL 以支持跨域资源共享 (CORS)。
- B. 使用 AWS WAF 委派管理员账户查看并基于使用函数的账户 OU 阻止对生产账户中函数 URL 的未经身份验证的访问。
- C. 使用 SCPs 允许所有具有 `lambda:FunctionUrlAuthType` 条件键值为 `AWS_IAM` 的 `lambda:CreateFunctionUrlConfig` 和 `lambda:UpdateFunctionUrlConfig` 操作。

D.使用 SCPs 拒绝所有具有lambda:FunctionUrlAuthType 条件键值为 NONE 的 lambda:CreateFunctionUrlConfig 和 lambda:UpdateFunctionUrlConfig 操作。

▼ 答案:

D

1. 考察的知识点

本题考察的是AWS Organizations中的服务控制策略（SCP）的使用，以及如何通过SCP限制AWS Lambda函数URL的配置，以确保生产环境的安全性。

涉及的知识点包括：SCP的条件键使用、AWS Lambda函数URL的认证类型配置、以及如何通过AWS Organizations实现集中化的安全控制。

2. 选项分析

A. 要求开发人员在函数从不同域调用时配置所有函数 URL 以支持跨域资源共享 (CORS)。

错误：CORS是用于跨域资源共享的机制，与限制未经身份验证的函数URL无关。此选项无法满足题目要求的“防止未经身份验证的函数部署”的目标。

B. 使用 AWS WAF 委派管理员账户查看并基于使用函数的账户 OU 阻止对生产账户中函数 URL 的未经身份验证的访问。

错误：AWS WAF主要用于保护Web应用程序免受恶意流量攻击，而不是直接管理Lambda函数URL的认证配置。此选项无法直接解决题目要求的限制未经身份验证的函数URL的问题。

C. 使用 SCPs 允许所有具有 lambda:FunctionUrlAuthType 条件键值为 AWS_IAM 的 lambda:CreateFunctionUrlConfig 和 lambda:UpdateFunctionUrlConfig 操作。

错误：此选项试图通过允许特定条件的操作来解决问题，但它没有明确禁止未经身份验证的函数URL（即AuthType为NONE的情况）。因此，无法完全满足题目要求。

D. 使用 SCPs 拒绝所有具有 lambda:FunctionUrlAuthType 条件键值为 NONE 的 lambda:CreateFunctionUrlConfig 和 lambda:UpdateFunctionUrlConfig 操作。

正确：此选项通过SCP明确拒绝未经身份验证的函数URL（AuthType为NONE），完全符合题目要求。它确保生产环境中无法部署未经身份验证的函数URL，同时不会增加开发人员的额外工作。

▼ 英文:

A company is implementing new compliance requirements to meet customer needs. According to the new requirements, the company must not use any Amazon RDS DB instances or DB clusters that lack encryption of the underlying storage. The company needs a solution that will generate an email alert when an unencrypted DB instance or DB cluster is created. The solution also must terminate the unencrypted DB instance or DB cluster. Which solution will meet these requirements in the MOST operationally efficient manner?

A. Create an AWS Config managed rule to detect unencrypted RDS storage. Configure an automatic remediation action to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic that includes an AWS Lambda function and an email delivery target as subscribers. Configure the Lambda function to delete the unencrypted resource

B. Create an AWS Config managed rule to detect unencrypted RDS storage. Configure a manual remediation action to invoke an AWS Lambda function. Configure the Lambda function to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic and to delete the unencrypted resource.

C. Create an Amazon EventBridge rule that evaluates RDS event patterns and is initiated by the creation of DB instances or DB clusters. Configure the rule to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic that includes an AWS Lambda function and an email delivery target as subscribers. Configure the Lambda function to delete the unencrypted resource.

D. Create an Amazon EventBridge rule that evaluates RDS event patterns and is initiated by the creation of DB instances or DB clusters. Configure the rule to invoke an AWS Lambda function. Configure the Lambda function to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic and to delete the unencrypted resource.

▼ 中文:

一家公司正在实施新的合规要求以满足客户需求。根据新的要求，公司不得使用任何未加密底层存储的 Amazon RDS DB 实例或 DB 集群。公司需要一个解决方案，当创建未加密的 DB 实例或 DB 集群时，该解决方案能够生成电子邮件警报。解决方案还必须终止未加密的 DB 实例或 DB 集群。

哪个解决方案能够以最高的运营效率满足这些要求？

A. 创建一个 AWS Config 托管规则以检测未加密的 RDS 存储。配置一个自动修复操作，将消息发布到一个 Amazon Simple Notification Service (Amazon SNS) 主题，其中包括一个 AWS Lambda 函数和一个电子邮件发送目标作为订阅者。配置 Lambda 函数以删除未加密的资源。

B. 创建一个 AWS Config 托管规则以检测未加密的 RDS 存储。配置一个手动修复操作以调用一个 AWS Lambda 函数。配置 Lambda 函数将消息发布到一个 Amazon Simple Notification Service (Amazon SNS) 主题，并删除未加密的资源。

C. 创建一个 Amazon EventBridge 规则，该规则评估 RDS 事件模式并由创建 DB 实例或 DB 集群触发。配置该规则将消息发布到一个 Amazon Simple Notification Service (Amazon SNS) 主题，其中包括一个 AWS Lambda 函数和一个电子邮件发送目标作为订阅者。配置 Lambda 函数以删除未加密的资源

D. 创建一个 Amazon EventBridge 规则，该规则评估 RDS 事件模式并由创建 DB 实例或 DB 集群触发。配置该规则调用一个 AWS Lambda 函数。配置 Lambda 函数将消息发布到一个 Amazon Simple Notification Service (Amazon SNS) 主题，并删除未加密的资源。

▼ 答案:

A

1. 考察的知识点

AWS Config的托管规则及自动修复功能。

Amazon SNS用于通知机制。

AWS Lambda的自动化操作能力。

Amazon RDS加密存储的合规性要求。

2. 选项分析

A. Create an AWS Config managed rule to detect unencrypted RDS storage...

正确性分析：AWS Config托管规则可以自动检测未加密的RDS存储，并支持自动修复操作。通过SNS发布消息，结合Lambda函数可以实现通知和删除未加密资源的功能。这种方式是最自动化和高效的解决方案。

结论：正确。

B. Create an AWS Config managed rule to detect unencrypted RDS storage...

正确性分析：虽然AWS Config可以检测未加密的RDS存储，但手动修复操作需要人工干预，降低了操作效率，不符合题目要求的“最操作高效”的解决方案。

结论：错误。

C. Create an Amazon EventBridge rule that evaluates RDS event patterns...

正确性分析：EventBridge可以捕获RDS事件并触发后续操作，但它无法直接检测资源的加密状态。相比AWS

Config，EventBridge的实现复杂度更高，且不如Config托管规则直接针对加密状态的检测。

结论：错误。

D. Create an Amazon EventBridge rule that evaluates RDS event patterns...

正确性分析：与选项C类似，EventBridge无法直接检测加密状态，且需要额外的逻辑来实现加密状态的检查。相比AWS

Config，操作效率较低。

结论：错误。

▼ 95

▼ 英文:

A security engineer wants to evaluate configuration changes to a specific AWS resource to ensure that the resource meets compliance standards. However, the security engineer is concerned about a situation in which several configuration changes are made to the resource in quick succession. The security engineer wants to record only the latest configuration of that resource to indicate the cumulative impact of the set of changes. Which solution will meet this requirement in the MOST operationally efficient way?

A. Use AWS CloudTrail to detect the configuration changes by filtering API calls to monitor the changes. Use the most recent API call to indicate the cumulative impact of multiple calls.

B. Use AWS Config to detect the configuration changes and to record the latest configuration in case of multiple configuration changes.

- C. Use Amazon CloudWatch to detect the configuration changes by filtering API calls to monitor the changes. Use the most recent API call to indicate the cumulative impact of multiple calls.
- D. Use AWS Cloud Map to detect the configuration changes. Generate a report of configuration changes from AWS Cloud Map to track the latest state by using a sliding time window

▼ 中文:

一位安全工程师希望评估对特定 AWS 资源的配置更改，以确保该资源符合合规标准。然而，安全工程师担心在短时间内对资源进行多次配置更改的情况。安全工程师希望仅记录该资源的最新配置，以表明一组更改的累积影响。哪种解决方案将以最有效的操作方式满足此要求？

- A.使用 AWS CloudTrail 通过过滤 API 调用来检测配置更改以监控更改。使用最新的 API 调用来表明多次调用的累积影响。
- B.使用 AWS Config 检测配置更改，并在发生多次配置更改的情况下记录最新配置。
- C.使用 Amazon CloudWatch 通过过滤 API 调用来检测配置更改以监控更改。使用最新的 API 调用来表明多次调用的累积影响。
- D.使用 AWS Cloud Map 检测配置更改。从 AWS Cloud Map 生成配置更改报告，通过使用滑动时间窗口跟踪最新状态。

▼ 答案:

B

1. 考察的知识点

本题考察的是AWS服务中用于监控和记录资源配置变化的工具，尤其是如何高效地记录最新的资源配置以满足合规性要求。

重点知识点包括AWS Config、CloudTrail、CloudWatch和Cloud Map的功能及适用场景。

2. 选项分析

A. 使用 AWS CloudTrail 通过过滤 API 调用来检测配置更改以监控更改。使用最新的 API 调用来表明多次调用的累积影响。

CloudTrail主要用于记录API调用历史，适合审计和追踪用户活动，但它并不直接记录资源的最新配置状态。

虽然可以通过分析API调用来推断资源的状态，但这种方法效率低下且不适合处理快速连续的配置变化。

因此，此选项不符合题目要求。

B. 使用 AWS Config 检测配置更改，并在发生多次配置更改的情况下记录最新配置。

AWS Config专门设计用于记录资源的配置状态，并能够自动记录最新的配置变化。

它可以提供资源的最新状态和历史变化记录，完全符合题目要求。

此选项是正确答案。

C. 使用 Amazon CloudWatch 通过过滤 API 调用来检测配置更改以监控更改。使用最新的 API 调用来表明多次调用的累积影响。

CloudWatch主要用于监控性能指标和事件，而不是专门设计用于记录资源配置状态。

虽然可以通过过滤API调用来监控变化，但它无法直接记录资源的最新配置状态。

此选项不符合题目要求。

D. 使用 AWS Cloud Map 检测配置更改。从 AWS Cloud Map 生成配置更改报告，通过使用滑动时间窗口跟踪最新状态。

AWS Cloud Map主要用于服务发现和动态资源注册，而不是用于记录资源配置变化。

它无法直接提供资源的最新配置状态，也不适合处理快速连续的配置变化。

此选项不符合题目要求。

▼ 96

▼ 英文:

A company uses AWS Organizations to manage an organization that consists of three workload OUs. Production, Development, and Testing. The company uses AWS CloudFormation templates to define and deploy workload infrastructure in AWS accounts that are associated with the OUs. Different SCPs are attached to each workload OU.

The company successfully deployed a CloudFormation stack update to workloads in the Development OU and the Testing OU.

When the company uses the same CloudFormation template to deploy the stack update in an account in the Production OU, the update fails. The error message reports insufficient IAM permissions.

What is the FIRST step that a security engineer should take to troubleshoot this issue?

- A. Review the AWS CloudTrail logs in the account in the Production OU. Search for any failed API calls from CloudFormation during the deployment attempt.
- B. Remove all the SCPs that are attached to the Production OU. Rerun the CloudFormation stack update to determine if the SCPs were preventing the CloudFormation API calls.
- C. Confirm that the role used by CloudFormation has sufficient permissions to create, update, and delete the resources that are referenced in the CloudFormation template.
- D. Make all the SCPs that are attached to the Production OU the same as the SCPs that are attached to the Testing OU.

▼ 中文:

一家公司使用AWS Organizations来管理一个由三个工作负载OU组成的组织：Production、Development和Testing。该公司使用AWS CloudFormation模板来定义和部署与这些OU关联的AWS账户中的工作负载基础设施。每个工作负载OU都附加了不同的SCP。该公司成功地将CloudFormation堆栈更新部署到Development OU和Testing OU中的工作负载。当公司使用相同的CloudFormation模板在Production OU中的一个账户中部署堆栈更新时，更新失败。错误消息报告IAM权限不足。安全工程师应该采取的第一步来排查此问题是什么？

- A.查看Production OU中的账户的AWS CloudTrail日志。搜索CloudFormation在部署尝试期间的任何失败的API调用。
- B.移除附加到Production OU的所有SCP。重新运行CloudFormation堆栈更新以确定是否是SCP阻止了CloudFormation API调用。
- C.确认CloudFormation使用的角色是否有足够的权限来创建、更新和删除CloudFormation模板中引用的资源。
- D.将附加到Production OU的所有SCP设置为与附加到Testing OU的SCP相同。

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS Organizations中的服务控制策略（SCP）的作用和限

制，以及如何通过AWS CloudTrail日志进行权限问题的排查。
涉及的知识点包括：SCP的应用范围、IAM权限模型、CloudFormation的操作权限需求，以及CloudTrail日志的使用。

2. 选项分析

A.

正确：CloudTrail日志是排查权限问题的首选工具，可以帮助识别具体的API调用失败原因。

通过查看日志，可以确认是否是SCP限制了某些API调用，或者是IAM角色权限不足导致问题。

B.

错误：直接移除所有SCP可能会导致安全问题，因为SCP是用来限制账户权限的关键工具。

这种方法不符合最佳实践，应该先通过日志确认问题，而不是盲目移除策略。

C.

错误：虽然确认IAM角色权限是必要的，但题目中提到“Production OU”有特定的SCP，这表明问题可能与SCP限制有关，而不是IAM角色权限不足。

此选项忽略了SCP可能导致的权限问题。

D.

错误：不同OU的SCP通常是根据业务需求定制的，直接复制其他OU的SCP可能会破坏现有的安全策略。

此选项没有解决问题的根本原因，且可能引入新的安全风险。

▼ 97

▼ 英文:

A company hosts a web-based application that captures and stores sensitive data in an Amazon DynamoDB table. The company needs to implement a solution that provides end-to-end data protection and the ability to detect unauthorized data changes.

Which solution will meet these requirements?

A. Use an AWS Key Management Service (AWS KMS) customer managed key. Encrypt the data at rest.

B. Use AWS Private Certificate Authority. Encrypt the data in transit.

C. Use the DynamoDB Encryption Client. Use client-side encryption. Sign the table items.

D. Use the AWS Encryption SDK. Use client-side encryption. Sign the table items.

▼ 中文:

一家公司托管了一个基于网络的应用程序，该应用程序捕获并存储敏感数据在一个Amazon DynamoDB表中。该公司需要实施一个解决方案，提供端到端的数据保护以及检测未经授权的数据更改的能力。

哪个解决方案可以满足这些需求？

A.使用AWS Key Management Service (AWS KMS)客户管理密钥。对静态数据进行加密。

B.使用AWS Private Certificate Authority。对传输中的数据进行加密。

C.使用DynamoDB Encryption Client。使用客户端加密。对表项进行签名。

D.使用AWS Encryption SDK。使用客户端加密。对表项进行签名。

▼ 答案:

C

1. 考察的知识点

数据保护：包括数据加密（静态数据和传输中的数据）以及数据完整性验证。

客户端加密：如何在客户端对数据进行加密和签名以确保数据的安全性和完整性。

AWS服务：AWS KMS、AWS Private Certificate Authority、DynamoDB Encryption Client、AWS Encryption SDK的功能和适用场景。

2. 选项分析

A. 使用AWS Key Management Service (AWS KMS)客户管理密钥。对静态数据进行加密。

正确性分析：AWS KMS确实可以用于静态数据加密，但题目要求的是“端到端数据保护”和“检测未经授权的数据更改”。

仅使用AWS KMS加密静态数据无法满足数据完整性验证的需求。

结论：此选项不完全满足题目要求，因此错误。

B. 使用AWS Private Certificate Authority。对传输中的数据进行加密。

正确性分析：AWS Private Certificate Authority可以用于生成证书以加密传输中的数据，但题目要求的是“端到端数据保护”和“检测未经授权的数据更改”。此选项仅解决了传输中的数据加密问题，未涉及静态数据加密和数据完整性验证。

结论：此选项不完全满足题目要求，因此错误。

C. 使用DynamoDB Encryption Client。使用客户端加密。对表项进行签名。

正确性分析：DynamoDB Encryption Client支持客户端加密和数据签名，可以实现端到端数据保护，并能够检测未经授权的数据更改。这完全符合题目要求。

结论：此选项正确。

D. 使用AWS Encryption SDK。使用客户端加密。对表项进行签名。

正确性分析：AWS Encryption SDK支持客户端加密和数据签名，但它是一个通用的加密工具，而不是专门针对

DynamoDB的解决方案。相比之下，DynamoDB Encryp

▼ 98

▼ 英文:

A security engineer has created an Amazon GuardDuty detector in several AWS accounts. The accounts are in an organization in AWS Organizations. The security engineer needs centralized visibility of the security findings from the detectors.

Which solution will meet this requirement?

- A. Configure Amazon CloudWatch Logs Insights.
- B. Create an Amazon CloudWatch dashboard.
- C. Configure AWS Security Hub integrations.
- D. Query the findings by using Amazon Athena.

▼ 中文:

一位安全工程师在多个AWS账户中创建了Amazon GuardDuty检测器。这些账户属于AWS Organizations中的一个组织。安全工程师需要集中查看来自这些检测器的安全发现。

哪种解决方案可以满足此需求？

- A. 配置Amazon CloudWatch Logs Insights。
- B. 创建一个Amazon CloudWatch仪表板。
- C. 配置AWS Security Hub集成。
- D. 使用Amazon Athena查询发现。

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS安全服务的集成与集中化管理，特别是Amazon

GuardDuty与AWS Security Hub的集成能力。
重点在于如何实现跨账户的集中化安全可见性。

2. 选项分析

A. Configure Amazon CloudWatch Logs Insights. 配置Amazon CloudWatch Logs Insights。

错误：CloudWatch Logs Insights主要用于分析和查询日志数据，但它并不直接支持集中化管理GuardDuty的安全发现。

虽然可以通过日志流的方式将GuardDuty的发现导入CloudWatch Logs，但这需要额外的配置，并且不如AWS Security Hub直接支持GuardDuty集成。

B. Create an Amazon CloudWatch dashboard. 创建一个Amazon CloudWatch仪表板。

错误：CloudWatch仪表板主要用于监控和可视化指标数据，而不是专门用于集中化管理安全发现。

GuardDuty的发现是安全事件，而不是CloudWatch的指标数据，因此此选项不适合解决问题。

C. Configure AWS Security Hub integrations. 配置AWS Security Hub集成。

正确：AWS Security Hub是专门设计用于集中化管理和可视化多个AWS账户中的安全发现。

Security Hub支持与GuardDuty的原生集成，可以自动汇总和显示所有账户的安全发现。

这是实现集中化安全可见性的最佳解决方案。

D. Query the findings by using Amazon Athena. 使用Amazon Athena查询发现。

错误：虽然Athena可以查询存储在S3中的数据，但这需要将GuardDuty的发现导出到S3，并且需要手动编写查询。

这种方法复杂且不适合实时集中化管理安全发现。

▼ 99

▼ 英文:

A company runs workloads on Amazon EC2 instances in VPCs. The EC2 instances make requests to Amazon S3 buckets through VPC endpoints. The company uses AWS Organizations to manage its AWS accounts.

The company needs the requests from the EC2 instances to originate from the same VPC that the EC2 instance credentials

were issued to.

Which solution will meet this requirement?

- A. Deploy an SCP that includes the S3:* action with the "aws:SourceVpc": "\${aws:Ec2InstanceSourceVpc}" condition.
- B. Edit the VPC endpoints to include the S3:* action with the "aws:Ec2InstanceSourcePrivateIpv4": "\${aws:VpcSourceIp}" condition.
- C. Limit all actions in the S3 bucket policies by using the aws:SourceVpce condition key with the value of the allowed VPC endpoint.
- D. Limit all actions in the S3 bucket policies by using the aws:SourceVpc condition key with the value of the allowed VPC ID.

▼ 中文:

一家公司在 VPC 中的 Amazon EC2 实例上运行工作负载。这些 EC2 实例通过 VPC endpoints 向 Amazon S3 buckets 发出请求。该公司使用 AWS Organizations 来管理其 AWS 账户。

该公司需要确保来自 EC2 实例的请求来源于颁发 EC2 实例凭证的同一 VPC。

哪种解决方案可以满足此要求？

- A.部署一个 SCP，其中包括 S3:* 操作，并带有 "aws:SourceVpc": "\${aws:Ec2InstanceSourceVpc}" 条件。
- B.编辑 VPC endpoints 以包含 S3:* 操作，并带有 "aws:Ec2InstanceSourcePrivateIpv4": "\${aws:VpcSourceIp}" 条件。
- C.通过使用 aws:SourceVpce 条件键和允许的 VPC endpoint 的值，在 S3 bucket policies 中限制所有操作。
- D.通过使用 aws:SourceVpc 条件键和允许的 VPC ID 的值，在 S3 bucket policies 中限制所有操作。

▼ 答案:

D

1. 考察的知识点

VPC端点的安全性配置

S3存储桶策略的条件键使用

如何限制资源访问以确保请求来源于特定的VPC

2. 选项分析

A. Deploy an SCP that includes the S3:* action with the "aws:SourceVpc": "\${aws:Ec2InstanceSourceVpc}" condition.

错误：SCP（Service Control Policy）用于管理组织内账户的权限，但无法直接限制特定VPC的访问。SCP的作用范围是账户级别，而不是资源级别。

B. Edit the VPC endpoints to include the S3:* action with the "aws:Ec2InstanceSourcePrivateIpv4": "\${aws:VpcSourceIp}" condition.

错误：VPC端点的配置不支持直接使用

"aws:Ec2InstanceSourcePrivateIpv4"或"aws:VpcSourceIp"条件键。这些条件键不适

用于VPC端点的访问控制。

C. Limit all actions in the S3 bucket policies by using the aws:SourceVpce condition key with the value of the allowed VPC endpoint.

部分正确：使用"aws:SourceVpce"条件键可以限制访问来源于特定的VPC端点，但题目要求限制来源于特定的VPC，而不是特定的VPC端点。

D. Limit all actions in the S3 bucket policies by using the aws:SourceVpc condition key with the value of the allowed VPC ID.

正确：使用"aws:SourceVpc"条件键可以直接限制访问来源于特定的VPC。这完全符合题目要求。

▼ 100

▼ 英文:

A company uses Amazon Cognito for external user authentication for a web application. External users report that they can no longer log in to the application.

What is the FIRST step that a security engineer should take to troubleshoot the problem?

A. Review AWS CloudTrail logs to identify authentication errors that relate to Cognito users.

B. Use AWS Identity and Access Management Access Analyzer to delete all unused IAM roles and users.

C. Review any recent changes in Cognito configuration, IAM policies, and role trust policies to identify issues.

D. Write a script that uses CLI commands to reset all user passwords in the Cognito user pool.

▼ 中文:

一家公司使用 Amazon Cognito 为其网络应用程序进行外部用户身份验证。外部用户报告他们无法再登录到该应用程序。安全工程师应该采取的第一步来排查问题是什么？

- A. 查看 AWS CloudTrail 日志以识别与 Cognito 用户相关的身份验证错误。
- B. 使用 AWS Identity and Access Management Access Analyzer 删除所有未使用的 IAM 角色和用户。
- C. 查看 Cognito 配置、IAM 策略和角色信任策略中的任何最近更改，以识别问题。
- D. 编写一个脚本，使用 CLI 命令重置 Cognito 用户池中的所有用户密码。

▼ 答案:

C

本题考察的是 Amazon Cognito 的用户认证问题排查能力，以及对 AWS 服务（如 IAM、CloudTrail）的使用和配置变更的理解。

2. 选项分析

A.

分析：CloudTrail 日志可以帮助识别与 Cognito 用户相关的身份验证错误，但这不是排查问题的第一步。首先需要检查配

置是否有变更，因为配置问题可能是导致用户无法登录的主要原因。

结论：错误。

B.

分析：Access Analyzer 用于分析 IAM 权限和访问风险，与解决用户无法登录的问题无直接关系。删除未使用的 IAM 角色

和用户也不会解决当前问题。

结论：错误。

C.

分析：检查 Cognito 配置、IAM 策略和角色信任策略的变更是排查用户无法登录问题的合理第一步。配置变更可能直接导致用户认证失败。

结论：正确。

D.

分析：重置用户密码是一个极端的操作，且不一定能解决问题。问题可能与配置或策略相关，而不是用户密码本身。

结论：错误。

▼ 101

▼ 英文:

A company is running its application on AWS. Malicious users exploited a recent promotion event and created many fake accounts.

The application currently uses Amazon CloudFront in front of an Amazon API Gateway API. AWS Lambda functions serve the different API endpoints. The GET registration endpoint is behind the path of /store/registration. The URI for submission of the new account details is at /store/newaccount.

A security engineer needs to design a solution that prevents similar exploitations for future promotion events.

Which combination of steps will meet these requirements? (Choose two.)

- A. Create an AWS WAF web ACL. Add the AWSManagedRulesACFPRuleSet rule group to the web ACL. Associate the web ACL with the CloudFront distribution.
- B. Create an AWS WAF web ACL. Add a rate limit rule to the web ACL. Include a RateBasedStatement entry that has a SearchString value that points to /store/registration.
- C. Specify /store/registration as the registration page path. Specify /store/newaccount as the account creation path.
- D. Enable AWS Shield Advanced for the account that hosts the CloudFront distribution. Configure a DNS-specific custom.
- E. Enable Amazon GuardDuty for the account that hosts the CloudFront distribution. Enable Lambda Protection for the Lambda functions that answer calls to /store/registration and /store/newaccount.

▼ 中文:

一家公司正在 AWS 上运行其应用程序。恶意用户利用最近的促销活动创建了许多虚假账户。

该应用程序目前在 Amazon API Gateway API 前使用 Amazon CloudFront。AWS Lambda 函数为不同的 API 端点提供服务。GET 注册端点位于 /store/registration 路径后面。提交新账户详细信息的 URI 位于

/store/newaccount。

一名安全工程师需要设计一个解决方案，以防止未来促销活动中出现类似的利用行为。哪种步骤组合可以满足这些要求?(选择两项)

A.创建一个 AWS WAF web ACL。将 AWSManagedRulesACFPRuleSet 规则组添加到 web ACL 中。将 web ACL 与 CloudFront 分配关联。

B.创建一个 AWS WAF web ACL。向 web ACL 添加一个速率限制规则。在规则中包含一个 RateBasedStatement 条目，该条目具有指向 /store/registration 的 SearchString 值。

C.指定 /store/registration 作为注册页面路径。指定 /store/newaccount 作为账户创建路径。

D.为托管 CloudFront 分配的账户启用 AWS Shield Advanced。为 /store/newaccount 配置一个使用 Shield Response Team (SRT) 的 DNS 特定自定义缓解措施。

E.为托管 CloudFront 分配的账户启用 Amazon GuardDuty。为响应 /store/registration 和 /store/newaccount 调用的 Lambda 函数启用 Lambda Protection。

▼ 答案:

AB

1. 考察的知识点

AWS WAF的使用，包括规则组和速率限制规则。

如何保护API Gateway和CloudFront免受恶意流量攻击。

如何设计解决方案以防止滥用和恶意账户创建。

2. 选项分析

A.

正确:AWS WAF的AWSManagedRulesACFPRuleSet规则组包含一系列预定义规则，可以帮助检测和阻止常见的恶意流量模式，例如SQL注入和跨站脚本攻击。

将web ACL与CloudFront关联可以保护API Gateway后端免受恶意流量的攻击。

B.

正确:速率限制规则可以帮助检测和阻止短时间内大量请求的流量，这通常是恶意用户滥用的表现。

通过指定SearchString值为/store/registration，可以针对特定路径进行保护。

C.

错误:此选项仅描述了路径的定义，并未提供任何安全措施或解决方案。

D.

错误:AWS Shield Advanced主要用于防御DDoS攻击，而题目中并未提到DDoS攻击的场景。

此外，DNS特定的缓解措施与API Gateway的保护无直接关联。

E.

错误:Amazon GuardDuty是一个威胁检测服务，主要用于检测账户级别的异常活动，而不是直接保护API Gateway或CloudFront。

Lambda Protection是GuardDuty的一部分，但它的作用是检测Lambda函数的异常行为，而不是防止恶意账户创建。

▼ 102

▼ 英文:

A company is investigating an increase in its AWS monthly bill. The company discovers that bad actors compromised some Amazon EC2 instances and served webpages for a large email phishing campaign. A security engineer must implement a solution to monitor for cost increases in the future to help detect malicious activity. Which solution will offer the company the EARLIEST detection of cost increases?

A. Create an Amazon EventBridge rule that invokes an AWS Lambda function hourly. Program the Lambda function to download an AWS usage report from AWS Data Exports about usage of all services. Program the Lambda function to analyze the report and to send a notification when anomalies are detected.

B. Create a cost monitor in AWS Cost Anomaly Detection. Configure an individual alert to notify an Amazon Simple Notification Service (Amazon SNS) topic when the percentage above the expected cost exceeds a threshold.

C. Review AWS Cost Explorer daily to detect anomalies in cost from prior months. Review the usage of any services that experience a significant cost increase from prior months.

D. Capture VPC flow logs from the VPC where the EC2 instances run. Use a third-party network analysis tool to analyze the flow logs and to detect anomalies in network traffic that might increase cost.

▼ 中文:

一家公司正在调查其AWS月度账单的增加情况。该公司发现一些Amazon EC2实例被恶意行为者入侵，并用于为大规模电子邮件钓鱼活动提供网页服

务。

一名安全工程师必须实施一个解决方案，以监控未来的成本增加，从而帮助检测恶意活动。哪种解决方案可以为公司提供最早的成本增加检测？

A. 创建一个Amazon EventBridge规则，每小时调用一个AWS Lambda函数。编程Lambda函数以从AWS Data Exports下载关于所有服务使用情况的AWS使用报告。编程Lambda函数以分析报告并在检测到异常时发送通知。

B. 在AWS Cost Anomaly Detection中创建一个成本监控。配置一个单独的警报，当超过预期成本的百分比超过阈值时，通知一个Amazon Simple Notification Service (Amazon SNS)主题。

C. 每天审查AWS Cost Explorer，以检测前几个月成本中的异常情况。审查任何服务的使用情况，这些服务的成本与前几个月相比有显著增加。

D. 捕获运行EC2实例的VPC的VPC流日志。使用第三方网络分析工具分析流日志，并检测可能导致成本增加的网络流量异常。

▼ 答案:

B

1. 这题考察的知识点是什么

本题主要考察AWS成本监控与异常检测的能力，尤其是如何快速发现成本异常以应对潜在的安全问题。

涉及的服务包括AWS Cost Anomaly Detection、Amazon EventBridge、AWS Lambda、AWS Cost Explorer、VPC Flow Logs等。

2. 独立分析每个选项

A. Create an Amazon EventBridge rule that invokes an AWS Lambda function hourly...

正确性分析:此选项通过EventBridge定时触发Lambda函数来下载和分析使用报告，理论上可以实现成本监控。但这种方法依赖于手动编程和自定义逻辑，可能存在延迟(例如，报告生成和分析可能需要时间)，并且实现复杂度较高。

结论:虽然可行，但不是最早检测成本异常的解决方案。

B. Create a cost monitor in AWS Cost Anomaly Detection...

正确性分析:AWS Cost Anomaly Detection是专门设计用于检测成本异常的服务，能够基于机器学习模型快速识别异常并发送通知。此选项直接利用AWS原生服务，配置简单且检测及时。

结论:这是最早检测成本异常的解决方案。

C. Review AWS Cost Explorer daily...

正确性分析:手动审查Cost Explorer虽然可以发现成本异常，但需要人工干预，无法实现实时或快速检测，且效率较低。

结论:不适合作为最早检测成本异常的解决方案。

D. Capture VPC flow logs...

正确性分析:捕获VPC流日志并使用第三方工具分析网络流量可以帮助检测潜在的恶意活动，但这与成本监控的直接目标不完全匹配。此外，流日志分析可能需要较长时间，无法实现快速检测成本异常。

结论:不适合作为最早检测成本异常的解决方案。

▼ 103

▼ 英文:

A company's network security policy requires encryption for all data in transit. The company must encrypt data that is sent between Amazon EC2 instances and Amazon Elastic Block Store (Amazon EBS) volumes. Which solution will meet this requirement?

A. Configure Amazon EC2 to enable encryption in the EC2 network interface properties.

B. Configure Amazon EBS to enable volume encryption with AWS Key Management Service (AWS KMS) for data at rest.

C. Configure Amazon EBS to enable TLS encryption in the volume configuration properties.

D. Configure Amazon EC2 to enable TLS encryption with certificates that are stored in AWS Certificate Manager (ACM).

▼ 中文:

一家公司网络安全策略要求对所有传输中的数据进行加密。该公司必须加密在 Amazon EC2 实例与 Amazon Elastic BlockStore (Amazon EBS) 卷之间传输的数据。哪种解决方案可以满足此要求？

A. 配置 Amazon EC2，在 EC2 网络接口属性中启用加密。

B. 配置 Amazon EBS，使用 AWS Key Management Service (AWS KMS) 为静态数据启用卷加密。

C. 配置 Amazon EBS，在卷配置属性中启用 TLS 加密。

D. 配置 Amazon EC2，使用存储在 AWS Certificate Manager (ACM) 中的证书启用 TLS 加密。

▼ 答案:

D

1. 考察的知识点

本题考察的是AWS中数据传输加密的实现方式，特别是如何在Amazon EC2和Amazon EBS之间实现数据加密以满足网络安全策略要求。

涉及的技术包括TLS加密、AWS Certificate Manager (ACM)、以及AWS Key Management Service (KMS)。

2. 选项分析

A. Configure Amazon EC2 to enable encryption in the EC2 network interface properties.

错误:EC2网络接口属性中没有直接提供加密选项。数据加密需要通过其他机制(如TLS或IPsec)来实现。

B. Configure Amazon EBS to enable volume encryption with AWS Key Management Service (AWS KMS) for data at rest.

错误:EBS卷加密使用AWS KMS来加密静态数据(data at rest)，而不是数据在传输中的加密(data in transit)。本题要求的是数据传输加密。

C. Configure Amazon EBS to enable TLS encryption in the volume configuration properties.

错误:EBS卷配置属性中没有直接支持TLS加密的选项。TLS加密通常在网络层实现，而不是在EBS卷配置中实现。

D. Configure Amazon EC2 to enable TLS encryption with certificates that are stored in AWS Certificate Manager (ACM).

正确:TLS加密是数据传输加密的标准方法。通过使用存储在AWS Certificate Manager (ACM)中的证书，可以在EC2实例之间实现安全的TLS加密通信。

▼ 104

▼ 英文:

A company runs a web application on a fleet of Amazon EC2 instances that are in an Auto Scaling group. The EC2 instances are in the same VPC subnet as other workloads.

A security engineer deploys an Amazon GuardDuty detector in the same AWS Region as the EC2 instances. The security engineer also sets up an AWS Security Hub integration with GuardDuty.

The security engineer needs to implement an automated solution to detect and appropriately respond to anomalous traffic patterns for the web application. The solution must comply with AWS best practices for initial response to security incidents and must minimize disruption to the web application.

Which solution will meet these requirements?

- A. Create an Amazon EventBridge rule that detects the Behavior:EC2/TrafficVolumeUnusual GuardDuty finding. Configure the rule to invoke an AWS Lambda function to disable the EC2 instance profile access keys.
- B. Create an Amazon EventBridge rule that invokes an AWS Lambda function when GuardDuty detects anomalous traffic. Program the Lambda function to disassociate the identified instance from the Auto Scaling group and to isolate the instance by using a new restricted security group.
- C. Create a Security Hub automated response that updates the network ACL that is associated with the subnet of the EC2 instances. Configure the response to update the network ACL to deny traffic from the source of detected anomalous traffic.
- D. Create an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the security engineer's email address to the SNS topic. Configure GuardDuty to send all findings to the SNS topic.

▼ 中文:

一家公司在一个包含 Amazon EC2 实例的 Auto Scaling 组上运行一个 Web 应用程序。这些 EC2 实例与其他工作负载位于同一个 VPC 子网中。

一名安全工程师在与 EC2 实例相同的 AWS 区域中部署了一个 Amazon GuardDuty 检测器。安全工程师还设置了 GuardDuty 与 AWS Security Hub 的集成。

安全工程师需要实施一个[自动化解决方案](#)，以检测并适当地响应 Web 应用程序的异常流量模式。该解决方案必须符合 AWS 对安全事件初步响应的[最佳实践](#)，并且必须最大限度地减少对 Web 应用程序的干扰。

哪种解决方案可以满足这些要求？

- A. 创建一个 Amazon EventBridge 规则，用于检测 Behavior:EC2/TrafficVolumeUnusual GuardDuty 发现。配置该规则以调用一个 AWS Lambda 函数来禁用 EC2 实例配置文件的访问密钥。
- B. 创建一个 Amazon EventBridge 规则，当 GuardDuty 检测到异常流量时调用一个 AWS Lambda 函数。编写 Lambda 函数以将识别出的实例从 Auto Scaling 组中解除关联，并通过使用新的受限安全组来隔离该实例。
- C. 创建一个 Security Hub 自动响应，更新与 EC2 实例子网关联的网络 ACL。配置响应以更新网络 ACL，拒绝来自检测到的异常流量源的流量。

D.创建一个 Amazon Simple Notification Service (Amazon SNS) 主题。将安全工程师的电子邮件地址订阅到 SNS 主题。配置 GuardDuty 将所有发现发送到 SNS 主题。

▼ 答案:

B

1. 考察的知识点

Amazon GuardDuty的功能和使用场景。

Amazon EventBridge规则的配置与自动化响应。

AWS Lambda的集成与安全事件处理。

安全事件响应的最佳实践，包括隔离受影响资源。

2. 独立思考与分析

根据题目要求，解决方案需要能够自动检测异常流量并采取适当的响应措施，同时遵循AWS最佳实践以最小化对应用的干扰。

3. 选项分析

A. 创建一个 Amazon EventBridge 规则，用于检测

Behavior:EC2/TrafficVolumeUnusual GuardDuty 发现。配置该规则以调用一个 AWS Lambda 函数来禁用 EC2 实例配置文件的访问密钥。

分析:

禁用EC2实例配置文件的访问密钥并不能直接解决异常流量问题，因为流量问题通常与网络配置或实例本身的行为有

关，而不是与访问密钥相关。

此选项没有提到隔离受影响的实例，也没有采取措施来阻止异常流量，因此不符合最佳实践。

结论:错误。

B. 创建一个 Amazon EventBridge 规则，当 GuardDuty 检测到异常流量时调用一个 AWS Lambda 函数。编写 Lambda

函数以将识别出的实例从 Auto Scaling 组中解除关联，并通过使用新的受限安全组来隔离该实例。

分析:

此选项符合AWS最佳实践，因为它通过隔离受影响的实例来最小化对其他资源的影响。

解除实例与Auto Scaling组的关联可以防止Auto Scaling组自动替换受影响的实例，从而避免进一步的潜在问题。

使用受限安全组隔离实例是处理异常流量的有效方法。

结论:正确。

C. 创建一个 Security Hub 自动响应，更新与 EC2 实例子网关联的网络 ACL。配置响应以更新网络 ACL，拒绝来自检测到的异常流量源的流量。

分析:

更新网络ACL可以阻止异常流量，但这种方法可能会影响整个子网的流量，而不仅仅是受影响的实例。

此选项没有提到隔离受影响的实例，因此可能会导致其他实例受到影响。

虽然可以阻止流量，但不符合最小化干扰的要求。

结论:错误。

D. 创建一个 Amazon SNS 主题。将安全工程师的电子邮件地址订阅到 SNS 主题。配置 GuardDuty 将所有发现发送到 SNS 主题。

分析:

此选项仅提供通知功能，没有自动化响应措施，因此无法满足题目要求。

虽然可以让安全工程师了解问题，但无法立即采取行动来解决异常流量问题。

结论:错误。

▼ 105

▼ 英文:

A company has an application that needs to read objects from an Amazon S3 bucket. The company configures an IAM policy and attaches the policy to an IAM role that the application uses. When the application tries to read objects from the S3 bucket, the application receives AccessDenied errors.

A security engineer must resolve this problem without decreasing the security of the S3 bucket or the application. Which solution will meet these requirements?

A. Attach a resource policy to the S3 bucket to grant read access to the role.

B. Launch a new deployment of the application in a different AWS Region. Attach the role to the application.

C. Review the IAM policy by using AWS Identity and Access Management Access Analyzer to ensure that the policy grants the right permissions. Validate that the application is assuming the role correctly.

D. Ensure that the S3 Block Public Access feature is disabled on the S3 bucket. Review AWS CloudTrail logs to validate that the application is assuming the role correctly.

▼ 中文:

一家公司有一个应用程序需要从一个 Amazon S3 bucket 中读取对象。该公司配置了一个 IAM policy，并将该 policy 附加到应用程序使用的 IAM role 上。当应用程序尝试从 S3 bucket 中读取对象时，应用程序收到 AccessDenied 错误。

一名安全工程师必须解决此问题，**同时不降低 S3 bucket 或应用程序的安全性。哪种解决方案可以满足这些要求？**

- A. 将一个资源策略附加到 S3 bucket，以授予角色读取权限。
- B. 在不同的 AWS Region 中启动应用程序的新部署。将角色附加到应用程序。
- C. 使用 AWS Identity and Access Management Access Analyzer 审查 IAM policy，以确保 policy 授予正确的权限。验证应用程序是否正确地假设了角色。
- D. 确保 S3 的 Block Public Access 功能在 S3 bucket 上被禁用。审查 AWS CloudTrail 日志以验证应用程序是否正确地假设了角色。

▼ 答案:

C

1. 考察的知识点

IAM角色与策略的正确配置和权限验证。

使用AWS工具(如Access Analyzer和CloudTrail)进行权限问题排查。

Amazon S3的访问控制机制。

2. 选项分析

A. Attach a resource policy to the S3 bucket to grant read access to the role.

分析:虽然可以通过资源策略授予访问权限，但题目要求不降低S3 bucket的安全性。直接修改资源策略可能会导致过

度权限暴露，违背最小权限原则。

结论:错误。

B. Launch a new deployment of the application in a different AWS Region. Attach the role to the application.

分析:问题与Region无关，重新部署应用程序不会解决权限问题。此选项与题目要求无关。

结论:错误。

C. Review the IAM policy by using AWS Identity and Access Management Access Analyzer to ensure that the policy grants the

right permissions. Validate that the application is assuming the role correctly.

分析:使用Access Analyzer可以检查IAM策略是否正确配置，同时验证应用程序是否正确地假设了角色。这是解决权限问题的正确方法。

结论:正确。

D. Ensure that the S3 Block Public Access feature is disabled on the S3 bucket. Review AWS CloudTrail logs to validate that the application is assuming the role correctly.

分析:S3 Block Public Access功能与IAM角色权限问题无关。虽然CloudTrail日志可以帮助验证角色假设，但禁用Block Public Access可能会降低S3 bucket的安全性。

结论:错误。

▼ 106

▼ 英文:

A security engineer is designing a solution that will provide end-to-end encryption between clients and Docker containers running in Amazon Elastic Container Service (Amazon ECS). This solution will also handle volatile traffic patterns.

Which solution would have the MOST scalability and LOWEST latency?

A. Configure a Network Load Balancer to terminate the TLS traffic and then re-encrypt the traffic to the containers.

B. Configure an Application Load Balancer to terminate the TLS traffic and then re-encrypt the traffic to the containers.

C. Configure a Network Load Balancer with a TCP listener to pass through TLS traffic to the containers.

D. Configure Amazon Route 53 to use multivalue answer routing to send traffic to the containers.

▼ 中文:

一名安全工程师正在设计一个解决方案，该解决方案将为客户端和运行在 Amazon Elastic Container Service (Amazon ECS) 中的 Docker 容器之间提供端到端加密。该解决方案还将处理波动的流量模式。哪种解决方案具有最高的可扩展性和最低的延迟？

A.配置一个 Network Load Balancer 来终止 TLS 流量，然后将流量重新加密到容器。

- B.配置一个 Application Load Balancer 来终止 TLS 流量，然后将流量重新加密到容器。
- C. 配置一个带有 TCP 监听器的 Network Load Balancer，将 TLS 流量直接传递到容器。
- D. 配置 Amazon Route 53 使用多值答案路由将流量发送到容器。

▼ 答案:

C

1. 考察的知识点

Amazon ECS的网络架构和负载均衡器的使用。

TLS终端的处理方式及其对性能和延迟的影响。

如何设计高可扩展性和低延迟的解决方案。

2. 选项分析

A. Configure a Network Load Balancer to terminate the TLS traffic and then re-encrypt the traffic to the containers.

错误:虽然Network Load Balancer (NLB)可以处理高吞吐量和低延迟，但终止TLS流量会增加额外的加解密开销，从而增加延迟。

此外，重新加密流量到容器会进一步增加复杂性和延迟。

B. Configure an Application Load Balancer to terminate the TLS traffic and then re-encrypt the traffic to the containers.

错误:Application Load Balancer (ALB)主要用于HTTP/HTTPS流量，适合应用层的负载均衡。

终止TLS流量并重新加密会增加延迟，且ALB的性能在处理高吞吐量和低延迟场景时不如NLB。

C. Configure a Network Load Balancer with a TCP listener to pass through TLS traffic to the containers.

正确:NLB具有高吞吐量和低延迟的特点，使用TCP监听器可以直接将TLS流量传递到容器，而无需终止TLS。

这种方式避免了额外的加解密开销，确保了端到端加密，同时提供了最佳的性能和可扩展性。

D. Configure Amazon Route 53 to use multivalue answer routing to send traffic to the containers.

错误:Amazon Route 53的多值答案路由主要用于DNS级别的流量分发，无法处理TLS终端或提供负载均衡功能。

它不适合处理复杂的流量模式或提供低延迟的解决方案。

▼ 英文:

A company has a large fleet of Amazon Linux 2 Amazon EC2 instances that run an application. The application processes sensitive data and has the following compliance requirements:

- No remote access management ports to the EC2 instances can be exposed internally or externally.
- All remote session activity must be recorded in an audit log.
- All remote access to the EC2 instances must be authenticated and authorized by AWS IAM Identity Center.

The company's DevOps team occasionally needs to connect to one of the EC2 instances to troubleshoot issues.

Which solution will provide remote access to the EC2 instances while meeting the compliance requirements?

A. Grant access to the EC2 serial console at the account level. Create an IAM policy that allows an IAM role of the DevOps team to access the EC2 serial console.

B. Enable EC2 instance Connect on the AMI of the EC2 instances. Configure the appropriate security group rules. Grant EC2 console access to the DevOps team for access to EC2 instance Connect.

C. Assign an EC2 instance role that allows access to AWS Systems Manager. Create an IAM policy that grants access to Systems Manager Session Manager. Assign the policy to an IAM role of the DevOps team.

D. Use AWS Systems Manager Automation runbooks to open remote access ports to the EC2 instances. Attach a role to the EC2 instances to allow the runbooks to run.

▼ 中文:

一家公司拥有大量运行应用程序的 Amazon Linux 2 Amazon EC2 实例。该应用程序处理敏感数据，并具有以下合规性要求：

- 不能对 EC2 实例的远程访问管理端口进行内部或外部暴露。
- 所有远程会话活动必须记录在审计日志中。
- 所有对 EC2 实例的远程访问必须通过 AWS IAM Identity Center 进行身份验证和授权。

该公司的 DevOps 团队偶尔需要连接到其中一个 EC2 实例以排除故障。
哪种解决方案能够在满足合规性要求的同时提供对 EC2 实例的远程访问？

- A. 在账户级别授予对 EC2 串行控制台的访问权限。创建一个 IAM 策略，允许 DevOps 团队的 IAM 角色访问 EC2 串行控制台。
- B. 在 EC2 实例的 AMI 上启用 EC2 instance Connect。配置适当的安全组规则。授予 DevOps 团队 EC2 控制台访问权限以使用 EC2 instance Connect。
- C. 分配允许访问 AWS Systems Manager 的 EC2 实例角色。创建一个 IAM 策略，授予对 Systems Manager Session Manager 的访问权限。将该策略分配给 DevOps 团队的 IAM 角色。
- D. 使用 AWS Systems Manager Automation runbooks 打开对 EC2 实例的远程访问端口。为 EC2 实例附加一个角色以允许运行 runbooks。

▼ 答案:

C

EC2实例的安全访问方法。

AWS Systems Manager Session Manager的功能与使用。

IAM权限管理与授权。

如何满足合规性要求(无远程管理端口暴露、记录所有远程会话活动、通过IAM进行认证和授权)。

2. 选项分析

A. Grant access to the EC2 serial console at the account level...

分析:EC2串行控制台可以提供对实例的访问，但它不满足“记录所有远程会话活动”的要求。此外，串行控制台的使用

需要额外的配置，并不直接支持IAM Identity Center的认证和授权。

结论:错误。

B. Enable EC2 instance Connect on the AMI...

分析:EC2 Instance Connect允许通过SSH访问实例，但需要开放端口(如22端口)，这违反了“不暴露远程管理端口”的

合规要求。此外，它不支持记录所有远程会话活动。

结论:错误。

C. Assign an EC2 instance role that allows access to AWS Systems Manager...

分析:AWS Systems Manager Session Manager提供无代理、无端口的远程访问，并且会记录所有会话活动到CloudTrail或S3，完全符合合规要求。此

外，它可以通过IAM Identity Center进行认证和授权。结论:正确。

D. Use AWS Systems Manager Automation runbooks...

分析:使用Automation runbooks打开远程访问端口会违反“不暴露远程管理端口”的合规要求。此外，runbooks的主要用途是自动化任务，而不是提供交互式远程访问。

结论:错误。